



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temario para la preparación de la Oposición al Cuerpo Superior de
Sistemas y Tecnologías de la Información de la Administración del
Estado.

TEMAS ESPECÍFICOS – BLOQUE B
IV. Redes, comunicaciones e Internet

Tema 125. La seguridad en redes. Tipos de ataques y herramientas para su prevención: cortafuegos, control de accesos e intrusiones, técnicas criptográficas, etc. Medidas específicas para las comunicaciones móviles.

AUTOR: José Manuel Goberna Ruiz Poveda.

REVISOR: Guillermo Bayón del Oso.

Creación: septiembre 2023

ÍNDICE

1	LA SEGURIDAD EN REDES	5
1.1	INTRODUCCIÓN.....	5
1.2	ESTÁNDARES DE SEGURIDAD	5
1.3	FUNDAMENTOS DE SEGURIDAD DE RED	5
1.3.1	APLICACIÓN DE PRINCIPIOS DE SEGURIDAD FUNDAMENTALES AL DISEÑO DE REDES	6
1.3.2	TOPOLOGÍAS DE RED	6
1.3.3	SEGURIDAD DE RED PARA UN ENTORNO VIRTUAL	8
1.4	SEGURIDAD EN WiFi.....	10
1.5	SEGURIDAD EN SDN	10
1.5.1	VXLAN Y OVERLAYS.....	11
1.5.2	MICROSEGMENTACIÓN	12
1.5.3	INICIATIVAS DE CÓDIGO ABIERTO.....	13
1.6	SEGURIDAD EN LA NUBE	14
1.6.1	ESTÁNDARES DE SEGURIDAD EN LA NUBE	14
1.6.2	ARQUITECTURA SERVERLESS	15
1.6.3	DEVSECOPS.....	16
1.6.4	ZERO TRUST	17
1.6.5	SEGURIDAD EN LA NUBE EN UN ENTORNO MULTINUBE O DE NUBE HÍBRIDA.....	17
1.7	CONCLUSIÓN	19
2	TIPOS DE ATAQUES Y HERRAMIENTAS PARA SU PREVENCIÓN	20
2.1	INTRODUCCIÓN.....	20
2.2	TIPOS DE ATAQUES	20
2.2.1	ATAQUES DISTRIBUIDOS DE DENEGACIÓN DE SERVICIO.....	20
2.2.2	MÉTODOS DE INGENIERÍA SOCIAL	21
2.2.3	MÉTODOS DE PÉRDIDA Y EXFILTRACIÓN DE DATOS	21
2.2.4	VIRUS Y GUSANOS.....	22
2.2.4.1	TIPOS Y MÉTODOS DE TRANSMISIÓN.....	22
2.2.4.2	CARGAS ÚTILES DE MALWARE	22
2.2.5	TROYANOS	23
2.2.5.1	TIPOS DE TROYANOS	23
2.2.5.2	PUERTOS TROYANOS Y MÉTODOS DE COMUNICACIÓN	24
2.2.6	DISTRIBUCIÓN DE MALWARE	24
2.2.7	RANSOMWARE	24
2.2.8	COMUNICACIÓN ENCUBIERTA	25
2.2.9	KEYLOGGERS	25
2.2.10	SPYWARE	26
2.2.11	ATAQUES DE COMPUTACIÓN EN LA NUBE.....	26
2.2.12	AMENAZAS DE SEGURIDAD DE IOT	27
2.3	HERRAMIENTAS PARA LA PREVENCIÓN DE ATAQUES	28
2.3.1	CORTAFUEGOS	28
2.3.1.1	METODOLOGÍAS DE FIREWALL.....	28

2.3.1.1.1	FILTRADO ESTÁTICO DE PAQUETES.....	28
2.3.1.1.2	PUERTA DE ENLACE DE LA CAPA DE APLICACIÓN	29
2.3.1.1.3	FILTRADO DE PAQUETES CON ESTADO	29
2.3.1.1.4	INSPECCIÓN DE APLICACIONES.....	29
2.3.1.1.5	FIREWALLS TRANSPARENTES	29
2.3.1.2	FIREWALLS DE PRÓXIMA GENERACIÓN (NGFW)	29
2.3.1.3	TRADUCCIÓN DE DIRECCIONES DE RED (NAT).....	30
2.3.1.4	CONFIGURACIONES DE FIREWALL.....	32
2.3.2	CONTROL DE ACCESOS.....	32
2.3.2.1	AUTENTICACIÓN	33
2.3.2.1.1	AUTENTICACIÓN POR CONOCIMIENTO	33
2.3.2.1.2	AUTENTICACIÓN POR PROPIEDAD O POSESIÓN	33
2.3.2.1.3	AUTENTICACIÓN POR CARACTERÍSTICA	34
2.3.2.1.4	AUTENTICACIÓN MULTIFACTOR (MFA)	34
2.3.2.2	AUTORIZACIÓN	35
2.3.2.2.1	CONTROL DE ACCESO OBLIGATORIO (MAC)	35
2.3.2.2.2	CONTROL DE ACCESO DISCRECIONAL (DAC)	35
2.3.2.2.3	CONTROL DE ACCESO BASADO EN ROLES (RBAC).....	35
2.3.2.2.4	CONTROL DE ACCESO BASADO EN REGLAS.....	36
2.3.2.2.5	CONTROL DE ACCESO BASADO EN ATRIBUTOS (ABAC).....	36
2.3.2.3	RESPONSABILIDAD (ACCOUNTING)	36
2.3.2.4	PROTOCOLOS AAA.....	36
2.3.2.4.1	RADIUS	36
2.3.2.4.2	TACACS+	37
2.3.2.4.3	DIAMETER.....	37
2.3.2.4.4	KERBEROS.....	37
2.3.2.4.5	802.1X	38
2.3.2.5	LISTAS DE CONTROL DE ACCESO (ACL)	38
2.3.3	CONTROL DE INTRUSIONES	39
2.3.3.1	IDS E IPS	39
2.3.3.2	DIFERENCIA ENTRE IPS E IDS.....	39
2.3.3.3	TÉCNICAS IPS	40
2.3.3.4	NGIPS	41
2.3.3.5	IDENTIFICACIÓN DEL TRÁFICO MALICIOSO EN LA RED	41
2.3.4	TÉCNICAS CRIPTOGRÁFICAS	42
2.3.4.1	PROTOCOLO DE TÚNEL PUNTO A PUNTO.....	42
2.3.4.2	IPSEC.....	43
2.3.4.3	SSL/TLS	43
2.4	CONCLUSIÓN	44
3	MEDIDAS ESPECÍFICAS PARA LAS COMUNICACIONES MÓVILES.....	45
3.1	INTRODUCCIÓN.....	45
3.2	LA SEGURIDAD EN REDES MÓVILES: AMENAZAS Y MEDIDAS DE PROTECCIÓN ...	45
3.2.1	AMENAZAS DE SEGURIDAD Y PROTECCIÓN PARA 1G	46
3.2.2	AMENAZAS DE SEGURIDAD Y PROTECCIÓN PARA 2G	47
3.2.3	AMENAZAS DE SEGURIDAD Y PROTECCIÓN PARA 3G	48
3.2.4	AMENAZAS DE SEGURIDAD Y PROTECCIÓN PARA 4G	48
3.2.5	AMENAZAS DE SEGURIDAD Y PROTECCIÓN PARA 5G	49
3.3	ASPECTOS FUNDAMENTALES DE LA SEGURIDAD EN LAS REDES 5G	50
3.3.1	SEGURIDAD EN LA CAPA FÍSICA.....	50
3.3.2	SEGURIDAD EN LA CAPA DE ENLACE DE DATOS	51
3.3.3	SEGURIDAD EN LA CAPA DE CONTROL	52
3.3.4	MONITORIZACIÓN DE TRÁFICO.....	52
3.3.5	CONTROL DE ACCESO	53
3.3.6	RESILIENCIA DE RED.....	53
3.3.7	SISTEMAS DE SEGURIDAD Y CORTAFUEGOS	53

3.3.8	AUTOMATIZACIÓN DE LA SEGURIDAD DE RED	54
3.4	CONCLUSIÓN	54
4	RESUMEN ESQUEMÁTICO	55
5	GLOSARIO	57
6	TEST	59
6.1	PREGUNTAS DE TEST	59
6.2	SOLUCIONES A LAS PREGUNTAS DE TEST	64
7	BIBLIOGRAFÍA BÁSICA	65
7.1	BIBLIOGRAFÍA BÁSICA	65
7.2	BIBLIOGRAFÍA PARA AMPLIAR EL TEMA	65

1 La seguridad en redes

1.1 Introducción

Este tema es ambicioso al pretender hacer un compendio de aplicación de seguridad de manera transversal a los principales tipos de redes del temario, como son las redes inalámbricas WiFi y móviles, las redes cloud, las redes virtuales o SDN y a redes más propias del ámbito industrial como el IoT.

A lo largo del presente documento se realiza un análisis exhaustivo de todos los aspectos de seguridad en redes de telecomunicaciones, apoyándose en conceptos que corresponden a otros temas, como el análisis forense (ciberseguridad), análisis de riesgos, seguridad en el nivel de aplicación, redes de comunicaciones móviles, protocolos de redes IP, criptografía, WiFi (tecnologías de acceso), DevOps, IoT o cloud.

1.2 Estándares de seguridad

Existen ciertos estándares de seguridad de la información reconocidos internacionalmente que se destacan a continuación que se pueden seguir durante el diseño e implantación de la seguridad en redes:

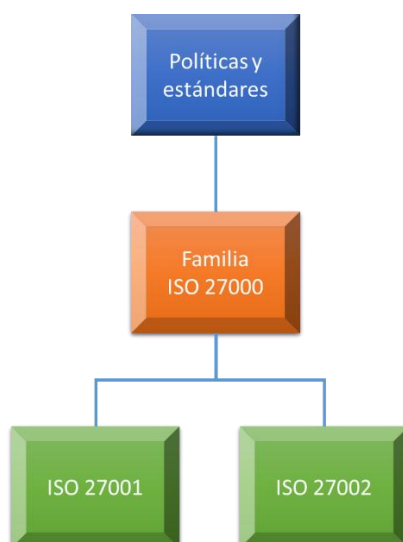


Figura 1: Estándares en seguridad de la información

- **ISO 27001.** Esta norma proporciona las mejores prácticas para un Sistema de Gestión de Seguridad de la Información (SGSI). Este estándar de sistema de gestión está diseñado para administrar los datos confidenciales de una organización junto con sus políticas y procedimientos establecidos. La ausencia de SGSI hace que la organización sea vulnerable a los ataques cibernéticos y las fugas de datos. Por lo tanto, este sistema es un componente crítico dentro de una organización.
- **ISO 27002.** Trata sobre las directrices para las prácticas del Sistema de Gestión de Seguridad de la Información (SGSI) organizacionales, incluida la selección, implementación y gestión de controles teniendo en cuenta el entorno de riesgo de seguridad de la información de la organización.

1.3 Fundamentos de seguridad de red

La seguridad es importante, y la falta de ella pone en riesgo las implicaciones financieras, legales, políticas y de relaciones públicas. Esta sección cubre algunos de los conceptos, términos y metodologías utilizados en la preparación y el trabajo con redes seguras.

Los objetivos de seguridad de red generalmente involucran tres conceptos básicos (la conocida tríada CIA, en inglés: Confidentiality, Integrity and Availability).

- **Confidencialidad.** Hay dos tipos de datos: datos en movimiento a medida que circulan a través de la red; y datos en reposo, cuando los datos se encuentran en medios de almacenamiento (servidor, estación de trabajo local, en la nube, etc.). Confidencialidad significa que solo las personas o sistemas autorizados pueden ver información sensible o clasificada. Esto también implica que las personas no autorizadas no deben tener ningún tipo de acceso a los datos. Con respecto a los datos en movimiento, la forma principal de proteger esos datos es cifrarlos antes de enviarlos a través de la red.
- **Integridad.** La integridad de los datos significa que los cambios realizados en los datos son realizados únicamente por individuos o sistemas autorizados. La corrupción de datos es un fallo en la tarea de mantenimiento de la integridad de los datos.
- **Disponibilidad.** Esto se aplica a los sistemas y a los datos. Si la red o sus datos no están disponibles para los usuarios autorizados, tal vez debido a un ataque de denegación de servicio (DoS) o tal vez debido a un fallo general de la red, el impacto puede ser significativo para las empresas y los usuarios que confían en esa red como herramienta comercial.

Se asume el conocimiento de los conceptos de activo, amenaza, vulnerabilidad y riesgo, tratados en otro de los temas.

1.3.1 Aplicación de principios de seguridad fundamentales al diseño de redes

Se establecen algunos principios y pautas básicos en las primeras etapas del diseño e implementación de una red. A continuación se describen estas directrices clave.

- **Principio de mínimo privilegio.** Establece que a todos los usuarios se les debe otorgar solo el nivel de privilegio que necesitan para hacer su trabajo, y no más. Es por eso que siempre debe limitar los usuarios, las aplicaciones y los procesos para que accedan y se ejecuten con el privilegio mínimo que necesitan.
- **Defensa en profundidad (Defense in Depth, DID).** Este concepto sugiere que tiene seguridad implementada en casi todos los puntos de su red. Los métodos adicionales que se pueden usar para implementar un enfoque de defensa en profundidad incluyen el uso de mecanismos de autenticación y autorización, seguridad web y de correo electrónico, seguridad de contenido, monitorización de inspección de aplicaciones, monitorización de tráfico y protección contra malware. El concepto detrás de la defensa en profundidad es que, si falla una sola tecnología de seguridad, aún existen niveles o mecanismos adicionales de seguridad para proteger los datos, las aplicaciones y los dispositivos en la red.
- **Separación de funciones.** Es un control administrativo que dicta que una sola persona no debe realizar todas las tareas de nivel crítico o privilegiado. Además, las tareas importantes deben separarse o dividirse entre varios individuos dentro de la organización. El objetivo es protegerse contra un solo individuo que realiza acciones suficientemente críticas o privilegiadas que podrían dañar seriamente un sistema o la organización en su conjunto.
- **Auditoría.** Esto se refiere a la responsabilidad (accounting) y el mantenimiento de registros sobre lo que está ocurriendo en la red. La mayor parte de esto se puede automatizar a través de las características de autenticación, autorización y responsabilidad (AAA, ver apartado 2.3.2 Control de accesos). Cuando ocurren eventos en la red, los registros de esos eventos se pueden enviar a un servidor de responsabilidad.

1.3.2 Topologías de red

Existen varias topologías de red que dependen del tamaño y el tipo de cada organización. Algunas organizaciones tendrán presencia de cada una de las siguientes topologías, mientras que otras solo pueden utilizar un subconjunto de esta lista. A continuación se presenta una descripción y representación de cada una de las diferentes topologías que pueden formar la red de toda organización.

- ❖ **Red de área de campus (CAN):** Una red de área de campus, como se ilustra en la Figura 2, es la topología de red utilizada para proporcionar conectividad, datos, aplicaciones y servicios a los usuarios de una organización que se encuentran físicamente en la oficina corporativa (sede). El CAN incluye un módulo para cada edificio del campus, para el centro de datos, para la agregación WAN y para Internet Edge.

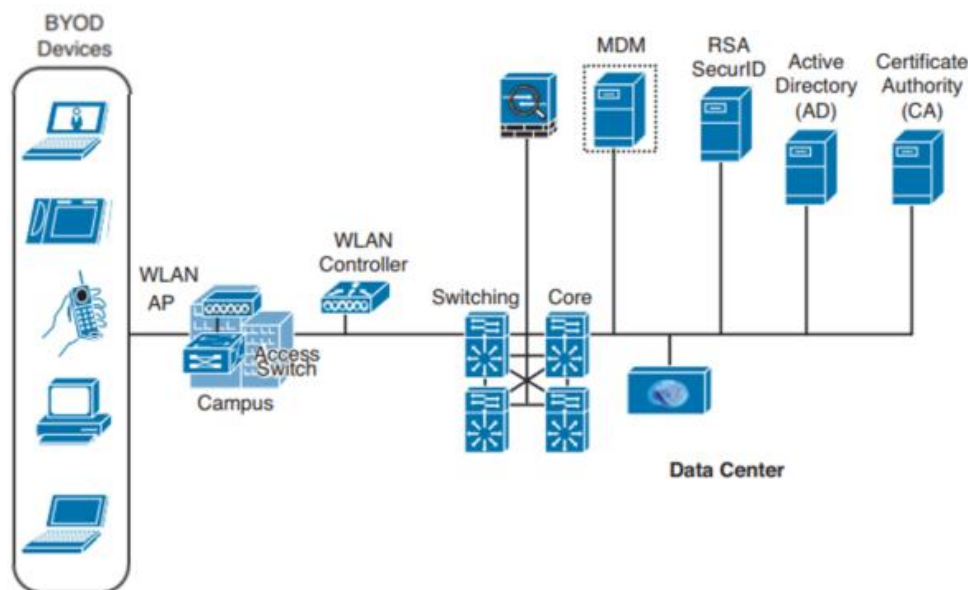


Figura 2: Topología de red de área de campus

- ❖ **Nube, red de área amplia (WAN):** La nube y la WAN proporcionan una ubicación lógica y física para los datos y las aplicaciones que una organización prefiere mover fuera del sitio, como se ilustra en la Figura 3. Esto alivia que una organización tenga que gastar recursos para operar, mantener y administrar los servicios que se han ubicado previamente dentro del ámbito de la organización.

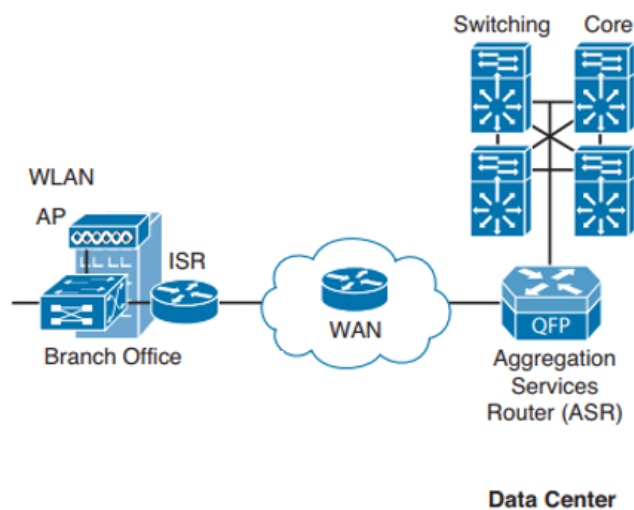


Figura 3: Topología de nube/WAN

- ❖ **Centro de datos (DC):** La red del Data Center contiene los servidores, las pasarelas de voz y otros elementos, todos los cuales reciben conectividad de red mediante una serie de switches de data center, como se ilustra en la Figura 4. Toda la red del centro de datos está protegida por un conjunto de firewalls en el borde que filtra todo el tráfico que entra y sale del centro de datos.

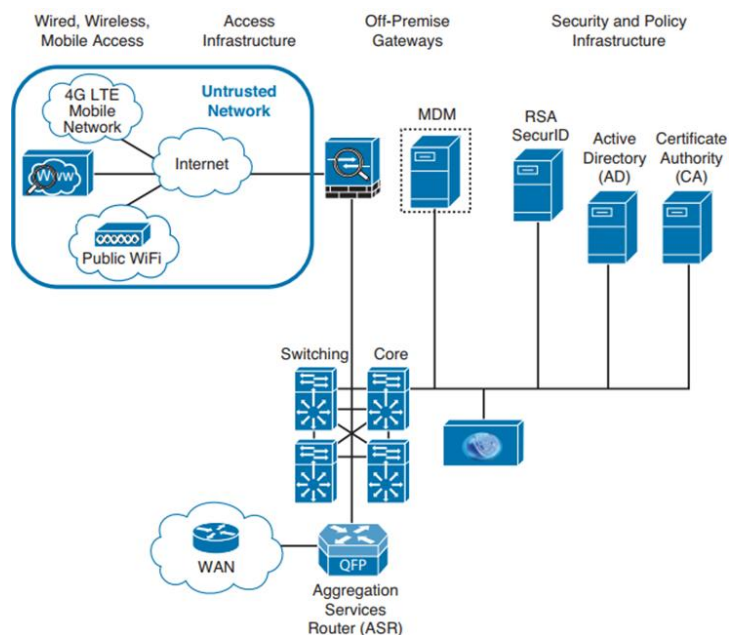


Figura 4. Topología del centro de datos

- ❖ **Oficina pequeña/oficina doméstica (en inglés, Small Office/Home Office o SOHO):** El sitio SOHO remoto proporcionará conectividad a los usuarios de SOHO mediante el uso de enrutadores WAN que encuentran su camino de regreso al módulo de agregación WAN en la CAN, como se ilustra en la Figura 5. Dentro del SOHO, los usuarios reciben conectividad de red a través de la presencia de switches de acceso.

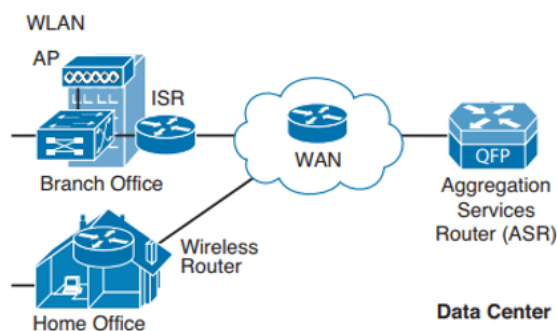


Figura 5: Topología de sucursal/oficina doméstica

1.3.3 Seguridad de red para un entorno virtual

Los entornos de centros de datos actuales deben diseñarse para reducir significativamente la sobrecarga administrativa y mejorar la flexibilidad y la eficiencia operativa. Las funciones de seguridad críticas deben poder escalar dinámicamente para proteger los activos a medida que cambian las demandas del negocio.

La Figura 6 ilustra un entorno de centro de datos de alto nivel con múltiples conexiones de red y define el concepto de tráfico este-oeste frente a norte-sur.

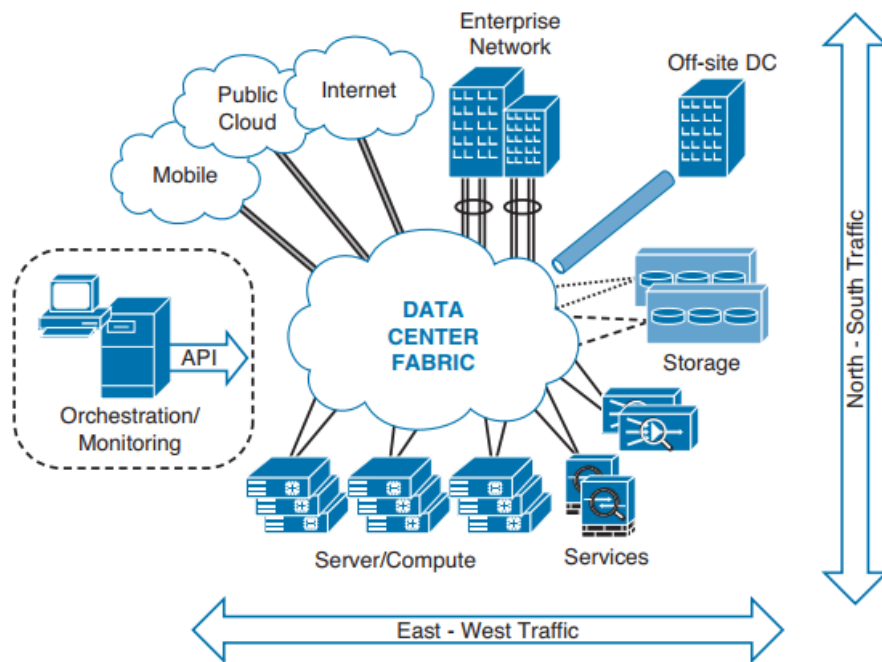


Figura 6: Entorno de centro de datos de alto nivel y definiciones de tráfico

La Figura 7 muestra un centro de datos virtualizado donde se utilizan varias aplicaciones de software (como VMWare, KVM, Xen) para dividir un servidor físico en varios entornos virtuales aislados. En este ejemplo, se implementan firewalls físicos para proporcionar protección y segmentación al centro de datos respecto del resto de la red corporativa.

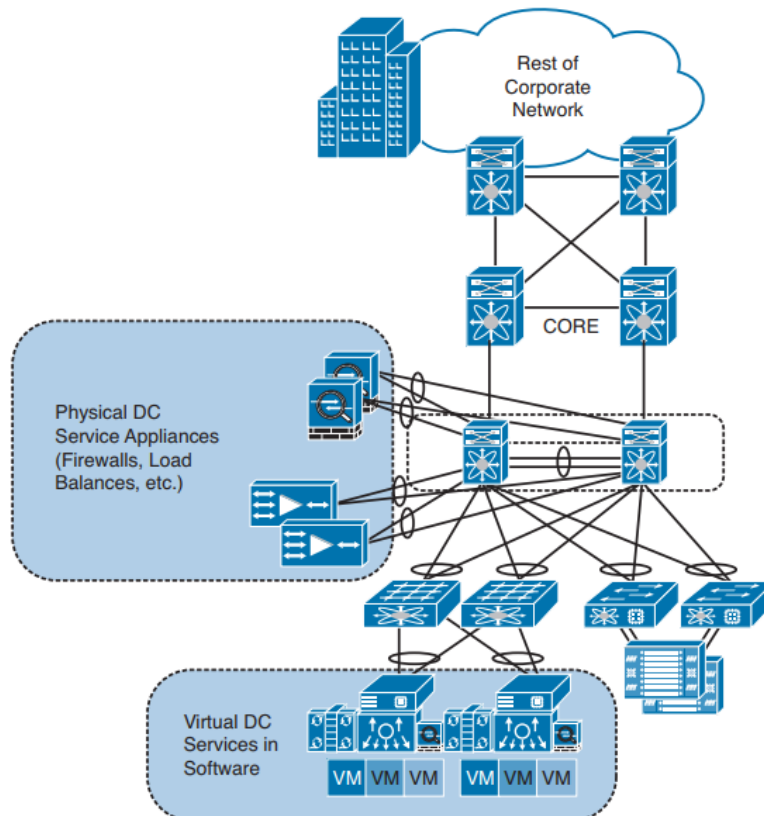


Figura 7: Topología virtualizada del centro de datos

El desafío de usar firewalls físicos y otros dispositivos de seguridad en un entorno virtualizado es que a veces el tráfico no sale del servidor físico (a menudo denominado bare metal). A la postre se necesita una solución de seguridad virtual.

1.4 Seguridad en WiFi

Dado que las redes inalámbricas son cada vez más frecuentes, es importante considerar la seguridad de las redes inalámbricas. Hay cuatro protocolos de seguridad Wi-Fi, que van desde el más antiguo y menos seguro (WEP) hasta el más reciente y seguro (WPA3). Cada uno de ellos se describe brevemente aquí.

- **WEP.** Wired Equivalent Privacy (WEP) utiliza el cifrado de flujo RC4 para proteger los datos y una suma de comprobación CRC-32 para la comprobación de errores. WEP estándar utiliza una clave de 40 bits (conocida como WEP-40) con un vector de inicialización (IV) de 24 bits para formar efectivamente un cifrado de 64 bits. WEP de 128 bits utiliza una clave de 104 bits con un IV de 24 bits.
Debido a que RC4 es un cifrado de flujo, la misma clave de tráfico nunca debe usarse dos veces. No es seguro, ya que es muy fácil en la actualidad romper este protocolo.
- **WPA.** El acceso protegido Wi-Fi (WPA) fue definitivamente una mejora con respecto a WEP. Primero, WPA usa AES, que es un algoritmo de cifrado muy bueno. A continuación, WPA utiliza el Protocolo de integridad de clave temporal. TKIP genera dinámicamente una nueva clave para cada paquete. Entonces, incluso si descifra una clave WPA, habrá una clave diferente para el siguiente paquete.
Este protocolo es fácil de romper con métodos como el de fuerza bruta en relativamente poco tiempo.
- **WPA2.** WPA2 se basa en el estándar IEEE 802.11i. Proporciona el estándar de cifrado avanzado (AES) utilizando el protocolo CCMP, (Counter Mode-Cipher Block Chaining-Message Authentication Code-Protocol) que proporciona confidencialidad de datos, autenticación de origen de datos e integridad de datos para tramas inalámbricas. El encadenamiento de bloques de cifrado evita los ataques de texto sin formato conocidos.
El Message Authentication Code (MAC) preserva la integridad del mensaje y garantiza que los paquetes no se hayan alterado en tránsito, ya sea accidental o intencionalmente. Esto significa que WPA2 utiliza un cifrado muy fuerte junto con la integridad del mensaje.
Se han detectado varias vulnerabilidades claves de gestión en el handshake de 4 vías de este protocolo y ha dejado de ser seguro.
- **WPA3.** Esta es la forma más moderna de seguridad Wi-Fi, y si es posible, esto es lo que debe usar. Fue anunciado en enero de 2018 por la Wi-Fi Alliance. Hay dos tipos: WPA3-Personal y WPA3-Empresarial. El nuevo estándar utiliza cifrado de 128 bits en modo WPA3-Personal (192 bits en WPA3-Empresarial) y confidencialidad de reenvío. El estándar WPA3 también reemplaza el intercambio de claves pre-compartidas con la autenticación simultánea de iguales, lo que resulta en un intercambio inicial de claves más seguro en modo personal.

1.5 Seguridad en SDN

Los cambios tecnológicos producidos en la última década se deben a la demanda de aplicaciones modernas en entornos muy diversos y a la nube. Esta complejidad introduce riesgos, incluidos errores de configuración de red que pueden causar un tiempo de inactividad significativo y desafíos de seguridad de red.

Estos elementos han impulsado la creación de redes definidas por software (SDN). SDN se creó originalmente para desacoplar el control de las funciones de reenvío en equipos de red. Esto se hace para usar software para administrar y programar centralmente el hardware y los dispositivos de red virtual para realizar el reenvío.

En las redes tradicionales, hay tres planos o elementos diferentes que permiten que los dispositivos de red funcionen: los planos de administración, control y datos.

El plano de control siempre ha estado separado del plano de datos. No había un cerebro central (o controlador) que controlara la configuración y el reenvío. En el ejemplo que se muestra en la Figura 8, los enrutadores, conmutadores y cortafuegos son administrados por la interfaz de línea de comandos (CLI), las interfaces gráficas de usuario (GUI) y los scripts Tcl personalizados. Por ejemplo, los firewalls son administrados por el Administrador de dispositivos de seguridad adaptable (ASDM), mientras que los enrutadores son administrados por la CLI.

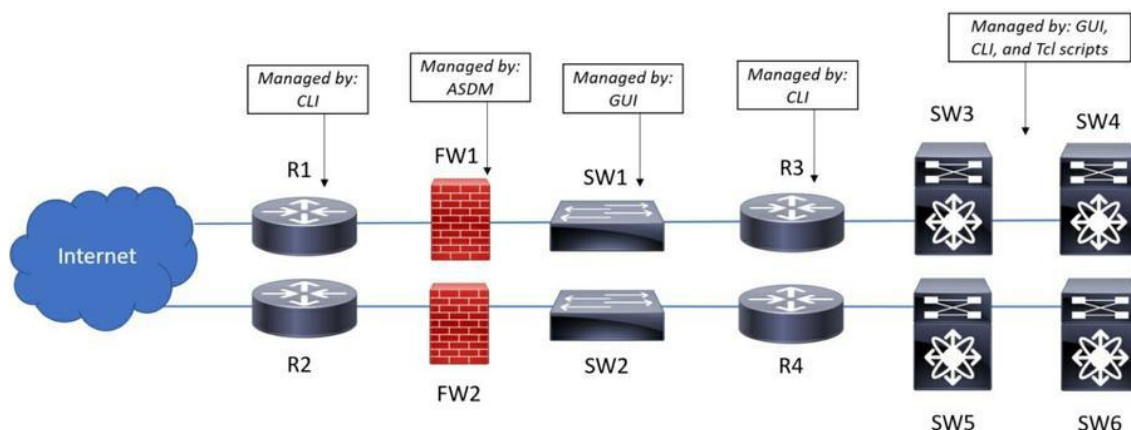


Figura 8: Soluciones tradicionales de administración de redes

Cada dispositivo en la Figura 8 tiene su "propio cerebro" y realmente no intercambia ninguna información inteligente con el resto de los dispositivos.

SDN introdujo la noción de un controlador centralizado. El controlador SDN tiene una vista global de la red y utiliza un protocolo de administración común para configurar los dispositivos de infraestructura de red. El controlador SDN también puede calcular la información de accesibilidad de muchos sistemas en la red y lanza un conjunto de flujos a los switches. Los flujos son utilizados por el hardware para hacer el reenvío. Aquí puede ver una clara transición de un enfoque distribuido de "cerebro semi-inteligente" a un enfoque de "cerebro central e inteligente".

SDN cambió algunas cosas en los planos de administración, control y datos. Sin embargo, el gran cambio fue en los planos de control y datos en switches y routers basados en software (incluyendo switches virtuales dentro de hipervisores).

SDN proporciona numerosos beneficios en el área del plano de gestión. Estos beneficios se encuentran tanto en conmutadores físicos como en conmutadores virtuales. SDN ahora se adopta ampliamente en los centros de datos.

Las API Southbound se utilizan para comunicarse entre el controlador SDN y los conmutadores y enrutadores dentro de la infraestructura. Estas API pueden ser abiertas o propietarias. Las API Southbound permiten a los controladores SDN realizar cambios dinámicamente en función de las demandas en tiempo real y las necesidades de escalabilidad.

Las API de Northbound suelen ser APIs RESTful que se utilizan para comunicarse entre el controlador SDN y los servicios y aplicaciones que se ejecutan a través de la red. Dichas API Northbound se pueden utilizar para la orquestación y automatización de los componentes de red para alinearse con las necesidades de diferentes aplicaciones a través de la programabilidad de red SDN.

1.5.1 VXLAN y overlays

Las redes y los centros de datos modernos deben proporcionar equilibrio de carga, mejor escalabilidad, elasticidad y una convergencia más rápida. Muchas organizaciones utilizan el modelo de red superpuesta u "overlays". La implementación de una red superpuesta permite tunelizar paquetes Ethernet de capa 2 con diferentes encapsulaciones a través de una red de capa 3. La red de superposición utiliza "túneles" para transportar el tráfico a través de la estructura de capa 3. Esta solución también debe permitir que la "capa subyacente" separe los flujos de red entre diferentes "inquilinos" (dominios administrativos). La solución también necesita cambiar paquetes dentro del mismo dominio de difusión de capa 2, enrutar el tráfico entre dominios de difusión de capa 3 y proporcionar separación de IP, tradicionalmente realizada a través de enrutamiento y reenvío virtual (VRF).

Los siguientes son algunos ejemplos de mecanismos de túnel:

- LAN virtual extensible (VXLAN)
- Virtualización de red mediante encapsulación de enrutamiento genérico (NVGRE)
- Túnel de transporte sin estado (STT)
- Encapsulación genérica de virtualización de red (GENEVE)

Todos los protocolos de túnel mencionados anteriormente llevan una trama Ethernet dentro de una trama IP. La principal diferencia entre ellos está en el tipo de trama IP utilizada. Por ejemplo, VXLAN usa UDP y STT usa TCP.

El uso de UDP en VXLAN permite a los routers aplicar algoritmos hash en el encabezado UDP externo para equilibrar la carga del tráfico de red. El tráfico de red que viaja por los túneles de red superpuestos se equilibra en la carga en varios enlaces mediante el enrutamiento de múltiples rutas (ECMP) de igual coste. Esto introduce una mejor solución en comparación con los diseños de red tradicionales. En los diseños de red tradicionales, los switches de acceso se conectan a los switches de distribución. Esto hace que los enlaces redundantes se bloqueen debido al spanning tree.

VXLAN utiliza un identificador o una etiqueta que representa un segmento lógico que se denomina identificador de red VXLAN (VNID). El segmento lógico identificado con el VNID es un dominio de difusión de capa 2 que se tuneliza sobre los túneles VTEP (VXLAN Tunnel End Point).

La Figura 9 muestra un ejemplo de una red superpuesta que proporciona capacidades de capa 2.

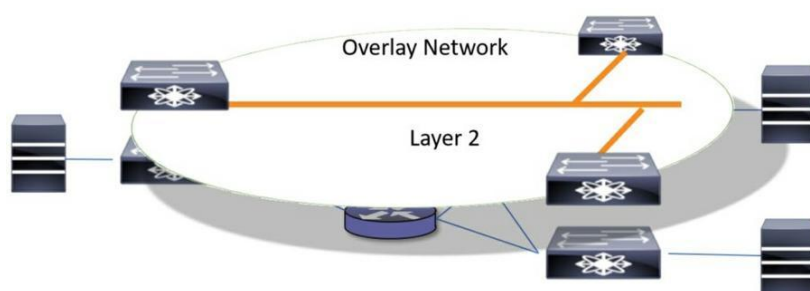


Figura 9: Red superpuesta que proporciona capacidades de capa 2

La Figura 10 muestra un ejemplo de una red superpuesta que proporciona capacidades de enrutamiento de capa 3.

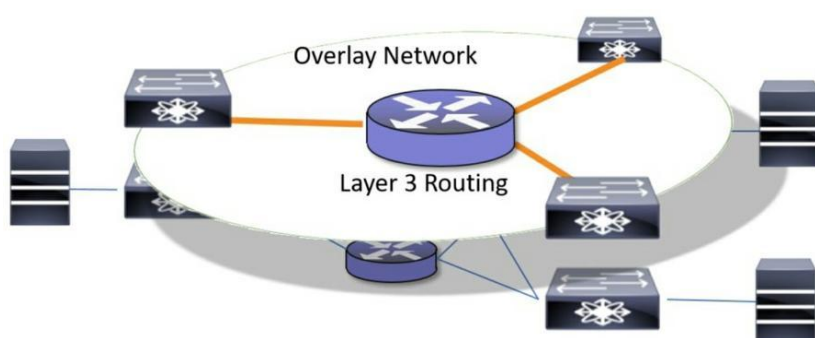


Figura 10: Red superpuesta que proporciona capacidades de enrutamiento de capa 3

1.5.2 Microsegmentación

Durante décadas, a los servidores se les asignaron subredes y VLAN. Esto introdujo muchas complejidades porque la segmentación de aplicaciones y las políticas estaban físicamente restringidas a los límites de la VLAN dentro del mismo centro de datos (o incluso en "el campus"). En entornos virtuales, el problema se hizo más difícil. Hoy en día, las aplicaciones pueden moverse entre servidores para equilibrar las cargas de rendimiento o alta disponibilidad en caso de fallos. También pueden moverse entre diferentes centros de datos e incluso diferentes entornos de nube.

La segmentación tradicional basada en VLAN le impide mantener las políticas de qué aplicación necesita comunicarse con qué aplicación (y quién puede acceder a dichas aplicaciones) en firewalls centralizados. Esto es ineficaz porque la mayor parte del tráfico en los centros de datos ahora es tráfico "Este-Oeste". Gran parte de ese tráfico ni siquiera llega al firewall tradicional. En entornos virtuales, gran parte del tráfico ni siquiera sale del servidor físico.

Se va a definir en primera instancia a qué se refiere la gente como tráfico "Este-Oeste" y tráfico "Norte-Sur". El tráfico "Este-Oeste" es el tráfico de red entre servidores (servidores virtuales o servidores

físicos, contenedores, etc.). El tráfico "Norte-Sur" es el tráfico de red que fluye dentro y fuera del centro de datos. La Figura 11 ilustra los conceptos de tráfico "Este-Oeste" y "Norte-Sur".

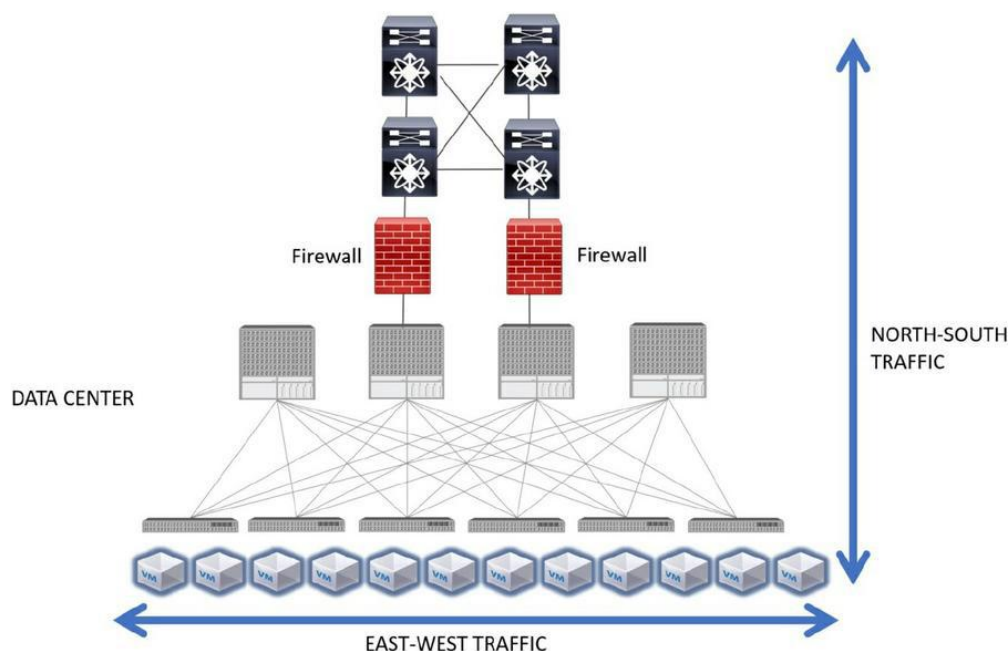


Figura 11: Tráfico "Este-Oeste" y "Norte-Sur"

Muchos proveedores han creado soluciones en las que las políticas aplicadas a las aplicaciones son independientes de la ubicación o la red vinculada a la aplicación.

Se deben aplicar directivas para restringir si la aplicación A necesita o no comunicarse con la aplicación B, o qué aplicación debe poder comunicarse con la base de datos. Estas políticas no deben estar vinculadas por la VLAN o subred IP a la que pertenece la aplicación y si está en el mismo rack o incluso en el mismo centro de datos. El tráfico de red no debe realizar múltiples viajes de ida y vuelta entre las aplicaciones y los firewalls centralizados para aplicar políticas entre máquinas virtuales. Los contenedores hacen esto un poco más difícil porque se mueven y cambian con más frecuencia.

La capacidad de hacer cumplir la segmentación de red en esos entornos es lo que se llama "microsegmentación". La microsegmentación se realiza a nivel de máquina virtual o entre contenedores, independientemente de una VLAN o una subred. Las soluciones de segmentación de microsegmentación deben ser "conscientes de la aplicación". Esto significa que el proceso de segmentación comienza y termina con la propia aplicación.

La mayoría de los entornos de microsegmentación aplican un "modelo de Zero Trust", concepto detallado en el apartado 1.6.4. Este modelo dicta que los usuarios no pueden hablar con las aplicaciones y las aplicaciones no pueden comunicarse con otras aplicaciones a menos que un conjunto definido de directivas les permita hacerlo.

1.5.3 Iniciativas de código abierto

El concepto de SDN es muy amplio, y cada proveedor de código abierto y proveedor comercial lo lleva en una dirección diferente. Hay varios proyectos de código abierto que están tratando de proporcionar microsegmentación y otros beneficios de redes modernas. Algunos ejemplos son los siguientes:

- **Neutron** es el componente de red de OpenStack. Neutron está diseñado para proporcionar "redes como servicio" (NaaS) en entornos de nube privada, pública e híbrida. Otros componentes de OpenStack, como Horizon y Nova, interactúan con Neutron mediante un conjunto de APIs para configurar los servicios de red. Neutron utiliza plug-ins para ofrecer capacidades de red avanzadas y permitir la integración de proveedores externos.
- **OVN y OVS.** OVN fue creado originalmente por la gente detrás de Open vSwitch (OVS) con el propósito de brindar una solución de código abierto para entornos de red virtual y SDN. Open vSwitch es una implementación de código abierto de un conmutador virtual multicapa dentro del hipervisor. OVN se utiliza a menudo en implementaciones de OpenStack con el uso de

OVS. También puede utilizar OVN con el protocolo OpenFlow. OpenStack Neutron utiliza OVS como "plano de control" predeterminado.

- **OpenDaylight (ODL)** es otro proyecto popular de código abierto que se centra en la mejora de los controladores SDN para proporcionar servicios de red a través de múltiples proveedores.
- **Contiv** es un proyecto de código abierto que permite implementar servicios basados en políticas de microsegmentación en entornos de contenedores. Ofrece un mayor nivel de abstracción de red para microservicios al proporcionar un marco de políticas. Contiv tiene funciones integradas de descubrimiento de servicios y enrutamiento de servicios para permitirle escalar horizontalmente los servicios.

Con Contiv se puede asignar una dirección IP a cada contenedor. Esta característica elimina la necesidad de NAT de puerto basado en host. Contiv puede operar en diferentes entornos de red, como redes tradicionales de capa 2 y capa 3, así como redes superpuestas. Contiv se puede implementar con todas las principales plataformas de orquestación de contenedores (o programadores), como Kubernetes y Docker Swarm.

1.6 Seguridad en la nube

A la hora de desarrollar la temática de la seguridad en la nube, es necesario conocer los siguientes conceptos, ya definidos en otros temas:

- Metodología ágil: Scum, Kanban, Extreme Programming
- DevOps
- Integración continua y entrega continua
- Orquestación de contenedores
- Microservicios y microsegmentación (apartado 1.5.2)

Sobre esta base se va a profundizar en los aspectos relacionados con la seguridad de las arquitecturas serverless y los conceptos de DevSecOps y Zero Trust.

Pero antes, se amplía el abanico de estándares aplicables a la seguridad en la nube.

1.6.1 Estándares de seguridad en la nube

Existen ciertos estándares de seguridad de la información reconocidos internacionalmente que se destacan a continuación que se pueden seguir durante la adopción de una plataforma en la nube:

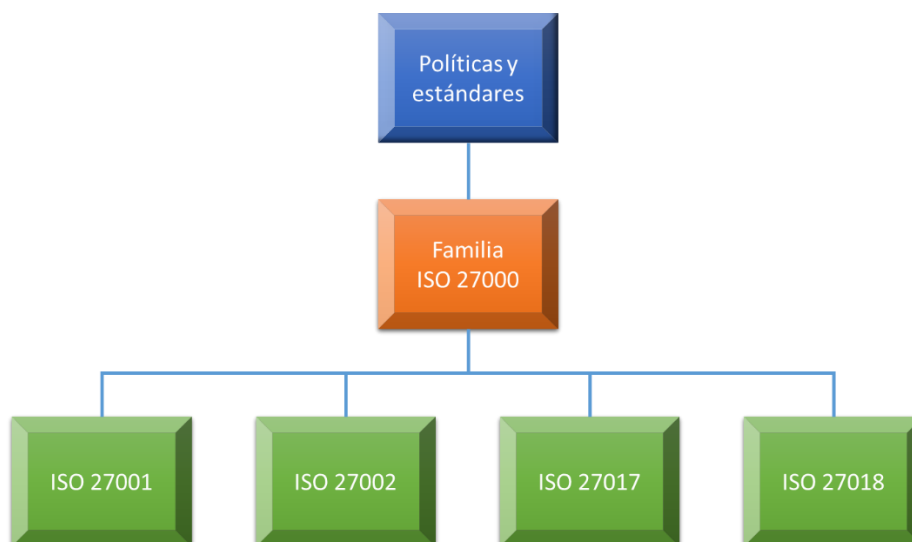


Figura 12: Estándares en seguridad de la información y la nube

Las normas ISO 27001 y 27002 ya se han descrito en el apartado 1.2.

- **ISO 27017.** Está diseñado para ayudar en la implementación de controles para organizaciones basadas en la nube. Este estándar es relevante para las organizaciones que almacenan

información en la nube, pero también para las organizaciones que proporcionan servicios basados en la nube a otras organizaciones que pueden tener información confidencial.

- **ISO 27018.** Para la organización de computación en la nube, diseñada específicamente para proteger la información de identificación personal (PII) almacenada y / o procesada en la nube. El enfoque principal de este estándar es relevante para los proveedores de la nube y no para los consumidores de la nube. Este estándar brinda un nivel adicional de confianza a los consumidores, específicamente cuando trabajan con organizaciones que manejan información confidencial.

1.6.2 Arquitectura serverless

En primer lugar, “*serverless*” o “*sin servidor*” no significa que no necesite un “servidor” en alguna parte. En cambio, significa que utilizará plataformas en la nube para alojar y/o desarrollar su código.

Serverless es un modelo de ejecución de computación en la nube en el que el proveedor de la nube (AWS, Azure, Google Cloud, etc.) administra dinámicamente la asignación y el aprovisionamiento de servidores. Las aplicaciones sin servidor se ejecutan en contenedores sin estado que son efímeros y activados por eventos (totalmente administrados por el proveedor de la nube).

AWS Lambda es una de las arquitecturas sin servidor más populares del sector. La Figura 13 muestra un ejemplo de una “función” o aplicación en AWS Lambda.

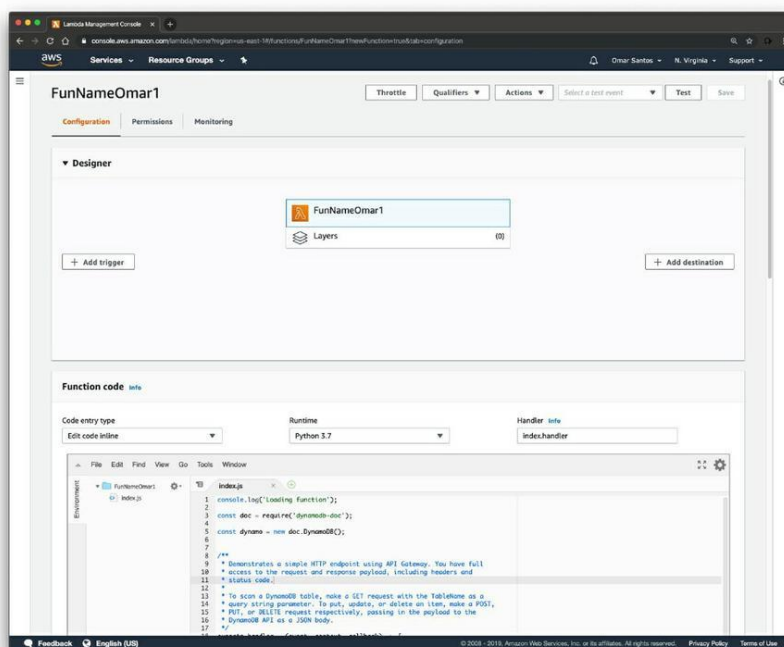


Figura 13: Ejemplo de función de aplicación sin servidor de AWS Lambda

Como se muestra en la Figura 14, la informática ha evolucionado de servidores físicos tradicionales (bare-metal) a máquinas virtuales (VM), contenedores y arquitecturas sin servidor.

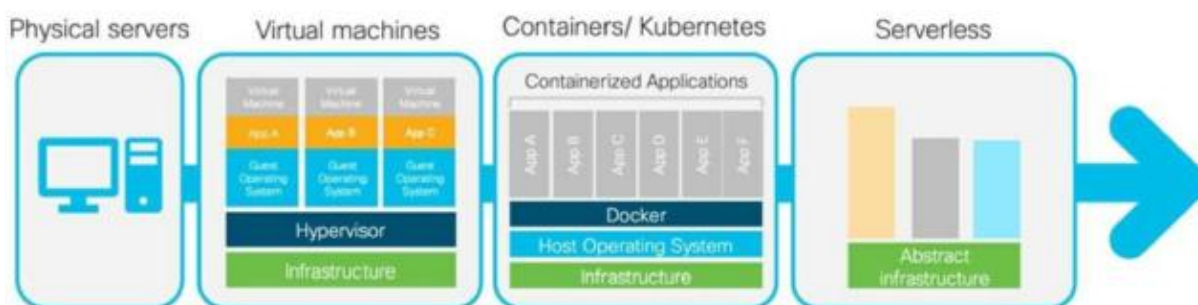


Figura 14: La evolución de la computación

1.6.3 DevSecOps

DevSecOps es un concepto utilizado en los últimos años para describir cómo mover las actividades de seguridad al inicio del ciclo de vida de desarrollo y tener prácticas de seguridad integradas en la canalización de CI/CD. El entorno empresarial, la cultura, el cumplimiento de la ley y el impulso del mercado se relacionan con la forma en cómo se implementa un ciclo de vida de desarrollo seguro (también conocido como SDLC) y un programa DevSecOps en una organización.

El éxito de la implementación de DevSecOps en un entorno de nube se administra por los siguientes factores:

- **Análisis de código:** las mejoras continuas del software significan revisiones exhaustivas del código.
- **Pruebas automatizadas:** las pruebas automatizadas garantizan la minimización del esfuerzo y ahorran tiempo. Como aspecto principal del proceso DevSecOps, las pruebas automatizadas hacen que el proceso de prueba sea más rápido y fácil a través de la ejecución eficiente de casos de prueba repetibles.
- **Gestión del cambio:** fomentar la colaboración en equipo para garantizar que cada equipo esté al tanto de las operaciones de todos los demás equipos. Si los desarrolladores están informados sobre las actividades relacionadas con la seguridad desde el principio, puede ayudar a abordar oportunamente las posibles vulnerabilidades.
- **Monitorización del cumplimiento:** el cumplimiento continúa desempeñando un papel importante en el crecimiento de una organización. Las regulaciones ayudan en la creación de código y la modificación del código fuente. Esto ayuda en la auditoría en tiempo real.
- **Investigación de amenazas:** la investigación de amenazas es importante para definir la preparación de seguridad de cualquier organización. Es importante que las organizaciones tengan una vigilancia estrecha y continua sobre la identificación de amenazas probables, análisis de seguridad periódicos y revisiones de código para abordar los desafíos prevalentes en seguridad.
- **Capacitación del personal:** la organización de sesiones de capacitación práctica y cursos de certificación fortalece la fortaleza de la empresa al equipar a los equipos con el conocimiento adecuado del dominio.

También se pueden usar herramientas y métodos de garantía de software, incluidos fuzzing, pruebas de seguridad de aplicaciones estáticas (SAST) y pruebas de seguridad de aplicaciones dinámicas (DAST). Algunas herramientas de ejemplo son Findsecbugs y SonarQube.

- **Findsecbugs** es una herramienta diseñada para encontrar bugs de seguridad en aplicaciones creadas en el lenguaje de programación Java. Se puede utilizar con sistemas de integración continua como Jenkins y SonarQube. Findsecbugs proporciona soporte para frameworks populares de Java, incluidos Spring-MCV, Apache Struts, Tapestry y otros.
- **SonarQube** es una herramienta que se puede utilizar para encontrar vulnerabilidades en el código, y proporciona soporte para la integración continua y entornos DevOps.

Fuzz testing, o fuzzing, es una técnica que se puede utilizar para encontrar errores de software (o errores) y vulnerabilidades de seguridad en aplicaciones, sistemas operativos, dispositivos de infraestructura, dispositivos IoT y otros dispositivos informáticos. El fuzzing implica el envío de datos aleatorios a la unidad que se está probando para encontrar problemas de validación de entrada, fallos del programa, desbordamientos de búfer y otros defectos. Las herramientas que se utilizan para realizar fuzzing se conocen como "fuzzers". Ejemplos de fuzzers populares son Munity, American Fuzzy Lop y Peach.

- El **Mutiny** Fuzzing Framework es un fuzzer de código abierto. Funciona reproduciendo archivos de captura de paquetes (pcaps) a través de un fuzzer mutacional. El Mutiny Fuzzing Framework utiliza Radamsa para realizar mutaciones. Radamsa es una herramienta que se puede utilizar para generar casos de prueba para fuzzers.
- **American Fuzzy Lop (AFL)** es una herramienta que proporciona características de instrumentación en tiempo de compilación y algoritmos genéticos para mejorar automáticamente la cobertura funcional de los casos de prueba de fuzzing.
- **Peach** es uno de los fuzzers más populares de la industria. Hay una versión gratuita (de código abierto) y una versión comercial.

1.6.4 Zero Trust

El término “zero trust” o “confianza cero” fue acuñado por un analista de Forrester Research Inc. en 2010 cuando se presentó por primera vez el modelo del concepto. Unos años más tarde, Google implementó la seguridad de confianza cero en su red, lo que llevó a un creciente interés en la adopción dentro de la comunidad tecnológica.

La seguridad de confianza cero es un modelo de seguridad de TI de próxima generación que requiere una verificación estricta de la identidad de cada dispositivo y persona que intenta acceder a los recursos en una red privada, independientemente de su posición dentro o fuera del perímetro de la red. No existe una tecnología específica asociada con la confianza cero. Es más bien un enfoque holístico e integral de la seguridad de la red que abarca varias tecnologías y principios diferentes.

La seguridad de la red de TI tradicional se basa en el concepto de castillo y foso. En la seguridad de castillos y fosos, obtener acceso desde fuera de la red es difícil, pero existe una confianza predeterminada para todos los que están dentro de la red. Las limitaciones de este enfoque son que cuando un atacante obtiene acceso a la red, tiene libertad sobre todo lo que está disponible dentro. Esta limitación y vulnerabilidad en los sistemas de seguridad de castillos y fosos se ve agravada por el hecho de que las organizaciones no tienen sus datos en un solo lugar. En la actualidad, la información a menudo se distribuye entre los proveedores de servicios en la nube, lo que dificulta aún más tener un único control de seguridad para toda una red.

Con Zero Trust se presume que todos los usuarios no son confiables. El concepto principal detrás de una red de confianza cero asume que existen atacantes potenciales tanto dentro como fuera de la red, por lo que no se debe confiar en ninguna máquina o usuario automáticamente. Los principios del Modelo de Zero Trust son los siguientes:

- Asegurarse de que solo se permita el tráfico legítimo o la comunicación de aplicaciones segmentando y habilitando la política de capa 7.
- Aprovechar una estrategia de acceso de mínimo privilegio y aplicar estrictamente el control de acceso. Esto significa que los usuarios solo deben tener acceso según la necesidad y el requisito, según la necesidad de saber. Esto minimiza la exposición del usuario a partes sensibles de la red.
- Inspeccionar y registrar todo el tráfico en la nube. De lo contrario, puede considerarse sencillo para un atacante acceder a la red de un departamento.
- Las redes de confianza cero utilizan el concepto de microsegmentación. Por ejemplo, una red con archivos que residen en un centro de datos que adopta la microsegmentación puede consistir en docenas de zonas separadas y seguras. Un programa o persona con acceso a cualquiera de estas zonas no tendrá acceso a ninguna de las otras zonas sin una autorización separada y única.
- La autenticación multifactor (MFA) también es el núcleo del modelo de confianza cero. MFA simplemente necesita más de una sola pieza de evidencia para la autenticación del usuario. Simplemente introducir una contraseña no es suficiente para acceder. Además de la introducción de contraseñas, los usuarios de servicios en la nube deben introducir un código enviado a otro dispositivo, como un teléfono móvil, lo que permite una autenticación de dos factores.
- Además del control de acceso de los usuarios, la confianza cero también necesita controles estrictos sobre el acceso a los dispositivos. Los sistemas de confianza cero necesitan monitorizar la cantidad de dispositivos distintos que intentan acceder a su red y garantizar que cada dispositivo esté autorizado. Esto minimiza aún más la superficie de ataque de la red.

1.6.5 Seguridad en la nube en un entorno multinube o de nube híbrida

Asegurar un entorno de TI híbrido que opera desde múltiples nubes es una tarea difícil. Las organizaciones que tienen la intención de funcionar desde una combinación de sistemas locales y en la nube crearían que el modelo híbrido es más seguro que los sistemas internos exclusivos. Por lo tanto, la mejora de la seguridad actuaría como un factor importante para aumentar su uso de los servicios híbridos o multinube. Hasta hace poco, muchos CSP no tenían los controles o garantías de cumplimiento y seguridad necesarios que los departamentos gubernamentales esperarían, pero esa configuración ha cambiado radicalmente.

Multicloud se refiere al uso de múltiples servicios de nube y almacenamiento dentro de una sola arquitectura heterogénea. Este entorno heterogéneo también se refiere a la distribución de activos en la nube, software, aplicaciones, etc. en varios entornos de alojamiento en la nube. Con una arquitectura

multinube típica, utilizando dos o más nubes públicas, o múltiples nubes privadas, este entorno multinube pretende eliminar la dependencia de cualquier CSP individual.

La protección de la infraestructura de la nube es obligatoria para el CSP seleccionado, pero es responsabilidad de la organización proteger cualquier dato que coloque en la nube, incluyendo la selección de los CSP/MSP para asegurarse de que cumplen con los requisitos legales y de seguridad aplicables.

La importancia en un entorno multinube cambia de asegurar el perímetro de la red a asegurar los datos, ya sea en reposo o en tránsito. En un entorno multinube, el objetivo es comprender de manera integral los flujos de datos y protegerlos de acuerdo con su grado de sensibilidad.

Ciertas medidas que se pueden tener en cuenta al considerar una implementación en entorno multinube son las siguientes:

- **Estrategia en materia de seguridad.** Centralizar el control de seguridad para maximizar la visibilidad de los datos. La información sobre todas las medidas y herramientas de seguridad implementadas debe compartirse entre los puntos de contacto identificados que son responsables de cada plataforma en la nube. Tener un protocolo uniforme para la aplicación de la seguridad ayuda a garantizar un enfoque coherente de las plataformas en la nube. El uso de servicios de terceros para la automatización puede ayudar a escalar la seguridad en la nube.
- **Comunicaciones seguras.** Una buena estrategia de seguridad multinube debe tener en cuenta la necesidad de cifrar las comunicaciones que entran dentro del dominio del plano de control, así como garantizar el cifrado de estas comunicaciones que controlan los contenedores y las máquinas virtuales.
- **Protocolo de seguridad.** Independientemente de dónde se implemente la aplicación, las políticas de seguridad deben mantenerse según las definiciones de directivas. Esto se puede lograr utilizando una solución centralizada de gestión de políticas que se extiende a través de diferentes nubes e instalaciones de centros de datos. Esta solución debe tener la capacidad de aplicar, supervisar y administrar las políticas de manera uniforme.

Con el fin de mantener los controles de seguridad a lo largo de las implementaciones híbridas o multinube de la organización, también se pueden utilizar agentes de seguridad de acceso a la nube o CASB. Los CASB (Cloud Security Gateways) descubren el uso interno de los servicios en la nube utilizando diversos mecanismos, como la supervisión de la red, la integración con una puerta de enlace de red existente o una herramienta de supervisión, o incluso mediante la supervisión de consultas DNS.

Los registros de infraestructura y aplicaciones de los múltiples entornos CSP que interactúan para proporcionar servicios deben recopilarse en una ubicación central para facilitar la supervisión centralizada de la seguridad, la gestión de incidentes y el análisis de eventos. Esto permitirá una vista única de las amenazas emergentes en los activos de datos de las organizaciones. Esta solución se basará en Inteligencia Artificial (IA) / Aprendizaje Automático (ML), con capacidades de Análisis de Comportamiento de Usuarios y Entidades (UEBA).

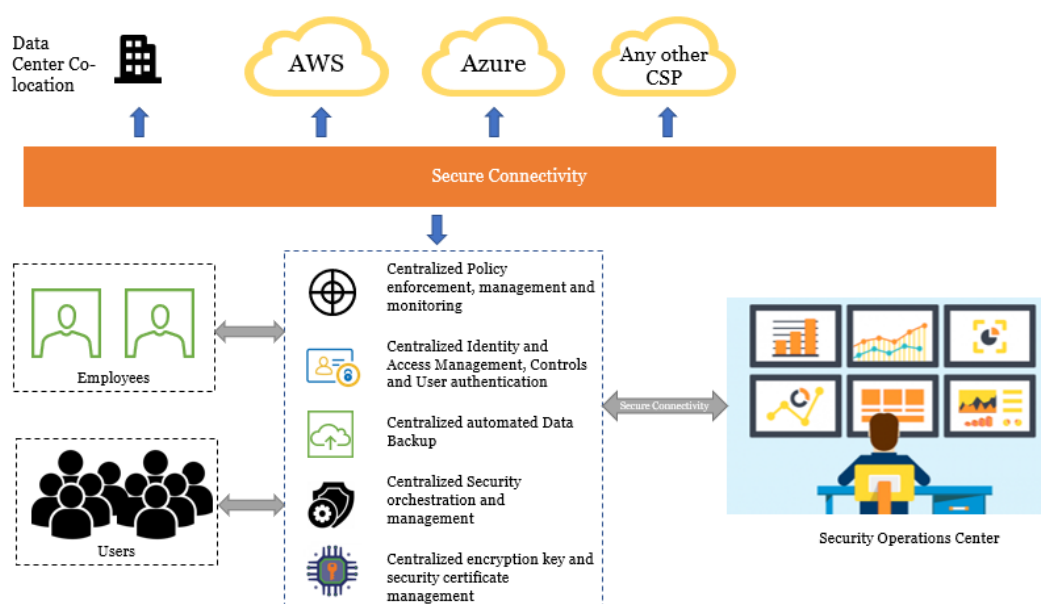


Figura 15: Seguridad en la nube en un entorno multinube

Todos los usuarios finales deben pasar por una solución centralizada de administración de acceso a la identidad (solución IdAM). Esta solución es capaz de acomodar múltiples identidades de usuario y administrar diferentes tipos de usuarios, facilitando un mecanismo de inicio de sesión único e integrando o teniendo la función para habilitar la autenticación multifactor.

Una solución centralizada de copia de seguridad de datos garantiza que los datos de todos los diferentes entornos estén disponibles, incluso durante un desastre, cuando más se necesita esta información.

La infraestructura de seguridad debe administrarse mediante una solución centralizada de análisis y monitorización en varios entornos. Esta herramienta también se puede utilizar para la orquestación de infraestructura de TI que abarca herramientas y tecnologías de seguridad. Las claves de cifrado y los certificados se pueden administrar desde un HSM central o una solución de administración de claves, como Vault.

1.7 Conclusión

Afrontar la dimensión de seguridad en las organizaciones requiere de un análisis exhaustivo a todos los niveles de aplicación de la misma, desde la capa más baja que trabaja sobre la infraestructura y el medio de transmisión hasta la capa superior de aplicación. En este tema nos hemos centrado en el estudio de la seguridad en redes, abarcando las más modernas tipologías de redes, como la SDN y el cloud.

A medida que avanza la tecnología, también lo hacen las amenazas sobre los activos de las organizaciones. La superficie de ataque se incrementa con cada paso innovador y con cada solución al servicio de la sociedad. Es por ello que la seguridad debe acompañar intrínsecamente cada avance tecnológico y tener un alcance más extensivo, más allá de un área de dominio o negocio, con un enfoque extremo a extremo. Por esta razón, la seguridad no se circunscribe únicamente a una red o una tecnología, sino que debe aportar soluciones completas a través de todas las diferentes redes por la que atraviesa la información y los datos de los usuarios.

En este apartado se han analizado los principios fundamentales, como la defensa en profundidad y el principio de mínimo privilegio; las principales topologías de red; y los conceptos más importantes de la seguridad no solo aplicables a la nube, como el DevSecOps o el modelo Zero Trust.

2 Tipos de ataques y herramientas para su prevención

2.1 Introducción

Esta sección cubre tanto los tipos de ataques que sufren las redes y sistemas de comunicaciones como las herramientas para su prevención.

Dentro de la clasificación de los ataques, destacan los diferentes tipos de virus, gusanos, troyanos, malware, ransomware o spyware. Además se analizan también sobre los casos de uso concretos de la nube y el IoT, debido a su enorme importancia en el panorama de seguridad actual. En un momento en el que la mayoría de empresas y organizaciones gubernamentales están presentes en la nube y en el que las infraestructuras críticas han adoptado el IoT, los ataques que puedan sufrir deben ser el principal foco de atención, ya que el número de afectados y el impacto causado adquiere enormes dimensiones.

En este apartado también se detallan las herramientas para la prevención de los anteriores vectores de ataque. El elemento más destacado es el firewall, profundizando en los últimos avances, como el firewall de nueva generación (NGFW). También se abordan tanto la autenticación y la autorización, junto con los principales protocolos y estándares de aplicación. Otros elementos de protección de la red son los IDS e IPS que conforman el control de intrusiones. Por último, se estudian las técnicas criptográficas aplicadas a la securización de las redes, destacando IPsec a nivel de red y TLS a nivel de transporte.

2.2 Tipos de ataques

El software malicioso, o *malware*, incluye virus, ransomware, rootkits, gusanos, troyanos, puertas traseras, herramientas de canal encubierto, spyware y amenazas persistentes avanzadas (APT). El malware puede causar una amplia gama de daños, desde mostrar mensajes y hacer que los programas funcionen de manera errática, hasta cifrar archivos y pedir un rescate para descifrarlos.

2.2.1 Ataques distribuidos de denegación de servicio

Los ataques DDoS generalmente se pueden dividir en las siguientes tres categorías:

- **Directo:** Los ataques DDoS directos ocurren cuando la fuente del ataque es la que genera los paquetes, independientemente del protocolo o la aplicación, enviándolos directamente a la víctima del ataque.
- **Reflejado:** Los ataques DDoS reflejados ocurren cuando las fuentes del ataque reciben paquetes falsificados que parecen ser de la víctima, y luego las fuentes se convierten en participantes involuntarios en los ataques DDoS al enviar el tráfico de respuesta a la víctima prevista. UDP se usa a menudo como mecanismo de transporte porque es más fácil falsificarlo debido a la falta de un 3-way handshake. Por ejemplo, si el atacante (A) decide que quiere atacar a una víctima (V), enviará paquetes a una fuente (S) para que piense que estos paquetes son legítimos. La fuente (S) responde a las solicitudes NTP enviando las respuestas a la víctima (V), que nunca esperó estos paquetes NTP de la fuente (S) (ver Figura 16).
- **Amplificación:** Los ataques de amplificación son una forma de ataques reflejados en los que el tráfico de respuesta (enviado por los participantes involuntarios) se compone de paquetes que son mucho más grandes que los que fueron enviados inicialmente por el atacante (suplantación de la víctima). Un ejemplo de esto es cuando se envían consultas DNS y las respuestas DNS son mucho mayores en tamaño de paquete que los paquetes de consulta iniciales. El resultado final es que la víctima se ve inundada por grandes paquetes para los que nunca emitió consultas.

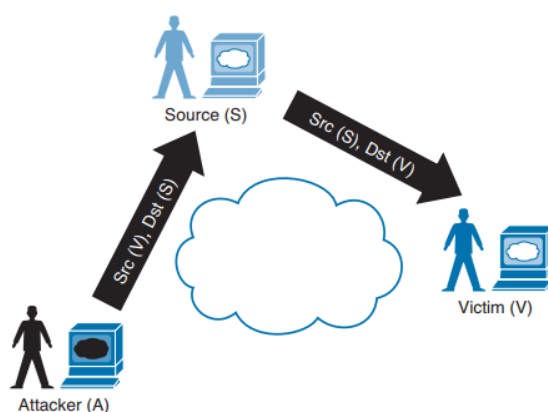


Figura 16: Ataque DDoS reflejado

2.2.2 Métodos de ingeniería social

La ingeniería social está evolucionando tan rápidamente que las soluciones tecnológicas, las políticas de seguridad y los procedimientos operativos por sí solos no pueden proteger los recursos críticos. Incluso con estas salvaguardas, los hackers comúnmente manipulan a los empleados para que comprometan la seguridad corporativa. Las víctimas pueden, sin saberlo, revelar la información confidencial necesaria para eludir la seguridad de la red, o incluso abrir las puertas del lugar de trabajo para extraños sin identificación. Aunque los ataques al juicio humano son inmunes incluso a los mejores sistemas de defensa de red, las organizaciones pueden mitigar el riesgo de la ingeniería social con una cultura de seguridad activa que evoluciona a medida que cambia el panorama de amenazas.

Las formas comunes de ingeniería social incluyen las siguientes:

- **Phishing:** El phishing obtiene información segura a través de un mensaje de correo electrónico que parece provenir de una fuente legítima, como un proveedor de servicios o una institución financiera. El mensaje de correo electrónico puede pedir al usuario que responda con los datos confidenciales o que acceda a un sitio web para actualizar información, como un número de cuenta bancaria.
- **Publicidad maliciosa:** Éste es el acto de incorporar anuncios maliciosos en sitios web de confianza, lo que hace que los navegadores de los usuarios sean redirigidos inadvertidamente a sitios que alojan malware.
- **Estafas telefónicas:** No es raro que alguien llame a un empleado e intente convencer a los empleados de que divulguen información sobre ellos mismos u otros dentro de la organización. Un ejemplo es un malhechor que se hace pasar por un reclutador que pide nombres, direcciones de correo electrónico, etc., de los miembros de la organización y luego usa esa información para comenzar a construir una base de datos para aprovechar un ataque futuro, una misión de reconocimiento, etc.

2.2.3 Métodos de pérdida y exfiltración de datos

Los principales ataques de red ahora son realizados por equipos sofisticados y bien financiados que pueden evadir las medidas de seguridad corporativas y robar millones de registros de todo tipo de organizaciones en todo el mundo. Las medidas de seguridad tradicionales son buenas para identificar el tráfico sospechoso que está llegando, pero muchas organizaciones carecen de la visibilidad del tráfico que sale de sus redes internas.

Varios tipos de datos son particularmente atractivos para los malhechores del mundo cibernético:

- **Propiedad intelectual (PI):** Consiste en cualquier tipo de dato o documentación que sea propiedad de una organización y que haya sido creada o producida por empleados de la organización. La PI a menudo se refiere a los diseños, dibujos y documentos que respaldan el desarrollo, la venta y el soporte de los productos de una organización.
- **Información de identificación personal (PII):** Este es el tipo de información que, desafortunadamente, se ha hablado en la prensa con demasiada frecuencia últimamente cuando escuchamos sobre violaciones de datos. Esta información incluye nombres, fechas de nacimiento o direcciones.

- **Tarjetas de crédito / débito:** Además de la PII, que a menudo es robada o comprometida durante las violaciones de datos, la información de la tarjeta de crédito y débito (la información contenida en la banda magnética o dentro del chip incorporado en las tarjetas con chip y pin) es extremadamente deseada por los delincuentes.

Es primordial para todas las organizaciones, sin importar el tamaño, vertical o no, o si son públicas o privadas, hacer todo lo posible para proteger sus activos de datos. Esto implica una combinación de políticas de seguridad claramente efectivas, educación de los empleados y las tecnologías para ayudar a garantizar que se puedan aplicar las políticas de seguridad implementadas.

2.2.4 Virus y gusanos

Una cosa que hace que los virus sean únicos es que un virus generalmente necesita un programa o archivo host para infectar. Los virus requieren algún tipo de interacción humana. Un gusano puede viajar de un sistema a otro sin interacción humana. Cuando un gusano se ejecuta, puede replicarse de nuevo e infectar aún más sistemas. Por ejemplo, un gusano puede enviarse por correo electrónico a todos los miembros de su libreta de direcciones y luego repetir este proceso una y otra vez desde la computadora de cada usuario que infecta. Esa cantidad masiva de tráfico puede conducir a una denegación de servicio muy rápidamente.

2.2.4.1 Tipos y métodos de transmisión

El malware se propaga a través del mundo informático de varias maneras básicas:

- **Infección del registro de arranque maestro (MBR):** Este es el método original de ataque. Funciona atacando el registro de arranque maestro del disco duro.
- **Infección de la BIOS:** Esto podría hacer que el sistema no funcione por completo o que el dispositivo se bloquee antes de pasar la prueba automática de encendido (POST).
- **Infección de archivos:** Esto incluye malware que depende del usuario para ejecutar el archivo. Por lo general, se usan extensiones como .com y .exe, en entornos Windows. Alguna forma de ingeniería social se utiliza normalmente para conseguir que el usuario ejecute el programa. Las técnicas incluyen cambiar el nombre del programa o intentar enmascarar la extensión .exe y hacer que aparezca como un gráfico (.jpg, .bmp, .png, .svg y similares).
- **Infección por macros:** Los virus de macro explotan los servicios de scripting instalados en su equipo. La manipulación y el uso de macros en documentos de Microsoft Excel, Microsoft Word y Microsoft PowerPoint han sido muy populares en el pasado.
- **Clúster:** Este tipo de virus puede modificar las entradas de la tabla de directorios para que apunte un usuario o proceso del sistema al malware y no al programa real.
- **Multipartito:** Este estilo de virus puede utilizar más de un método de propagación y se dirige tanto al sector de arranque como a los archivos de programa. Un ejemplo es el virus NATAS (Satán deletreado al revés).

Los virus de **infección rápida** infectan cualquier archivo que son capaces de infectar. Otros limitan la tasa de infección. Este tipo de actividad se conoce como **infección dispersa**. La infección dispersa significa que el virus tarda su tiempo en infectar otros archivos o propagar su daño. Esta técnica se utiliza para tratar de ayudar al virus a evitar ser detectados. Algunos virus renuncian a vivir exclusivamente en archivos y se cargan en la RAM, que es la única forma en que los virus del sector de arranque pueden propagarse.

Otra técnica que los desarrolladores de malware han intentado es el **polimorfismo**. Un virus polimórfico puede cambiar su firma cada vez que se replica e infecta un nuevo archivo. Esta técnica hace que sea mucho más difícil para el programa antivirus detectarlo.

Gran parte del malware de hoy está escrito para un objetivo específico. Al limitar la propagación del malware y apuntar solo a unas pocas víctimas, los desarrolladores de malware hacen que descubrir el malware y crear una firma para detectarlo sea mucho más difícil para las compañías antivirus.

2.2.4.2 Cargas útiles de malware

El malware debe colocar su carga útil en algún lugar. Siempre pueden sobrescribir una parte del archivo infectado, pero hacerlo lo destruiría. La mayoría de los creadores de malware quieren evitar la detección durante el mayor tiempo posible y es posible que no hayan escrito el programa para destruir archivos inmediatamente. Una forma en que el escritor de malware puede lograr esto es colocar el código de

malware al principio o al final del archivo infectado. El malware conocido como **prepend** infecta programas colocando su código viral al principio del archivo infectado, mientras que un **append** coloca su código al final del archivo infectado. Ambas técnicas dejan el archivo intacto, con el código malicioso agregado al principio o al final del archivo.

No importa la técnica de infección, todos los virus tienen algunos componentes comunes básicos, como se detalla en la siguiente lista. Por ejemplo, todos los virus tienen una rutina de búsqueda y una rutina de infección.

- **Rutina de búsqueda:** Es responsable de localizar nuevos archivos, espacio en disco o RAM para infectar.
- **Rutina de infección:** La rutina de búsqueda es inútil si el virus no tiene una forma de aprovechar estos hallazgos. Por lo tanto, el segundo componente de un virus es una rutina de infección. Esta parte del virus es responsable de copiar el virus y adjuntarlo a un host adecuado.
- **Carga útil:** La mayoría de los virus no se detienen aquí y también contienen una carga útil. El propósito de la rutina de carga útil podría ser borrar el disco duro, mostrar un mensaje al monitor o posiblemente enviar el virus a 50 personas en su libreta de direcciones. Las cargas útiles no son necesarias, y sin ella, muchas personas nunca sabrán que el virus existió.
- **Rutina antidetección:** Su objetivo es ayudar a que el virus sea más sigiloso y evitar la detección.
- **Rutina de disparo:** El objetivo es lanzar la carga útil en una fecha y hora determinadas. El disparador se puede configurar para realizar una acción determinada en un momento dado.

2.2.5 Troyanos

Los troyanos son programas que pretenden hacer una cosa, pero cuando se cargan, en realidad realizan otro acto, dañino. Un usuario puede pensar que un archivo parece inofensivo y es seguro de ejecutar, pero después de que se ejecuta el archivo, entrega una carga maliciosa. Los troyanos funcionan porque normalmente se presentan como algo que desea, como un correo electrónico con un PDF, un documento de Word o una hoja de cálculo de Excel.

La carga útil se ejecuta si el atacante puede hacer que la víctima abra el archivo o haga clic en el archivo adjunto. Esa carga útil podría permitir a un hacker acceso remoto al sistema, iniciar un registrador de pulsaciones de teclas para registrar cada pulsación de tecla, plantar una puerta trasera en el sistema, causar una denegación de servicio (DoS) o incluso deshabilitar la protección antivirus o firewall de software.

A diferencia de un virus o gusano, los troyanos no pueden propagarse solos. Confían en el usuario desinformado.

2.2.5.1 Tipos de troyanos

En realidad, es difícil clasificar todos los tipos de troyanos porque muchos tienen más de una función. La siguiente lista pretende aportar algo de luz para comprender mejor lo que pueden hacer:

- **Acceso remoto:** Los troyanos de acceso remoto (RAT) permiten al atacante un control total sobre el sistema. Los troyanos de acceso remoto generalmente se configuran como programas cliente-servidor para que el atacante pueda conectarse al sistema infectado y controlarlo de forma remota.
- **Ocultación de datos:** La idea detrás de este tipo de troyano es ocultar los datos de un usuario. Este tipo de malware también se conoce a veces como ransomware. Este tipo de troyano restringe el acceso al sistema informático que infecta, y exige un rescate pagado al creador del malware para que se elimine la restricción.
- **Banca electrónica:** Estos troyanos (Zeus es uno de esos ejemplos) interceptan y utilizan la información bancaria de una víctima para obtener ganancias financieras. Por lo general, funcionan como un capturador de número de autenticación de transacción (TAN), usan inyección HTML o actúan como un capturador de formularios. El único propósito de este tipo de programas es la ganancia financiera.
- **Denegación de servicio (DoS):** Estos troyanos están diseñados para causar un DoS. Pueden diseñarse para eliminar un servicio específico o para desconectar todo un sistema.
- **Proxy:** Estos troyanos están diseñados para funcionar como programas proxy que ayudan a un hacker a ocultarse y le permiten realizar actividades desde la computadora de la víctima, no la suya. Cuanto más lejos está el hacker del crimen, más difícil se vuelve rastrearlo.
- **FTP:** Estos troyanos están diseñados específicamente para funcionar en el puerto 21. Permiten que el hacker cargue, descargue o mueva archivos a voluntad en la máquina de la víctima.

- **Deshabilitadores de software de seguridad:** Estos troyanos están diseñados para atacar y matar antivirus o firewalls de software.

2.2.5.2 Puertos troyanos y métodos de comunicación

Los troyanos pueden comunicarse de varias maneras. Algunos utilizan comunicaciones abiertas. Estos programas no intentan ocultar la transmisión de datos a medida que se mueven dentro o fuera de la computadora de la víctima. La mayoría utiliza canales de comunicación encubiertos. Esto significa que el hacker hace todo lo posible para ocultar la transmisión de datos hacia y desde la víctima.

Muchos troyanos que abren canales encubiertos también funcionan como puertas traseras. Una **puerta trasera** es cualquier tipo de programa que permitirá a un hacker conectarse a una computadora sin pasar por el proceso de autenticación normal. El peligro de este tipo de ataque es el tráfico que se mueve de adentro hacia afuera, lo que significa que desde dentro de la organización hacia el exterior de Internet.

2.2.6 Distribución de malware

Hoy en día, no es raro que los atacantes utilicen múltiples capas de técnicas para ofuscar el código, hacer que el código malicioso sea indetectable desde el antivirus y emplear el cifrado para evitar que otros examinen el malware. El resultado es que el malware moderno mejora las posibilidades de los atacantes de comprometer una computadora sin ser detectados. Estas técnicas incluyen las siguientes.

- **Wrappers.** Los wrappers ofrecen a los hackers un método para deslizarse más allá de las defensas normales de un usuario, empaquetando software en un contenedor. Un contenedor es un programa utilizado para combinar dos o más ejecutables en un solo programa empaquetado. Básicamente, estos programas funcionan como constructores de instalación y programas de instalación. Además de permitirle vincular un programa, los wrappers agregan capas adicionales de ofuscación y cifrado alrededor del archivo de destino, esencialmente creando un nuevo archivo ejecutable.
- **Packers.** Los packers son similares a programas como WinZip, Rar y Tar porque comprimen archivos. Sin embargo, mientras que los programas de compresión comprimen archivos para ahorrar espacio, los empaquetadores lo hacen para ofuscar la actividad del malware. La idea es evitar que alguien vea el código del malware hasta que se coloque en la memoria. Los packers trabajan para eludir los mecanismos de protección de seguridad de red, como los sistemas de detección de intrusos basados en host y red. El empaquetador de malware descomprimirá el programa solo cuando esté en la memoria, revelando el código original del programa solo cuando se ejecute.
- **Droppers.** Los droppers son software diseñado para instalar cargas útiles de malware en el sistema de la víctima. Los droppers intentan evitar la detección y evadir los controles de seguridad mediante el uso de varios métodos para propagar e instalar la carga útil de malware.
- **Cripters.** Los cripters funcionan para cifrar u ocultar el código. Algunos cripters ocultan el contenido del troyano aplicando un algoritmo de cifrado. Los cripters pueden usar cualquier cosa, desde AES, RSA, hasta incluso Blowfish, o pueden usar técnicas de ofuscación más básicas como XOR, codificación Base64 o incluso ROT13.

2.2.7 Ransomware

En los últimos años, el ransomware ha sido utilizado por delincuentes que ganan dinero con sus víctimas y por hacktivistas y atacantes de estados-nación que causan interrupciones. El ransomware puede propagarse como un gusano o un virus, pero está diseñado para cifrar archivos personales en el disco duro de la víctima hasta que se pague un rescate al atacante. Los siguientes son varios ejemplos populares de ransomware:

- WannaCry
- Pyeta
- Nyeta
- Sodinokibi
- Conejo malo
- Grangrejo
- SamSam
- CryptoLocker

- CryptoDefense
- CryptoWall
- Espora

El ransomware puede cifrar archivos específicos en su sistema o todos sus archivos, en algunos casos, incluido el registro de arranque maestro de su unidad de disco duro.

2.2.8 Comunicación encubierta

La distribución de malware es solo la mitad de la batalla para el atacante. El atacante necesitará tener alguna forma de filtrar datos y hacerlo de una manera que no se detecte.

Un canal encubierto es una forma de mover información a través de un canal o protocolo de comunicación de una manera en la que no estaba destinada a ser utilizada.

El diseño de TCP/IP ofrece muchas oportunidades para el mal uso. Los protocolos principales para las comunicaciones encubiertas incluyen los protocolos IP, TCP, UDP, ICMP y DNS.

- La **capa de Internet** ofrece varias oportunidades para que los hackers tunelicen el tráfico. Dos protocolos comúnmente tunelizados son IPv6 e ICMP.
 - **IPv6** es como todos los protocolos en que puede ser abusado o manipulado para actuar como un canal encubierto. Es posible que los dispositivos perimetrales no estén configurados para reconocer el tráfico IPv6, aunque la mayoría de los sistemas operativos tengan activada la compatibilidad con IPv6.
Hay muchas herramientas para hacer túneles a través de IPv6, incluyendo 6tunnel, socat, nt6tunnel y relay6. La mejor manera de mantener la seguridad con IPv6 es reconocer que incluso los dispositivos compatibles con IPv6 pueden no ser capaces de analizar correctamente la encapsulación IPv6 de los paquetes IPv4.
 - El segundo protocolo que podría ser tunelizado en la capa de Internet es el Protocolo de mensajes de control de Internet (**ICMP**). ICMP está diseñado para proporcionar mensajes de error, información de la mejor ruta de acceso y mensajes de diagnóstico. Un ejemplo de esto es el comando ping, que utiliza ICMP para probar una conexión a Internet.
- La **capa de transporte** ofrece a los atacantes dos protocolos para usar: TCP y UDP.
 - **TCP** ofrece varios campos que pueden ser manipulados por un atacante, incluido el campo Opciones de TCP en el encabezado TCP y el campo Indicador TCP. Por diseño, TCP es un protocolo orientado a la conexión que proporciona una comunicación robusta.
 - **UDP** no tiene estado y, como tal, no se puede iniciar sesión en conexiones de firewall; algunas aplicaciones basadas en UDP, como DNS, normalmente se permiten a través del firewall y es posible que los administradores de red y firewall no las vigilen de cerca.
- El túnel de la **capa de aplicación** utiliza aplicaciones comunes que envían datos en puertos permitidos. Por ejemplo, un hacker podría tunelizar una sesión web, el puerto 80, a través del puerto SSH 22 o incluso a través del puerto 443. Debido a que los puertos 22 y 443 usan cifrado, puede ser difícil monitorizar la diferencia entre una sesión legítima y un canal encubierto.
El **DNS** se puede usar para la tunelización de la capa de aplicación. La forma más sencilla de manipular DNS es mediante estas solicitudes/respuestas.

2.2.9 Keyloggers

Los registradores de pulsaciones de teclas (keyloggers) son software o hardware.

En su variante software, pueden grabar cada vez que se hace clic con el mouse, se visita un sitio web y se abre un programa. Aunque no son realmente una herramienta de comunicación encubierta, estos dispositivos permiten a un hacker monitorizar encubiertamente todo lo que hace un usuario.

El hacker podría enviar a una víctima un keylogger envuelto de la misma manera que se entregaría un troyano. Una vez instalado, el keylogger puede funcionar en modo sigiloso, lo que significa que es difícil de detectar a menos que sepa lo que está buscando.

Hay formas de hacer que los keyloggers sean completamente invisibles para el sistema operativo y para aquellos que examinan el sistema de archivos. Para lograr esto, todo lo que el hacker tiene que hacer es usar un keylogger de hardware. Estos dispositivos generalmente se instalan mientras el usuario está lejos de su escritorio. Los keyloggers de hardware son completamente indetectables, excepto por su presencia física. Incluso entonces, podrían pasarse por alto porque se parecen a una extensión. No muchas personas prestan mucha atención a los enchufes en la parte posterior de su computadora.

Los keyloggers de hardware pueden ser inalámbricos o cableados. Los keyloggers inalámbricos pueden comunicarse a través de 802.11 o Bluetooth, y los keyloggers cableados deben recuperarse para acceder a los datos almacenados. Un ejemplo de un keylogger con cable es KeyGhost, que parece un pequeño adaptador en el cable que conecta el teclado a la computadora. Este dispositivo no requiere alimentación externa, dura indefinidamente y no puede ser detectado por ningún software.

2.2.10 Spyware

El spyware es otra forma de código malicioso que es similar a un troyano y estrechamente relacionado con virus y gusanos. Se instala sin su consentimiento o conocimiento, oculto a la vista, supervisa su computadora y el uso de Internet, y está configurado para ejecutarse en segundo plano cada vez que se inicia la computadora. El código suele estar oculto en las claves de ejecución del Registro, la carpeta Inicio de Windows, las líneas load= o run= de Windows que se encuentran en el archivo Win.ini o en la línea Shell= que se encuentra en el archivo .ini sistema de Windows.

Por lo general, se utiliza para uno de dos propósitos:

- **Vigilancia:** Se utiliza para determinar los hábitos de compra de los usuarios, descubrir sus preferencias y reportar esta información demográfica.
- **Publicidad:** Se le dirige la publicidad que se le ha pagado al proveedor de spyware para entregar. Por ejemplo, el fabricante de una funda de teléfono móvil de diamantes de imitación podría haber pagado al proveedor de spyware por 100.000 anuncios emergentes. Si ha sido infectado, se recibirán más de estos anuncios emergentes no deseados.

2.2.11 Ataques de computación en la nube

Debido a que los servicios basados en la nube son accesibles a través de Internet, están abiertos a cualquier número de ataques. Algunos de los posibles vectores de ataque que los delincuentes podrían intentar incluyen los siguientes:

- **Secuestro de sesión:** este ataque se produce cuando el atacante puede esnifar el tráfico e interceptarlo para hacerse cargo de una conexión legítima a un servicio en la nube.
- **Ataque DNS:** Esta forma de ataque engaña a los usuarios para que visiten un sitio de phishing y renuncien a credenciales válidas.
- **Cross-site scripting (XSS):** Se utiliza para robar cookies que pueden ser explotadas para obtener acceso como usuario autenticado a un servicio basado en la nube.
- **Inyección SQL:** Este ataque explota aplicaciones vulnerables basadas en la nube que permiten a los atacantes pasar comandos SQL a una base de datos para su ejecución.
- **Sesión de equitación:** Los atacantes utilizan esta técnica para transmitir comandos no autorizados a través de una sesión activa mediante el uso de un correo electrónico o un enlace malicioso para engañar a los usuarios mientras están conectados a un servicio en la nube.
- **Ataque distribuido de denegación de servicio (DDoS):** Algunos profesionales de la seguridad han argumentado que la nube es más vulnerable a los ataques DDoS porque es compartida por muchos usuarios y organizaciones.
- **Ataque criptográfico Man-in-the-middle:** Este ataque se lleva a cabo cuando el atacante se coloca en la ruta de comunicación entre dos usuarios. Cada vez que el atacante puede hacer esto, existe la posibilidad de que pueda interceptar y modificar las comunicaciones.
- **Ataque de canal lateral:** Un atacante podría intentar poner en peligro la nube colocando una máquina virtual maliciosa muy cerca de un servidor en la nube de destino y, a continuación, lanzando un ataque de canal lateral.
- **Ataque de autenticación:** La autenticación es un punto débil en los servicios alojados y virtuales y con frecuencia se ataca. Hay muchas maneras de autenticar a los usuarios, como en función de lo que una persona sabe, tiene o es.
- **Ataques a las API:** A menudo, las API se configuran de forma insegura. Un atacante puede aprovechar las configuraciones incorrectas de API para modificar, eliminar o anexar datos en aplicaciones o sistemas en entornos de nube.

Independientemente del modelo utilizado, la seguridad en la nube es responsabilidad tanto del cliente como del proveedor de la nube. Estos detalles deberán resolverse antes de firmar un contrato de computación en la nube. Los contratos variarán dependiendo de los requisitos de seguridad dados del cliente. Las consideraciones incluyen recuperación ante desastres, SLA, integridad de datos y cifrado.

2.2.12 Amenazas de seguridad de IoT

El Internet de las cosas (IoT) incluye cualquier dispositivo informático que pueda transferir datos a través de una red sin requerir interacción de persona a persona o de persona a computadora, por ejemplo, sensores, electrodomésticos, cámaras de seguridad, dispositivos portátiles y muchos otros dispositivos.

La capacidad de inteligencia distribuida en la red es un componente arquitectónico central de IoT:

- **Recopilación de datos:** La recopilación centralizada de datos presenta algunos desafíos para que un entorno de IoT pueda escalar. Por ejemplo, la gestión de millones de sensores en una red de red inteligente no se puede hacer de manera eficiente utilizando un enfoque centralizado.
- **Preservación de recursos de red:** Esto es particularmente importante porque el ancho de banda de la red puede ser limitado, y la recopilación centralizada de datos de dispositivos IoT conduce al uso de una gran cantidad de capacidades de red.
- **Funcionamiento de bucle cerrado:** Los entornos IoT a menudo requieren tiempos de reacción reducidos.

La computación en la niebla (fog computing) es un concepto de una arquitectura de inteligencia distribuida diseñada para procesar datos y eventos de dispositivos IoT lo más cerca posible de la fuente.

Los dispositivos IoT generalmente se comunican con la nube a través de un dispositivo de borde de niebla o directamente a la nube. La Figura 17 muestra cómo varios sensores se comunican con un enrutador de borde de niebla y, posteriormente, el enrutador se comunica con la nube.

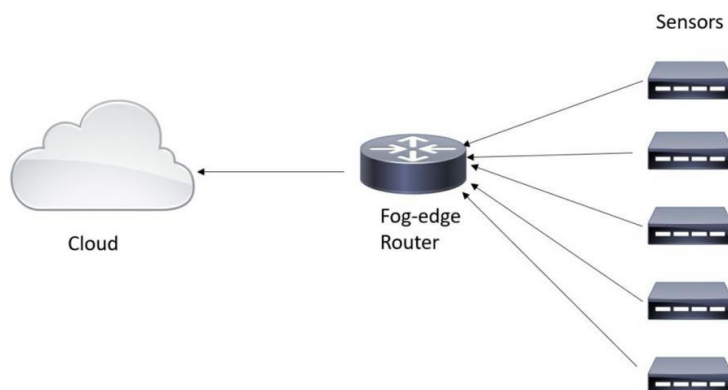


Figura 17: Ejemplo de un dispositivo de borde de niebla

La Figura 18 muestra cómo un termostato inteligente se comunica directamente con la nube mediante una API RESTful a través de una conexión de seguridad de la capa de transporte (TLS). El dispositivo IoT (un termostato inteligente en este ejemplo) envía datos a la nube, y un usuario final comprueba la temperatura y administra el termostato mediante una aplicación móvil.

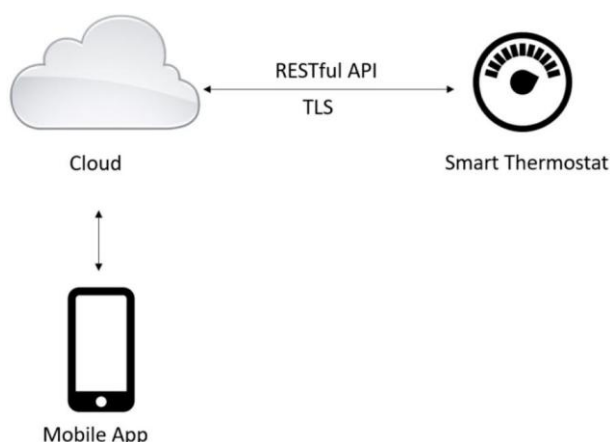


Figura 18. IoT, aplicaciones en la nube y API

Hackeando implementaciones de IoT

Muchas de las herramientas y metodologías para hackear aplicaciones y redes se aplican a la piratería de IoT; sin embargo, varias herramientas especializadas realizan piratería de hardware y software de IoT.

Los siguientes son algunos ejemplos de herramientas y métodos para hackear dispositivos IoT.

- Herramientas de hardware:
 - Multímetros
 - Osciloscopios
 - Herramientas de soldadura
 - Depuradores y herramientas UART
 - Herramientas de interfaz universal como herramientas JTAG, SWD, I2C y SPI
 - Analizadores lógicos
- Herramientas de ingeniería inversa, como desensambladores y depuradores:
 - IDA
 - Ninja binario
 - Radare2
 - Ghidra
 - Hopper
- Interfaces y herramientas de comunicación inalámbrica:
 - Ubertooth One (para hackear Bluetooth)
 - Radio definida por software (SDR), como HackRF y BladeRF, para realizar evaluaciones de implementaciones de Z-Wave y Zigbee

2.3 Herramientas para la prevención de ataques

2.3.1 Cortafuegos

Un cortafuegos o firewall es, en esencia, una barrera entre dos computadoras o sistemas informáticos. El lugar más común para encontrar un firewall es entre la red interna y el mundo exterior. Sin embargo, los firewalls en computadoras individuales y entre segmentos de red también son bastante comunes. Como mínimo, un firewall filtrará los paquetes entrantes en función de ciertos parámetros, como el tamaño del paquete, la dirección IP de origen, el protocolo y el puerto de destino. El objetivo del firewall es reducir el riesgo.

Un firewall podría ser un enrutador que también tiene capacidades de firewall incorporadas. O bien, podría ser un servidor dedicado exclusivamente a ejecutar software de firewall (instancia virtual).

Los firewalls también son excelentes herramientas cuando se intenta determinar qué ha sucedido después de que haya ocurrido un incidente. Casi todos los firewalls, independientemente del tipo o la implementación, registrarán la actividad. Estos registros pueden proporcionar información valiosa que puede ayudar a determinar el origen de un ataque, los métodos utilizados para atacar y otros datos que podrían ayudar a localizar al autor de un ataque o al menos prevenir un ataque futuro utilizando las mismas técnicas.

Nota: El estudio de los firewalls a nivel de aplicación, o Web Application Firewalls (WAF), se deja para el tema de seguridad en el nivel de aplicación.

2.3.1.1 Metodologías de firewall

Los firewalls basados en red proporcionan características clave utilizadas para la seguridad perimetral. La tarea principal de un firewall de red es denegar o permitir el tráfico que intenta entrar o salir de la red en función de políticas y reglas preconfiguradas explícitas. Los firewalls a menudo se implementan en varias otras partes de la red para proporcionar segmentación de red dentro de la infraestructura corporativa y también en los centros de datos.

2.3.1.1.1 Filtrado estático de paquetes

El filtrado estático de paquetes se basa en la capa 3 y la capa 4 del modelo OSI. Un ejemplo de una tecnología de firewall que utiliza el filtrado estático de paquetes es un enrutador con una ACL aplicada a una o más de sus interfaces con el fin de permitir o denegar tráfico específico. Uno de los desafíos con el filtrado estático de paquetes es que el administrador debe saber exactamente qué tráfico debe

permitirse a través del firewall, lo que puede ser complicado si tiene muchos usuarios que necesitan acceder a muchos servidores.

2.3.1.1.2 Puerta de enlace de la capa de aplicación

Los firewalls de la capa de aplicación, que a veces también se denominan firewalls proxy o puertas de enlace de aplicaciones, pueden funcionar en la capa 3 y superior en el modelo de referencia OSI. La mayoría de estos servidores proxy incluyen software de aplicación especializado que toma las solicitudes de un cliente, pone a ese cliente en espera por un momento, y luego se da la vuelta y hace las solicitudes como si fuera su propia solicitud hasta el destino final.

Un firewall proxy actúa como intermediario entre el cliente original y el servidor. No se produce ninguna comunicación directa entre el cliente y el servidor de destino. Debido a que la puerta de enlace de la capa de aplicación puede operar hasta la capa 7, tiene el potencial de ser muy granular sobre cada paquete que intercambian el cliente y el servidor y puede hacer cumplir reglas basadas en cualquier cosa que vea el firewall.

2.3.1.1.3 Filtrado de paquetes con estado

El filtrado de paquetes con estado (stateful) es una de las tecnologías de firewall más importantes en uso hoy en día. Se llama stateful porque recuerda el estado de las sesiones que pasan por el firewall.

Con un dispositivo de filtrado de paquetes con estado, para los clientes en el interior de la red corporativa, mientras intentan llegar a los recursos en las redes públicas externas, sus paquetes van a los firewalls al salir. Los firewalls echan un vistazo a la dirección IP de origen, la dirección IP de destino, los puertos en uso y otras capas para obtener información y recuerdan esa información en lo que se conoce como una base de datos con estado en el firewall (como escribir los nombres, del ejemplo del parque de atracciones). Se llama stateful porque el firewall recuerda el estado de la sesión (que estaba en camino, incluidos los puertos y las direcciones IP involucradas).

2.3.1.1.4 Inspección de aplicaciones

Un firewall de inspección de aplicaciones puede analizar y verificar protocolos hasta la capa 7 del modelo de referencia OSI, pero no actúa como un proxy entre el cliente y el servidor al que accede el cliente.

2.3.1.1.5 Firewalls transparentes

Un firewall transparente se trata más de cómo se inyecta el firewall en la red en lugar de qué tecnologías utiliza para filtrar. Un firewall transparente puede usar filtrado basado en paquetes, filtrado con estado, inspección de aplicaciones como se ha detallado anteriormente, pero la gran diferencia con los firewalls transparentes es que se implementan en la capa 2.

La mayoría de los firewalls tradicionales se implementan como un salto de capa 3 en la red (similar a un salto de enrutador), lo que significa que los paquetes tienen que pasar por este dispositivo en la capa 3. En un firewall de capa 3, cada una de las interfaces tiene una dirección IP en una red diferente, y el tráfico de una subred a otra que pasa a través del firewall tiene que pasar las reglas del firewall.

Con un firewall transparente hay dos interfaces, pero no se asignan direcciones IP a esas interfaces, y esas dos interfaces actúan más como un puente (o un switch con dos puertos en la misma VLAN).

A pesar de que esto se implementa como un dispositivo de capa 2, todavía ve todos los paquetes que van entre sus interfaces, y aún puede aplicar todas las reglas de un firewall normal de capa 3 relacionadas con permitir el tráfico, construir una base de datos con estado y realizar la inspección de aplicaciones.

2.3.1.2 Firewalls de próxima generación (NGFW)

Los firewalls de próxima generación (NGFW) proporcionan servicios de seguridad centrados en las amenazas que permiten una protección más completa contra amenazas conocidas y avanzadas, incluida la protección contra ataques de malware dirigidos y persistentes.

El objetivo de un NGFW es mantener una visibilidad completa de los usuarios, dispositivos móviles, aplicaciones del lado del cliente, comunicaciones de máquina virtual (VM) a VM, vulnerabilidades, amenazas y localización uniforme de recursos (URL).

Los NGFW pueden hacer todo lo que hacen los firewalls normales. Esto incluye:

- Filtrado de paquetes: Inspeccionar cada paquete individual de datos y bloquear los paquetes peligrosos o inesperados. Más adelante explicaremos el filtrado de paquetes.
- Inspección de estado: Examinar los paquetes en su contexto para asegurarse de que forman parte de una conexión de red legítima.
- Conocimiento de la VPN: Los firewalls son capaces de identificar el tráfico de VPN encriptado y permitir su paso.

Los NGFW también añaden varias funciones que no tienen los firewalls tradicionales. Los NGFW utilizan la inspección profunda de paquetes (DPI) además del filtrado de paquetes. Un NGFW incluye:

- Conocimiento y control de las aplicaciones
- Prevención de intrusiones
- Información sobre amenazas
- Itinerarios de actualización para añadir futuras fuentes de información
- Técnicas para hacer frente a la evolución de las amenazas para la seguridad

Por último, un NGFW se puede implementar como un servicio en la nube; esto se denomina firewall en la nube o firewall como servicio (FWaaS). El FWaaS es un componente importante de modelos de red de perímetro de servicio de acceso seguro (SASE).

2.3.1.3 Traducción de direcciones de red (NAT)

La traducción de direcciones de red (NAT) es una característica importante que a menudo se implementa en firewalls. Este apartado proporciona una visión detallada de las opciones que existen para NAT. Se puede utilizar NAT en combinación con las otras características del firewall descritas anteriormente. La Figura 19 sirve como punto de referencia.

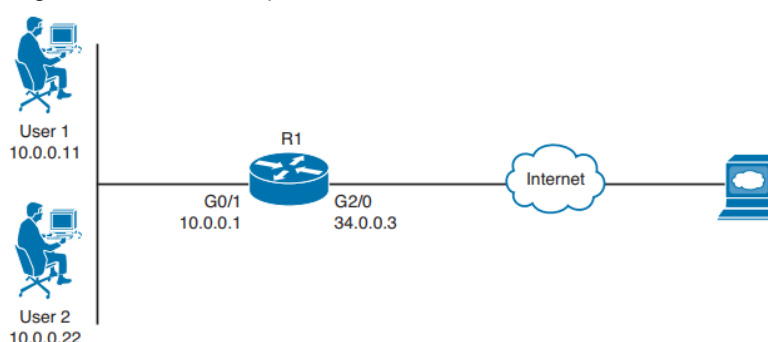


Figura 19: Diagrama de ejemplo para explicación de NAT

Los dos usuarios están utilizando el espacio de direcciones privadas en la red 10 junto con la interfaz G0/1 del router. R1 también está conectado a Internet a través de un proveedor de servicios mediante su interfaz G2/0. Desde una perspectiva de seguridad, la interfaz G0/1 se conecta a la red "confiable" o "interna" (desde la perspectiva de la organización), y la interfaz G2/0 se conecta a la red "no confiable" o "externa". Ahora el enrutador en sí no tiene un problema con la conectividad IP a Internet porque el enrutador tiene una dirección IP accesible globalmente (34.0.0.3) en este ejemplo. Sin embargo, los usuarios no son tan afortunados porque están utilizando un espacio de direcciones IP privadas, y ese tipo de dirección no está permitida directamente en Internet por los proveedores de servicios. Por lo tanto, si los usuarios desean acceder a un servidor en Internet, reenvían sus paquetes a la puerta de enlace predeterminada, que en este caso es R1, y si está configurado para hacerlo, R1 modifica los encabezados IP en esos paquetes e intercambia las direcciones IP de origen originales con su propia dirección global o una dirección global de un grupo de direcciones globales (que R1 es responsable de administrar, lo que significa que si un paquete estaba destinado a una de esas direcciones, el enrutamiento a esas direcciones en Internet reenviaría los paquetes a R1). Estas son direcciones globales asignadas por el proveedor de servicios para el uso de R1.

El dispositivo principal que hace NAT es un enrutador o un firewall. NAT no solo permite tener miles de usuarios escondidos detrás de una sola dirección IP (usando la traducción de direcciones de puerto (PAT), discutida más tarde), sino que también ofrece protección a esos usuarios porque el mundo

exterior no sabe exactamente qué dispositivos se han asignado dinámicamente a qué direcciones IP, por lo que iniciar una conexión desde el exterior a un dispositivo interno es más difícil (sin mencionar las ACL que podrían evitar que los paquetes del exterior regresen al interior).

Es importante entender que NAT o PAT no deben considerarse solo como un mecanismo de seguridad. El tráfico se permite o se deniega mediante el uso de ACL.

Dentro, Fuera, Local, Global

Algunos términos que se usan con NAT a menudo son confusos, como las palabras dentro, fuera, local y global:

- **Local interna:** La IP real configurada en un host interno.
- **Global interna:** La dirección asignada que el router está intercambiando para el host interno durante NAT. El mundo exterior ve al usuario como proveniente de esta dirección mapeada.
- **Local externa:** Es la dirección asignada al dispositivo externo tal como aparecería a los hosts internos.
- **Global externa:** La IP real configurada en un host externo.

Los términos utilizados tienen que ver con el establecimiento de un punto de referencia. El *interior* y el *exterior* tienen que ver con dónde existe una IP antes de tocarla. Lo *local* y lo *global* tienen que ver con la apariencia de la dirección y, por lo tanto, pueden ser manipulación pre o post-NAT.

Traducción de direcciones de puerto (PAT)

La traducción de direcciones de puerto (PAT) es un subconjunto de NAT. El dispositivo PAT realiza un seguimiento de las sesiones individuales en función de los números de puerto y otros identificadores únicos, y luego reenvía todos los paquetes utilizando una única dirección IP de origen, que se comparte.



Figura 20: Ejemplo de PAT

Esto a menudo se conoce como **NAT con sobrecarga (overload)**, donde se ocultan múltiples direcciones IP internas (en el ejemplo de la Figura 20, 192.168.10.10 y 192.168.11.10) en una sola dirección global interna (209.165.200.225). Nótese que esta dirección global interna es la que tiene configurada la interfaz externa (S0/1/0) del router R2. Cuando todos esos paquetes regresan, vuelven a números de puerto únicos (1444 y 1445, en la tabla de direcciones globales interna). Afortunadamente, el dispositivo PAT realiza un seguimiento de qué clientes desde qué direcciones IP inician qué sesiones. Si por casualidad los hosts inician sesiones en el mismo servidor y utilizan puertos de origen idénticos (como en el ejemplo), el router utiliza dinámicamente un puerto de origen diferente para una de las sesiones. Es poco probable que los números de puerto dinámicos se utilicen por completo porque el rango comienza en 1.024 y llega hasta 65.535.

Opciones de NAT

- **NAT estático:** Éste es un mapeo permanente uno a uno. Si tiene 100 usuarios internos y 100 direcciones globales, se puede realizar una asignación uno a uno para cada usuario, y cada usuario tendría una dirección global dedicada asociada con su dirección interna. Un uso típico de un mapeo estático es cuando hay un servidor en una interfaz de la DMZ, y se quiere permitir que los dispositivos en Internet accedan a ese servidor específico. Cuando se crea una asignación estática para ese servidor a una dirección IP global, esa dirección IP global se puede utilizar en las tablas del DNS y los usuarios de Internet pueden llegar al servidor por su nombre.
- **NAT dinámico:** Implica tener un grupo de direcciones globales y solo asignar esas direcciones globales a dispositivos internos cuando esos dispositivos internos necesitan salir a Internet. Con NAT dinámico aplicada a los hosts internos, después de un período de tiempo en el que un host no utiliza una dirección IP asignada dinámicamente, el enrutador o firewall que realiza la NAT reclama esa dirección IP y puede usarla para otro dispositivo que pueda necesitarla en el futuro.
- **PAT dinámico (NAT con sobrecarga):** Esta es la característica que se utiliza para la mayoría de los usuarios que acceden a Internet. Combina los beneficios de asignar dinámicamente direcciones globales solo cuando es necesario, y utiliza la sobrecarga para que literalmente miles de dispositivos internos se puedan traducir a la misma dirección IP global.
- **Política NAT/PAT:** La NAT basada en políticas se basa en un conjunto de reglas, como cuál es la dirección IP de origen, cuál es la dirección IP de destino y qué puertos se utilizan que calificarían ese paquete para que se le aplique NAT/PAT. Se pueden establecer reglas para que solo se traduzcan direcciones IP de origen específicas destinadas a direcciones de destino específicas y/o puertos específicos, y eso es lo que significa la parte de política. El tráfico fuera de la política simplemente se reenvía en función del reenvío de enrutamiento normal sin traducción.

2.3.1.4 Configuraciones de firewall

Además de las diversas metodologías de firewalls, existen varias opciones de configuración. La metodología de firewall utilizada, indica cómo se evaluará el tráfico y, por lo tanto, decidirá qué permitir y qué no permitir. La configuración le da una idea de cómo se configura ese firewall en relación con la red que está protegiendo. Algunas de las principales configuraciones/implementaciones para firewalls incluyen las siguientes:

- **Basado en host de red.** Un firewall basado en host de red es una solución de software instalada en una máquina existente con un sistema operativo existente. La preocupación más importante en el uso de este tipo de firewall es que no importa cuán buena sea la solución de firewall, depende del sistema operativo subyacente. En tal situación, es absolutamente crítico que la máquina que aloja el firewall tenga un sistema operativo reforzado.
- **Dual-homed host.** Es un firewall que se ejecuta en un servidor con al menos dos interfaces de red. El servidor actúa como un enrutador entre la red y las interfaces a las que está conectado. Para que esto funcione, la función de enrutamiento automático está desactivada, lo que significa que un paquete IP de Internet no se enruta directamente a la red. Puede elegir qué paquetes enrutar y cómo enrutarlos. Los sistemas dentro y fuera del firewall pueden comunicarse con el host de base dual, pero no pueden comunicarse directamente entre sí.
- **Firewall basado en enrutador.** Como se mencionó anteriormente, se puede implementar la protección de firewall en un enrutador. En redes más grandes con múltiples capas de protección, ésta suele ser la primera capa de protección. Aunque se pueden implementar varios tipos de firewalls en un enrutador, el tipo más común utilizado es el filtrado de paquetes. Este tipo es el firewall más común utilizado en la actualidad.
- **Host filtrado.** Es realmente una combinación de firewalls. En esta configuración, se utiliza una combinación de un host bastión y un enrutador de detección. El enrutador de detección agrega seguridad al permitirle denegar o permitir cierto tráfico desde el host bastión. Es la primera parada para el tráfico, que puede continuar solo si el enrutador de detección lo deja pasar.

2.3.2 Control de accesos

Un esquema de identificación, un método de autenticación y un modelo de autorización son atributos comunes de los controles de acceso.

Un **esquema de identificación** se utiliza para identificar registros únicos en un conjunto, como un nombre de usuario. La identificación es el proceso del sujeto que proporciona un identificador al objeto. El **método de autenticación** es la forma en que se demuestra que la identificación es genuina. La

autenticación es el proceso del sujeto que proporciona credenciales verificables al objeto. El **modelo de autorización** define cómo se conceden los derechos de acceso y los permisos. La autorización es el proceso de asignar a los sujetos autenticados el permiso para llevar a cabo una operación específica.

Otros conceptos a tener en cuenta a la hora de abordar el control de accesos son el principio de mínimo privilegio y el de separación de funciones, analizados en el apartado 1.3.1 Aplicación de principios de seguridad fundamentales al diseño de redes.

2.3.2.1 Autenticación

La identificación es el proceso de proporcionar la identidad de una máquina o un usuario. Éste es el primer paso en el proceso de autenticación, autorización y responsabilidad (AAA). Una identidad segura debe ser única en el sentido de que dos usuarios deben poder identificarse sin ambigüedades. Esto es particularmente importante en el contexto de la monitorización de cuentas. La duplicación de identidad es posible si los sistemas de autenticación no están conectados. Una identidad también debe emitirse de manera segura. Esto incluye todos los procesos y pasos para solicitar y aprobar una solicitud de identidad. Esta propiedad generalmente se conoce como "emisión segura".

La siguiente lista destaca los conceptos clave de identificación:

- Las identidades deben ser únicas. No se deben permitir dos usuarios con la misma identidad.
- Las identidades deben ser no descriptivas, lo que significa que no debe ser posible inferir el papel o la función del usuario a partir de su identidad. Por ejemplo, un usuario llamado "admin" representa una identidad descriptiva, mientras que un usuario llamado "om1337ar" representa una identidad no descriptiva.
- Las identidades deben emitirse de forma segura. Es necesario establecer un proceso seguro para emitir una identidad a un usuario.
- Las identidades pueden basarse en la ubicación. Es necesario establecer un proceso para autenticar a alguien en función de su ubicación. Hay tres categorías de factores: conocimiento (algo que el usuario sabe), posesión (algo que un usuario tiene) e inherencia o características (algo que el usuario es).

2.3.2.1.1 Autenticación por conocimiento

La autenticación por conocimiento es cuando el usuario proporciona un secreto que solo él o ella conoce. Un ejemplo de autenticación por conocimiento sería un usuario que proporciona una contraseña, un código de número de identificación personal (PIN) o responde preguntas de seguridad.

La desventaja de usar este método es que una vez que la información se pierde o es robada (por ejemplo, si se roba la contraseña de un usuario), un atacante podría autenticarse con éxito.

La seguridad de autenticación de una contraseña es una función de su longitud, complejidad e imprevisibilidad. Si es fácil de adivinar o reconstruir, es vulnerable a los ataques. El desafío es lograr que los usuarios creen, mantengan en secreto y recuerden contraseñas seguras. Las contraseñas débiles se pueden descubrir en cuestión de minutos o incluso segundos utilizando cualquier número de descifradores de contraseñas disponibles públicamente o técnicas de ingeniería social. Las mejores prácticas dictan que las contraseñas tengan un mínimo de ocho caracteres de longitud (preferiblemente más largas), incluyan una combinación de al menos tres de las siguientes categorías: letras mayúsculas y/o minúsculas, puntuación, símbolos y números (denominados complejidad), se cambien con frecuencia y sean únicas. El uso de la misma contraseña para iniciar sesión en múltiples aplicaciones y sitios aumenta significativamente el riesgo de exposición.

Generalmente, cuando a los usuarios se les concede acceso inicial a un sistema de información, se les da una contraseña temporal. La mayoría de los sistemas tienen un control técnico que obligará al usuario a cambiar su contraseña en el primer inicio de sesión. Una contraseña debe cambiarse inmediatamente si hay alguna sospecha de que ha sido comprometida, e invalidar todas las sesiones que se han abierto con esa contraseña, para expulsar a los usuarios que ya estuvieran accediendo de forma ilícita.

2.3.2.1.2 Autenticación por propiedad o posesión

Con este tipo de autenticación, se le pide al usuario que proporcione pruebas de que posee algo específico; por ejemplo, un sistema puede requerir que un empleado use una insignia para acceder a una instalación. Otro ejemplo de autenticación por propiedad es el uso de un token o tarjeta inteligente.

Similar al método anterior, si un atacante puede robar el objeto utilizado para la autenticación, podrá acceder con éxito al sistema.

Entre los ejemplos de autenticación por propiedad o posesión se incluyen los siguientes: un código de acceso de un solo uso, una tarjeta de memoria, una tarjeta inteligente y una comunicación fuera de banda.

El más común de los cuatro es el código de acceso de un solo uso enviado a un dispositivo en posesión del usuario. Las OTP generalmente se entregan a través de un dispositivo de token de hardware o software. El token muestra el código, que luego debe escribirse en la pantalla de autenticación. Alternativamente, la OTP puede ser entregada por correo electrónico, mensaje de texto o llamada telefónica a una dirección o número de teléfono predeterminado.

La autenticación fuera de banda requiere comunicación a través de un canal que sea distinto del primer factor. Una red móvil se usa comúnmente para la autenticación fuera de banda. Por ejemplo, un usuario escribe su nombre y contraseña en un mensaje de inicio de sesión de la aplicación (factor 1). El usuario recibe una llamada en su teléfono móvil; el usuario responde y proporciona un código predeterminado (factor 2). Para que la autenticación se viese comprometida, el atacante tendría que tener acceso tanto al ordenador como al teléfono.

2.3.2.1.3 Autenticación por característica

Un sistema que utiliza la autenticación por característica, autentica al usuario en función de alguna característica física o de comportamiento, a veces denominada atributo biométrico. Las características **físicas** o fisiológicas más utilizadas son las siguientes:

- Huellas
- Reconocimiento facial
- Retina e iris
- Geometría de la palma y la mano
- Información sanguínea y vascular
- Reconocimiento de voz

Ejemplos de características de **comportamiento** son los siguientes:

- Dinámica de firma
- Pulsación de teclas dinámica/patrón

El inconveniente de un sistema basado en este tipo de autenticación es que es propenso a errores de precisión.

Dos tipos de errores están asociados con la precisión de un sistema biométrico:

- Un error de tipo I, también llamado **rechazo falso o falso negativo**, ocurre cuando el sistema rechaza a un usuario válido que debería haberse autenticado.
- Un error de tipo II, también llamado **aceptación falsa o falso positivo**, ocurre cuando el sistema acepta a un usuario que debería haber sido rechazado (por ejemplo, un atacante que intenta hacerse pasar por un usuario válido).

La tasa de error cruzado (CER), también llamada tasa de error igual (EER), es el punto donde la tasa de errores de rechazo falso (FRR) y la tasa de errores de aceptación falsa (FAR) son iguales. Esto es generalmente aceptado como un indicador de la precisión (y por lo tanto la calidad) de un sistema biométrico.

2.3.2.1.4 Autenticación multifactor (MFA)

El proceso de autenticación requiere que el sujeto proporcione credenciales verificables. Las credenciales a menudo se denominan factores.

La autenticación de un solo factor es cuando solo se presenta un factor. El método más común de autenticación de un solo factor es el uso de contraseñas.

La autenticación multifactor es cuando se presentan dos o más factores. La autenticación multicapa es cuando se presentan dos o más del mismo tipo de factores. Cuantos más factores, más robusto será el proceso de autenticación.

La identificación y la autenticación a menudo se realizan juntas. Sin embargo, es importante entender que son dos operaciones diferentes. La identificación se trata de establecer quién eres, mientras que la autenticación se trata de demostrar que eres la entidad que dices ser.

En respuesta a la inseguridad de las contraseñas, muchas organizaciones han implementado opciones de autenticación multifactor para sus usuarios. Con la autenticación multifactor, las cuentas están protegidas por algo que usted sabe (contraseña) y algo que tiene (código de verificación de un solo uso que se le proporciona).

2.3.2.2 Autorización

Una vez autenticado, un sujeto debe ser autorizado. La autorización es el proceso de asignar permiso a sujetos autenticados para llevar a cabo una operación específica. El modelo de autorización define cómo se conceden los derechos de acceso y los permisos. Los tres modelos de autorización principales son la capacidad de objetos, las etiquetas de seguridad y las ACL.

La capacidad de objeto se utiliza mediante programación y se basa en una combinación de una referencia infalsificable y un mensaje operativo. Las etiquetas de seguridad son controles de acceso obligatorios incrustados en las propiedades de objeto y asunto. Ejemplos de etiquetas de seguridad (basadas en su clasificación) son "confidencial", "secreto" y "alto secreto". Las listas de control de acceso (ACL) se utilizan para determinar el acceso en función de una combinación de criterios específicos, como un ID de usuario, pertenencia a grupos, clasificación, ubicación, dirección y fecha.

2.3.2.2.1 Control de acceso obligatorio (MAC)

Los controles de acceso obligatorios (MAC) están definidos por la política y no pueden ser modificados por el propietario de la información. Los MAC se utilizan principalmente en sistemas militares y gubernamentales seguros que requieren un alto grado de confidencialidad. En un entorno MAC, a los objetos se les asigna una etiqueta de seguridad que indica la clasificación y categoría del recurso. A los sujetos se les asigna una etiqueta de seguridad que indica un nivel de autorización y categorías asignadas. La autorización del sujeto debe ser igual o mayor que la clasificación del objeto, mientras que la categoría debe coincidir.

2.3.2.2.2 Control de acceso discrecional (DAC)

Los controles de acceso discrecional (DAC) son definidos por el propietario del objeto. Los DAC se utilizan en sistemas operativos comerciales. El propietario del objeto crea una ACL que permite o deniega el acceso al objeto en función de la identidad única del usuario. La ACL puede hacer referencia a un ID de usuario o a un grupo (o grupos) del que el usuario es miembro. Los permisos pueden ser acumulativos.

2.3.2.2.3 Control de acceso basado en roles (RBAC)

Los controles de acceso basados en roles (RBAC, también llamados "controles no discrecionales") son permisos de acceso basados en un rol o función específica. Los administradores conceden derechos de acceso y permisos a los roles. A continuación, los usuarios se asocian a un único rol. No hay ninguna disposición para asignar derechos a una cuenta de usuario o grupo.

Se propone el ejemplo ilustrado en la Figura 21.

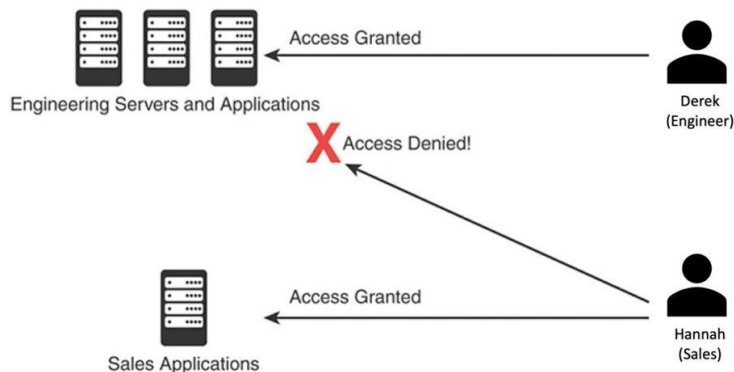


Figura 21: Un ejemplo de RBAC

El usuario Derek está asociado con el rol de "Ingeniero" y hereda todos los permisos asignados al rol de Ingeniero. A Derek no se le puede asignar ningún permiso adicional. Hannah está asociada con el

rol de "Ventas" y hereda todos los permisos asignados al rol de Ventas y no puede acceder a los recursos de ingeniería. Los usuarios pueden pertenecer a varios grupos. RBAC le permite controlar lo que los usuarios pueden hacer tanto a nivel amplio como granular.

2.3.2.2.4 Control de acceso basado en reglas

En un entorno de control de acceso basado en reglas, el acceso se basa en criterios independientes de la cuenta de usuario o grupo. Las reglas son determinadas por el propietario del recurso. Los criterios comúnmente utilizados incluyen la dirección de origen o destino, la ubicación geográfica y la hora del día. Los controles de acceso basados en reglas se pueden combinar con DAC y RBAC.

2.3.2.2.5 Control de acceso basado en atributos (ABAC)

El control de acceso basado en atributos es un modelo de control de acceso lógico que controla el acceso a los objetos mediante la evaluación de reglas con respecto a los atributos de las entidades, las operaciones y el entorno relevante para una solicitud. Las características de ABAC son las siguientes:

- ABAC admite un complejo conjunto de reglas booleanas que pueden evaluar muchos atributos diferentes.
- Las políticas que se pueden implementar en un modelo ABAC se limitan solo al grado impuesto por el lenguaje computacional y la riqueza de los atributos disponibles.
- Un ejemplo de un marco de control de acceso que es coherente con ABAC es el lenguaje de marcado de control de acceso extensible (XACML).

2.3.2.3 Responsabilidad (Accounting)

La responsabilidad es el proceso de auditar y monitorizar lo que hace un usuario una vez que se accede a un recurso específico. Es importante ser consciente de la responsabilidad y abogar para que se implemente debido a la gran ayuda que proporciona durante la detección e investigación de violaciones de ciberseguridad.

Cuando se implementa la responsabilidad, se crea y almacena un registro de seguimiento de auditoría que detalla cuándo el usuario ha accedido al recurso, qué hizo el usuario con ese recurso y cuándo dejó de usar el recurso. Dada la posible información confidencial incluida en los registros de auditoría, se debe tener especial cuidado en protegerlos del acceso no autorizado.

2.3.2.4 Protocolos AAA

Se utilizan varios protocolos para conceder acceso a redes o sistemas, proporcionar información sobre los derechos de acceso y proporcionar capacidades utilizadas para supervisar, auditar y responsabilizar las acciones del usuario una vez autenticadas y autorizadas. Estos protocolos se denominan protocolos de autenticación, autorización y responsabilidad (AAA).

Los protocolos AAA más conocidos son RADIUS, TACACS+, Diameter y Kerberos. Mención especial requiere la norma 801.X, que usa los protocolos RADIUS o Diameter en su arquitectura de seguridad.

2.3.2.4.1 RADIUS

El Servicio de autenticación remota telefónica de usuario (RADIUS) es un protocolo AAA utilizado principalmente para proporcionar servicios de acceso a la red. Debido a su flexibilidad, también se ha adoptado en otros escenarios. Las partes de autenticación y autorización se especifican en RFC 2865, mientras que la parte de responsabilidad se especifica en RFC 2866.

RADIUS es un protocolo cliente-servidor. En el contexto de RADIUS, el cliente es el servidor de acceso, que es la entidad a la que un usuario envía la solicitud de acceso. El servidor suele ser una máquina que ejecuta servicios RADIUS y que proporciona respuestas de autenticación y autorización que contienen toda la información utilizada por el servidor de acceso para proporcionar servicio al usuario.

El servidor RADIUS puede actuar como proxy para otros servidores RADIUS u otros sistemas de autenticación. Además, RADIUS puede admitir varios tipos de mecanismos de autenticación, como PPP PAP, CHAP y EAP. También permite la extensión del protocolo a través del campo de atributo.

La Figura 22 muestra una implementación típica de un servidor RADIUS, un cliente RADIUS (enrutador inalámbrico en este ejemplo) y un portátil (cliente inalámbrico o suplicante).

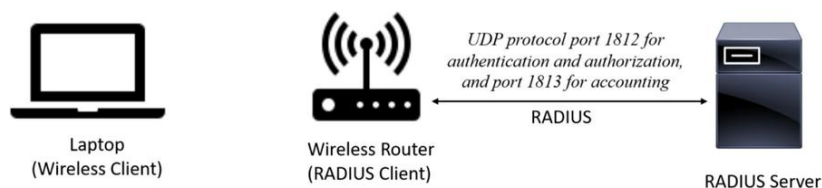


Figura 22: Implementación del servidor RADIUS

RADIUS opera en la mayoría de los casos sobre el puerto de protocolo UDP 1812 para autenticación y autorización, y el puerto 1813 para responsabilidad, que son los puertos asignados oficialmente para este servicio.

2.3.2.4.2 TACACS+

Terminal Access Controller Access Control System Plus (TACACS+) es un protocolo propietario desarrollado por Cisco. También utiliza un modelo cliente-servidor, donde el cliente TACACS+ es el servidor de acceso y el servidor TACACS+ es la máquina que proporciona los servicios TACACS+ (es decir, autenticación, autorización y responsabilidad).

2.3.2.4.3 Diameter

RADIUS y TACACS+ se crearon con el objetivo de proporcionar servicios AAA para el acceso a la red a través de protocolos de acceso telefónico o acceso a terminales. Debido a su éxito y flexibilidad, se han utilizado en varios otros ámbitos. Para responder a los nuevos requisitos y protocolos de acceso, el IETF ha propuesto un nuevo protocolo llamado Diameter, que se describe en la RFC 6733.

Diameter se ha construido con la siguiente funcionalidad:

- **Conmutación por error:** Diameter implementa algoritmos de reconocimiento y conmutación por error a nivel de aplicación.
- **Seguridad a nivel de transmisión:** Diameter protege el intercambio de mensajes mediante TLS o DTLS.
- **Transporte fiable:** Diameter utiliza TCP o SCTP como protocolo de transporte.
- **Soporte de agentes:** Diameter especifica los roles de diferentes agentes, como proxy, retransmisión, redirección y agentes de traducción.
- **Mensajes iniciados por el servidor:** Diameter hace obligatoria la implementación de mensajes iniciados por el servidor. Esto permite capacidades como la re-autenticación bajo demanda y la reautorización.
- **Soporte de transición:** Diameter permite la compatibilidad con sistemas que utilizan RADIUS.
- **Negociación de capacidad:** Diameter incluye negociaciones de capacidad, así como el manejo de errores como pares atributo/valor (AVP) obligatorios y no obligatorios.
- **Descubrimiento de pares (Peer discovery):** Diameter permite el descubrimiento dinámico de pares a través de DNS.

Diameter es un protocolo muy complejo y se utiliza en algunos entornos de proveedores de servicios móviles.

2.3.2.4.4 Kerberos

Kerberos es un protocolo de autenticación de red, diseñado para proporcionar una autenticación sólida para aplicaciones cliente-servidor mediante el uso de criptografía de clave simétrica.

Kerberos lleva el nombre del perro de tres cabezas debido a los tres actores que toman parte en el protocolo:

- **Cliente:** La entidad que busca proporcionar su identidad.
- **Servidor de aplicaciones (AP):** El servicio al que el cliente desea acceder.
- **Centro de distribución de claves (KDC):** Un tercero de confianza que emite los tickets.

Cada una de las entidades va a tener una clave secreta únicamente conocida por ella y por Kerberos. Esto sirve para demostrar la identidad. Para comunicarse genera una clave de sesión y de esta forma se cifran las comunicaciones. Cuando la autenticación se ha realizado correctamente, el servidor

genera un ticket. Ese ticket es enviado al cliente y asegura a los otros servidores que el cliente está autenticado.

La aplicación de Kerberos como herramienta de Single Sign-On (SSO) se estudia en otro tema.

2.3.2.4.5 802.1X

802.1x es un estándar IEEE que se utiliza para implementar el control de acceso basado en puertos. En términos simples, un dispositivo de acceso 802.1X permitirá el tráfico en el puerto solo después de que el dispositivo haya sido autenticado y autorizado.

En una red habilitada para 802.1X, se definen tres roles principales:

- **Servidor de autenticación:** Una entidad que proporciona un servicio de autenticación a un autenticador. El servidor de autenticación determina si el solicitante está autorizado para acceder al servicio. Esto a veces se conoce como el punto de decisión de política (PdP).
- **Suplicante:** Una entidad que busca ser autenticada por un autenticador. Por ejemplo, podría ser una computadora portátil cliente conectada a un puerto de conmutador.
- **Autenticador:** Una entidad que facilita la autenticación de otras entidades conectadas a la misma LAN. Esto a veces se conoce como el punto de aplicación de políticas (PeP). Los switches, routers inalámbricos y puntos de acceso son ejemplos de autenticadores.

Es posible que se requieran otros componentes, como una base de datos de identidades o una infraestructura PKI, para una implementación correcta. La Figura 23 ilustra un ejemplo de un servidor de autenticación, un suplicante y un autenticador. El solicitante está conectado al autenticador (router inalámbrico) a través de una conexión Wi-Fi.

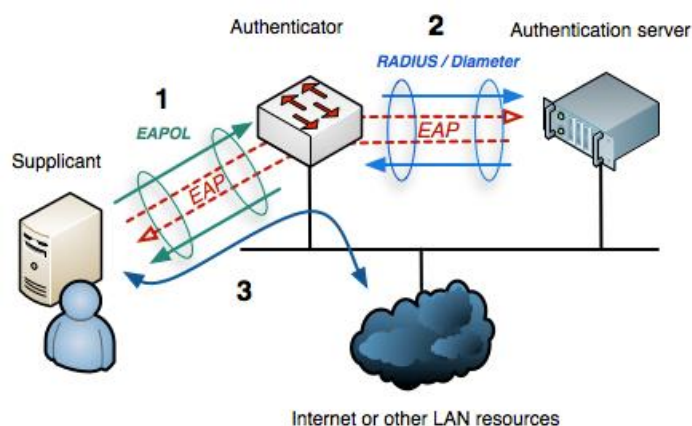


Figura 23: Topología de ejemplo 802.1X

802.1X utiliza los siguientes protocolos:

- **EAP over LAN (EAPoL):** Un protocolo definido en 802.1X que se utiliza para encapsular paquetes EAP que se transmitirán desde el solicitante al autenticador.
- **Protocolo de autenticación extensible (EAP):** Un protocolo de autenticación utilizado entre el solicitante y el servidor de autenticación para transmitir información de autenticación.
- **RADIUS o Diameter:** El protocolo AAA utilizado para la comunicación entre el autenticador y el servidor de autenticación.

2.3.2.5 Listas de control de acceso (ACL)

Una de las implementaciones más básicas de un control de acceso es una ACL. Cuando se aplica una ACL al tráfico de red, se denomina ACL de red. Los dispositivos de red, como enrutadores, conmutadores y firewalls, incluyen capacidades de ACL de red para controlar el acceso a los recursos de red. En cuanto a los controles de acceso basados en puertos, las ACL de red y el firewall generalmente se consideran casos especiales del modelo ABAC y, a veces, también se clasifican como control de acceso basado en identificación o basado en reglas porque basan la decisión de control en atributos como direcciones IP o MAC o información de capa 4. Las ACL de grupos de seguridad, por otro lado, son listas de acceso basadas en el rol del sujeto que intenta acceder a un recurso e implementan un control de acceso basado en roles.

Las ACL de red se pueden implementar en varios niveles del modelo OSI:

- **ACL de VLAN.** Las ACL de VLAN, también llamadas mapas de VLAN, no son específicamente ACL de capa 2; sin embargo, se utilizan para limitar el tráfico dentro de una VLAN específica. Un mapa VLAN puede aplicar una lista de acceso MAC, una ACL de capa 3 y una ACL de capa 4 a la dirección de entrada de una VLAN para proporcionar control de acceso.
- **ACL basada en grupos de seguridad.** Una ACL basada en grupos de seguridad (SGACL) es una ACL que implementa el control de acceso basado en el grupo de seguridad asignado a un usuario (por ejemplo, en función de su rol dentro de la organización) y los recursos de destino.
- **ACL descargable.** Una ACL descargable (dACL), también llamada ACL por usuario, es una ACL que se puede aplicar dinámicamente a un puerto. El término descargable se deriva del hecho de que estas ACL se envían desde el servidor de autenticación durante la fase de autorización limitará los recursos a los que el cliente puede tener acceso a través de la red.

2.3.3 Control de intrusiones

Esencialmente, un IDS inspeccionará toda la actividad de puertos entrantes y salientes en la máquina / firewall / sistema y buscará patrones que puedan indicar un intento de intrusión.

Un sensor es un dispositivo que analiza el tráfico en la red y luego toma una decisión basada en un conjunto de reglas para indicar si ese tráfico está bien o si es malicioso de alguna manera. Debido a que estos son sistemas que actúan en base a reglas configuradas, ningún sistema es cien por cien perfecto. Sin embargo, el objetivo es el mismo: reducir el riesgo de tráfico malicioso, aunque no se pueda eliminar por completo.

Este apartado cubre todo el ámbito del control de intrusiones, detallando tanto los sistemas IDS e IPS y sus diferencias, así como los IPS de nueva generación (NGIPS) y la identificación del tráfico malicioso en la red.

2.3.3.1 IDS e IPS

Hay varias maneras en que se pueden clasificar los sistemas IDS. Las categorías IDS más comunes son los IDS pasivos y los IDS activos (también llamados sistema de prevención de intrusiones o IPS).

- **IDS pasivo.** Un IDS pasivo solo monitoriza la actividad sospechosa y luego la registra. En algunos casos, puede notificar al administrador de la actividad en cuestión. Este es el tipo más básico de IDS. Cualquier sistema moderno debe tener, como mínimo, un IDS pasivo junto con el firewall, antivirus y otras medidas de seguridad tomadas.
- **IDS activo, o IPS.** Un IDS activo toma el paso adicional de cortar la comunicación sospechosa. Al igual que el antivirus, es posible que un IDS tenga un falso positivo. Podría sospechar que algo es un ataque cuando en realidad es tráfico legítimo. Si uno usa un IDS o IPS es una decisión que debe tomarse después de un análisis de riesgos exhaustivo.
Éste es un excelente lugar para considerar el análisis de riesgos. Se deben sopesar los peligros de los falsos positivos frente al riesgo de permitir que un ataque pase desapercibido antes de decidir si un IDS pasivo o un IPS es apropiado para la organización. Es posible encontrar que un IDS pasivo es probablemente lo más apropiado para la mayor parte de la red, pero que se necesite un IPS para los segmentos de red más sensibles.

Realmente hay dos formas de identificar una intrusión. El primer método se basa en la **firma**. Esto es similar a las firmas utilizadas por el antivirus. Sin embargo, las firmas IDS cubren problemas más allá del malware.

El segundo método es la **anomalía estadística**. Esencialmente, cualquier actividad que parezca estar fuera de los parámetros normales y lo suficientemente lejos como para ser considerado como tráfico lícito se identifica como un ataque probable. Un ejemplo puede ser un aumento repentino en la utilización del ancho de banda o cuentas de usuario que acceden a recursos a los que nunca antes habían accedido.

La mayoría de los IDS utilizan ambas formas de reconocimiento de ataques.

2.3.3.2 Diferencia entre IPS e IDS

Se puede colocar un sensor en la red para analizar el tráfico de red en línea o en modo promiscuo.

La primera opción es poner un sensor **en línea** con el tráfico, lo que significa que cualquier tráfico que pase por su red se ve obligado a ir a un puerto físico o lógico en el sensor. En el sensor, se analiza el tráfico y se reenvía a otra interfaz lógica o física para que el paquete continúe su viaje hacia su destino.

Si el tráfico (mientras está en su breve escala en el sensor) es identificado como malicioso por el sensor, el sensor (según las reglas configuradas) podría decidir que no reenviará el paquete más y lo descartará.

Debido a que el sensor está en línea con la red y a que puede dejar caer un paquete y evitar que ese paquete llegue a su destino final, el sensor acaba de evitar que se lleve a cabo ese ataque. Éste es el concepto detrás de los sistemas de prevención de intrusiones (IPS).

Cuando los paquetes llegan al sensor en lo que se llama **modo promiscuo**, puede analizar el tráfico y puede generar alertas. Sin embargo, debido a que el paquete original (el sensor analiza una copia) probablemente ya esté en camino hacia el destino, el sensor por sí solo no puede impedir que el paquete original se adentre más en la red. Por lo tanto, se dice que el IDS está detectando el ataque (de ahí el término sistema de detección de intrusos) pero no está previniendo el ataque.

En pocas palabras, ésta es la diferencia entre IPS, que está en línea, e IDS, que opera en modo promiscuo. Una ventaja de IDS es que no se agrega ningún retraso al paquete original y, si el IDS falla, no obstaculiza el rendimiento de la red porque el IDS no está en línea con el tráfico de la red de producción.

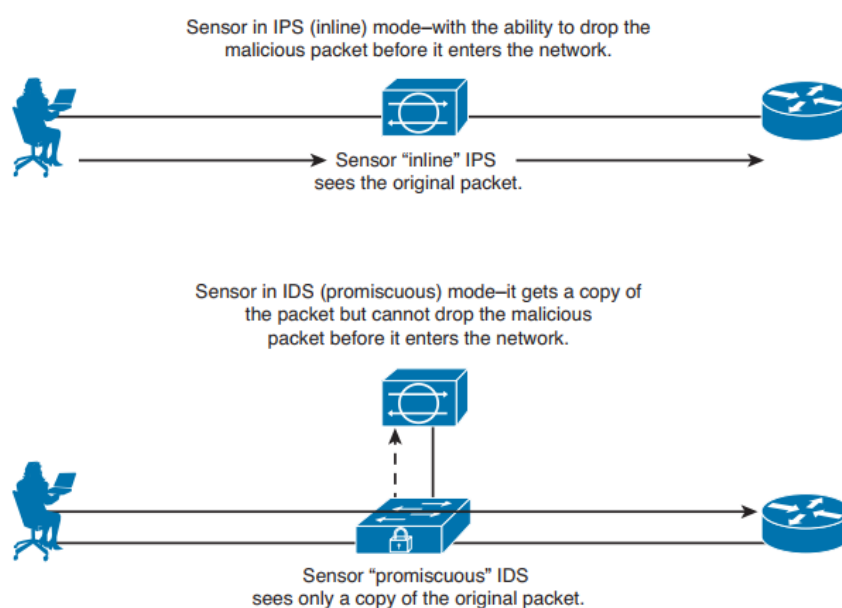


Figura 24: IPS versus IDS

2.3.3.3 Técnicas IPS

Entre las técnicas de IPS más populares se encuentra el snort, los honeypots, la supervisión de la actividad de la base de datos, la deflexión de intrusión y la disuasión de intrusiones.

- **Snort.** Es de código abierto. Se pueden descargar directamente desde la web tanto las reglas como el paquete de instalación. Ofrece la posibilidad de conectarse con una base de datos existente para el volcado de los registros de Snort.
- **Honeypots.** Un hoyneypot es una tecnología interesante. Esencialmente, asume que un atacante puede violar la seguridad de su red. Y sería mejor distraer a ese atacante de sus valiosos datos. Por lo tanto, uno crea un servidor que tiene datos falsos, tal vez un servidor SQL u Oracle cargado con datos falsos, y un poco menos seguro que sus servidores reales. Luego, dado que ninguno de sus usuarios reales accede a este servidor, se instala un software de monitorización para alertarlo cuando alguien accede a este servidor. Un hoyneypot logra dos objetivos. Primero, desviará la atención del atacante de los datos que desea proteger. En segundo lugar, proporcionará lo que parecen ser datos interesantes y valiosos, lo que llevará al atacante a permanecer conectado al servidor falso, lo que le dará tiempo para intentar rastrearlos.
- **Supervisión de la actividad de la base de datos.** La supervisión de la actividad de la base de datos (DAM) es la supervisión y el análisis de la actividad de la base de datos que funciona independientemente del sistema de administración de bases de datos (DBMS). Es

independiente de la auditoría, el registro y la supervisión de DBMS. La supervisión y prevención de la actividad de la base de datos (DAMP) es una extensión de DAM que va más allá de la supervisión y las alertas para bloquear también las actividades no autorizadas.

- **Deflexión de intrusión.** Se intenta atraer al intruso a un subsistema creado con el propósito de observarlo. Esto se hace engañando al intruso para que crea que ha logrado acceder a los recursos del sistema cuando, de hecho, ha sido dirigido a un entorno especialmente diseñado. Esto se hace a menudo mediante el uso de un honeypot. El verdadero propósito del sistema es monitorizar cuidadosamente las actividades de cualquier persona que acceda al sistema. Dado que ningún usuario legítimo accede a este sistema, es un hecho que cualquiera que acceda a él es un intruso.
- **Disuasión de intrusiones.** Este método implica simplemente tratar de hacer que el sistema parezca un objetivo menos aceptable. En resumen, se intenta hacer que cualquier recompensa potencial de un intento de intrusión exitoso requiera un esfuerzo mayor que el valor que se va a obtener.

2.3.3.4 NGIPS

Los IPS legacy dependen principalmente de patrones basados en firmas coincidentes para identificar y potencialmente prevenir la actividad maliciosa. Los IPS de nueva generación o NGIPS complementan la funcionalidad IPS legacy con más capacidades, como las siguientes:

- **Conocimiento y control de aplicaciones:** Los NGIPS proporcionan visibilidad de las aplicaciones de capa 7 y pueden proteger contra las amenazas de capa 7.
- **Conocimiento del contenido de la información que atraviesa la infraestructura:** Por ejemplo, el conocimiento sobre los archivos transferidos entre dos hosts se puede utilizar para identificar los virus transferidos y la trayectoria de una infección de virus en un sistema.
- **Conocimiento contextual:** Ayuda a comprender mejor las alertas y deducir automáticamente información completa sobre los eventos que tienen lugar, lo que hace que el NGIPS sea menos complejo y significa que requiere menos ajustes.
- **Conocimiento del anfitrión y del usuario:** La infraestructura ofrece información más concluyente sobre los eventos que tienen lugar.
- **Ajuste y recomendaciones automatizados:** Esto permite a un administrador seguir recomendaciones y ajustar firmas específicamente a su entorno.
- **Evaluación de impacto y vulnerabilidad de los eventos que tienen lugar:** El impacto de un evento de seguridad identificado por el sistema se puede evaluar en función de la información disponible para el entorno. Por ejemplo, un sistema Windows identificado para proteger una vulnerabilidad no puede verse gravemente afectado por un intento de explotar la vulnerabilidad en su contra.

Las redes modernas evolucionan constantemente, al igual que los malhechores y sus métodos de ataque. Las herramientas de seguridad modernas deben integrarse directamente en el tejido de red para maximizar el rendimiento y la eficiencia. Las respuestas deben ser completas y sencillas. La protección debe ser continua. Los controles de red no deben implementarse de manera dispar e individual.

2.3.3.5 Identificación del tráfico malicioso en la red

Los sensores pueden identificar el tráfico malicioso de muchas maneras diferentes. Esta sección examina algunas de las técnicas utilizadas por los sensores IPS e IDS.

Cuando el sensor analiza el tráfico, busca tráfico malicioso en función de las reglas que están actualmente vigentes en ese sensor. Existen varios métodos diferentes que los sensores se pueden configurar para identificar el tráfico malintencionado, incluidos los siguientes:

- **IPS/IDS basado en firmas.** Una firma es solo un conjunto de reglas que buscan algún patrón o característica específica en un solo paquete o en un flujo de paquetes. No todas las firmas están habilitadas, pero el administrador puede habilitar, deshabilitar, personalizar y crear nuevas firmas para satisfacer las necesidades de la red actual donde funciona el sensor. El IPS/IDS basado en firmas es el método más importante utilizado en los sensores hoy en día. Para fines de ajuste, si una firma predeterminada sigue activándose en función del tráfico que es normal para su red, eso se considera un falso positivo para una red específica, y se puede ajustar el sensor deshabilitando esa firma o configurando el filtro para que esa firma no genere una alerta cuando vea una coincidencia de direcciones IP específicas.

- **IPS/IDS basado en políticas.** Este tipo de coincidencia de tráfico se puede implementar en función de la directiva de seguridad de la red. Por ejemplo, si la organización tiene una directiva de seguridad que establece que no se debe usar tráfico Telnet (por razones de seguridad) en áreas específicas de la red, se puede crear una regla personalizada que indique que si se ve tráfico TCP destinado al puerto 23 (que es el puerto conocido para Telnet) a un dispositivo en la parte de la red para la que Telnet no está permitido, el IPS puede generar una alerta y descartar el paquete. Si esto está configurado como IDS, se podría simplemente generar una alerta (pero no puede descartar el paquete por sí solo porque IDS está en modo promiscuo y no en línea).
- **IPS/IDS basado en anomalías.** Un ejemplo de IPS/IDS basado en anomalías es crear una línea base de cuántas solicitudes de remitente TCP se generan en promedio cada minuto que no obtienen una respuesta. Éste es un ejemplo de una sesión entreabierta. Si un sistema crea una línea base de esto (suponiendo que la línea base es un promedio de 30 sesiones semiabiertas por minuto), y luego se nota que las sesiones semiabiertas han aumentado a más de 100 por minuto, y luego actúa en función de eso y genera una alerta o comienza a denegar paquetes, éste es un ejemplo de IPS/IDS basado en anomalías. Esta capacidad (llamada detección de anomalías) se utiliza para identificar gusanos.
- **IPS/IDS basado en reputación.** El IPS basado en la reputación recopila información de sistemas de todo el planeta que participan en la correlación global. Entonces, lo que otros sensores han aprendido colectivamente, el sensor local puede usarlo localmente. Un IPS/IDS basado en la reputación puede incluir descriptores como bloques de direcciones IP, URL, dominios DNS, etc. como indicadores de las fuentes de estos ataques. Los proveedores de soluciones de seguridad suelen ofrecer esta funcionalidad desde la nube.

2.3.4 Técnicas criptográficas

Hay muchos aspectos de la seguridad informática y de la información. El cifrado, el proceso de codificar un mensaje u otra información para que no se pueda leer fácilmente, es una de las partes más críticas del rompecabezas de la seguridad. Si se tiene el mejor firewall, estrictas políticas de seguridad, sistemas operativos reforzados, escáneres de virus, software de detección de intrusos, antispyware y todos los demás ángulos de seguridad informática cubiertos, pero se envían los datos en texto sin procesar y sin formato, entonces simplemente no hay seguridad.

En la seguridad de redes se utiliza el cifrado en las comunicaciones que transcurren por dichas redes. En este apartado se van a analizar las técnicas criptográficas aplicadas en las redes públicas (SSL/TLS) y las utilizadas en las redes privadas virtuales, comúnmente conocidas como VPN.

Una VPN es esencialmente una forma de usar Internet para crear una conexión virtual entre un usuario o sitio remoto y una ubicación central. Los paquetes enviados de ida y vuelta a través de esta conexión están encriptados, lo que la hace privada. La VPN debe emular una conexión de red directa.

Hay tres protocolos diferentes que se utilizan para crear VPN:

- Protocolo de túnel punto a punto (PPTP)
- Protocolo de túnel de capa 2 (L2TP)
- Seguridad del protocolo de Internet (IPsec)

De estos tres protocolos solo dos incluyen técnicas criptográficas intrínsecamente, PPTP e IPsec, que se verán en mayor detalle más abajo. L2TP utiliza IPsec para el cifrado.

El Protocolo de túnel de capa 2 (L2TP) se diseñó explícitamente como una mejora de PPTP. Al igual que PPTP, funciona en la capa de enlace de datos del modelo OSI. Tiene varias mejoras a PPTP. Primero, ofrece más y variados métodos para la autenticación: PPTP ofrece dos, mientras que L2TP ofrece cinco. Además de CHAP y EAP, L2TP ofrece PAP, SPAP y MS-CHAP.

2.3.4.1 Protocolo de túnel punto a punto

El protocolo de túnel punto a punto (PPTP) es el más antiguo de los tres protocolos utilizados en las VPN. Fue diseñado originalmente como una extensión segura del Protocolo Punto a Punto (PPP). PPTP fue propuesto originalmente como un estándar en 1996 por el Foro PPTP. Agrega las características de cifrado de paquetes y autenticación de usuarios al protocolo PPP anterior. PPTP trabaja en la capa de enlace de datos del modelo OSI.

PPTP ofrece dos métodos diferentes para autenticar al usuario: Protocolo de autenticación extensible (EAP) y Protocolo de autenticación por desafío mutuo (CHAP). EAP en realidad fue diseñado

específicamente para PPTP y no es propietario. CHAP es un proceso tridireccional mediante el cual el cliente envía un código al servidor, el servidor lo autentica y, a continuación, el servidor responde al cliente. CHAP también vuelve a autenticar periódicamente un cliente remoto, incluso después de establecer la conexión.

PPTP utiliza Microsoft Point-to-Point Encryption (MPPE) para cifrar paquetes. MPPE es en realidad una versión de DES. DES sigue siendo útil para muchas situaciones; sin embargo, se prefieren las versiones más recientes de DES, como DES 3.

2.3.4.2 IPsec

IPsec es el último de los tres protocolos VPN mencionados anteriormente. Una de las diferencias entre IPsec y los otros dos métodos es que cifra no sólo los datos del paquete, sino también la información del encabezado.

IPsec es una colección de protocolos y algoritmos utilizados para proteger paquetes IP en la Capa 3 (de ahí el nombre de Seguridad IP, IPsec). IPsec proporciona los principales beneficios de la confidencialidad a través de cifrado, integridad de datos mediante hash y HMAC, y autenticación mediante firmas o usar una clave precompartida (PSK) que es solo para la autenticación, similar a una contraseña. También tiene protección contra la retransmisión no autorizada de paquetes.

IPsec funciona en uno de dos modos: **modo de transporte**, en el que solo se cifra la carga útil, y **modo de túnel**, en el que se cifran tanto los datos como los encabezados IP.

A continuación se muestran algunos términos básicos de IPsec:

- Los encabezados de autenticación (**AH**) proporcionan integridad sin conexión y autenticación de origen de datos para paquetes IP.
- Las cargas útiles de seguridad encapsuladas (**ESP**) proporcionan autenticidad, integridad y protección de confianza de origen de los paquetes. Estos tienen configuraciones de solo cifrado y solo autenticación.
- Las asociaciones de seguridad (**SA**) proporcionan los parámetros necesarios para las operaciones AH o ESP. Las SA se establecen mediante la Asociación de seguridad de Internet y el Protocolo de administración de claves.
- Internet Security Association and Key Management Protocol (**ISAKMP**) proporciona un marco para la autenticación y el intercambio de claves.
- El intercambio de claves de Internet (**IKE** e **IKEv2**) se utiliza para configurar una asociación de seguridad (SA) mediante la negociación de protocolos y algoritmos y para generar las claves de cifrado y autenticación que se utilizarán.

Esencialmente, durante el establecimiento inicial de un túnel IPsec, se forman asociaciones de seguridad (SA). Estas SA tienen información como qué algoritmo de cifrado y qué algoritmos hash se utilizarán en el túnel IPsec. IKE se ocupa principalmente del establecimiento de estas SA. ISAKMP permite que los dos extremos del túnel IPsec se autenticuen entre sí e intercambien claves.

IPsec usa el protocolo de **intercambio de claves de Internet (IKE)** para negociar y establecer túneles seguros de red privada virtual (VPN) de acceso remoto o de sitio a sitio.

En la fase 1 de IKE, los pares IPsec negocian y se autentican entre sí. En la fase 2 negocian materiales de claves y algoritmos para el cifrado de los datos que se transfieren a través del túnel IPsec.

Hay dos versiones de IKE: IKEv1 definido en RFC 2409 e IKEv2, definido en RFC 4306.

IKEv2 mejora la función de realizar el intercambio dinámico de claves y la autenticación de pares. IKEv2 simplifica los flujos de intercambio de claves e introduce medidas para corregir las vulnerabilidades presentes en IKEv1. IKEv2 proporciona un intercambio más simple y eficiente.

2.3.4.3 SSL/TLS

La gran ventaja de SSL es que casi todos los navegadores web en todas las computadoras lo admiten, por lo que casi cualquier persona que tenga un ordenador puede usarlo.

Para usar SSL, el usuario se conecta a un servidor SSL, que es una forma de decir un servidor web que admite SSL, utilizando HTTPS en lugar de HTTP. Una manera fácil de recordar es que la S significa seguro. Dependiendo de con quién hable, SSL también puede etiquetarse como Seguridad de la capa de transporte o TLS. Para el usuario final, representa una conexión segura con el servidor y con el servidor correcto.

La mayoría de las veces el servidor web utiliza algún tipo de autenticación de usuario, como un nombre de usuario o contraseña, según sea necesario, para verificar quién es el usuario. Una vez realizada la autenticación, se producen varios intercambios adicionales entre el navegador y el servidor a medida que establecen el algoritmo de cifrado que utilizarán y las claves que utilizarán para cifrar y descifrar los datos (PKI).

TLS y su predecesor SSL son protocolos criptográficos que proporcionan transacciones seguras en Internet para cosas como correo electrónico, navegación web, mensajería instantánea, etc. SSL como protocolo fue desarrollado originalmente por Netscape. La mayoría de las transacciones en línea basadas en el navegador están protegidas por SSL o TLS. Ambos protocolos proporcionan servicios de confidencialidad, integridad y autenticación. Se considera que estos protocolos funcionan en la capa de sesión y superior en el modelo lógico OSI. Ambos pueden usar la infraestructura de clave pública (PKI) y los certificados digitales para la autenticación de los puntos finales de VPN y para establecer las claves de cifrado que se pueden usar. Al igual que IPsec, estos protocolos utilizan algoritmos simétricos para el cifrado masivo, y los algoritmos asimétricos se utilizan para la autenticación y para el intercambio de claves.

2.4 Conclusión

En este capítulo se han visto en detalle los diferentes tipos de ataques existentes en la actualidad. Nótese que a medida que aparecen nuevas tecnologías y se aumenta la superficie de ataque, surgen nuevos métodos de ataque y variaciones de los existentes.

La principal herramienta de seguridad en cualquier red es el cortafuegos. Con el paso del tiempo, ha ido integrando más funcionalidades, como el control de intrusiones o la terminación de túneles virtuales, hasta llegar a la nueva generación de firewalls (NGFW), con la inspección profunda de paquetes.

Uno de los elementos más importantes en la securización de las redes para por el control de accesos e intrusiones. Se han analizado las distintas dimensiones de la autenticación y de la autorización, aportando información relevante sobre los principales protocolos AAA y las listas de control de acceso.

Otro elemento básico de la seguridad informática es el cifrado. Enviar datos confidenciales que no están encriptados es simplemente un absurdo. Lo más importante a tener en cuenta es que, en última instancia, no son los equipos informáticos o la red lo que se verá comprometido, sino los datos. Cifrar los datos al transmitirlos es una parte integral de cualquier plan de seguridad. En la seguridad en redes, destaca la aplicación de técnicas criptográficas como IPsec o TLS, estudiadas en este apartado.

3 Medidas específicas para las comunicaciones móviles

3.1 Introducción

La red móvil comenzó simplemente como un canal de comunicación de voz, pero ha superado a cualquier otro medio en la historia para convertirse en el centro de la vida cotidiana, la economía y la sociedad. El futuro de las sociedades y de las grandes economías, como Europa, depende en gran medida de la infraestructura móvil. Con la tecnología 5G se llegará a un escenario con más conectividad y más generación y uso compartido de información utilizando las redes móviles.

Como resultado del auge de las telecomunicaciones y su papel crítico en la salud pública y económica en general, esta industria pronto se convertirá en un objetivo principal para los actores antiestatales y criminales que desean aprovechar esta plataforma para interrumpir su crecimiento y, a su vez, usarla para lanzar ataques contra una base de usuarios más amplia de redes móviles. Los impactos de las infracciones en esta nueva generación del mundo conectado pueden ser enormes, como los numerosos ataques que sufren las grandes empresas que aparecen cada día en primera plana.

La seguridad de las redes móviles ha evolucionado gradualmente en paralelo a la evolución de la industria de las telecomunicaciones. En este capítulo, se va a cubrir el panorama general de amenazas de seguridad de las redes móviles a medida que evolucionó con las diversas generaciones de redes móviles. También se analizará la historia de las amenazas de seguridad móvil, los mecanismos de protección relativos y los impactos en las redes móviles.

Se asume que el lector domina los conceptos de las diferentes generaciones de redes de comunicaciones móviles hasta el 5G, presentes en otro tema.

3.2 La seguridad en redes móviles: amenazas y medidas de protección

El panorama de la seguridad de las redes móviles (como se muestra en la Figura 25) debe considerarse a la luz de cómo han evolucionado las distintas generaciones de redes móviles. Existe una correlación directa entre la evolución de la tecnología de red móvil y la evolución relativa a las amenazas de seguridad en términos de arquitectura tecnológica, capacidades técnicas, servicios ofrecidos y vectores de amenazas asociados.

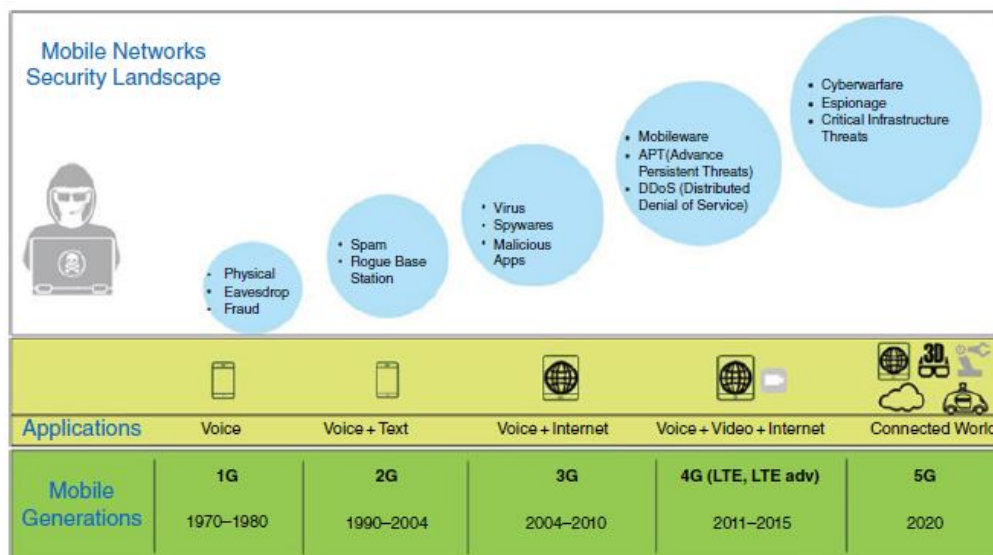


Figura 25: Panorama de seguridad de redes móviles

Las redes móviles comenzaron a presenciar serias amenazas y desafíos inmediatamente después de la introducción de la primera generación (también llamada 1G) de tecnología móvil y han seguido creciendo como un panorama de amenazas complejo y desafiante. 1G se introdujo principalmente para ofrecer movilidad a los usuarios de voz. Los consumidores comenzaron a presenciar la libertad de asistir y hacer llamadas mientras estaban en movimiento. Los delincuentes descubrieron una

oportunidad y métodos para cometer fraudes móviles y hacerse pasar por los suscriptores legales para hackear su teléfono para hacer llamadas gratuitas. Algunos hackers identificaron nuevas formas de secuestrar y espiar las llamadas mientras se realizaban, y escuchar las conversaciones privadas.

Con 2G, la era del spam de mensajes surgió en el mundo móvil. El spam se utilizó como un ataque generalizado para inyectar información falsa o enviar jerga de marketing no deseada a los usuarios móviles. Las bandejas de entrada de mensajes estaban ocupadas con mensajes de spam dirigidos a un determinado grupo o a la comunidad en general. Las estaciones base no autorizadas (IMSI Catchers) se inventaron para interceptar el tráfico móvil ofreciendo autenticación de red falsa.

A medida que los dispositivos de los usuarios se vuelven inteligentes e ingeniosos, las aplicaciones de datos e Internet se convirtieron en los servicios clave ofrecidos por los proveedores de servicios móviles en las nuevas redes 3G. Una velocidad promedio de conexión de datos 3G estaba entre 500 y 700 kbps, lo que era suficiente para proporcionar conectividad para aplicaciones orientadas a Internet. Se explotaron las vulnerabilidades del sistema operativo móvil, ya que las aplicaciones móviles se inyectaron con código malicioso para obtener acceso no autorizado a información personal confidencial, como contactos, contraseñas de usuario y datos de ubicación. A medida que aumentaba la velocidad de los datos, también lo hacía el tipo de infecciones en forma de malwares y spywares.

LTE fue la primera vez en la que la red móvil se cambió a una arquitectura de extremo a extremo basada en IP. Ayudó a los proveedores de servicios móviles con mayor velocidad, ofreció nuevos servicios y escala, y también aumentó el vector de amenaza para las redes 4G. DDoS y APT fueron las nuevas realidades para la red móvil, ya que el impacto en el servicio fue crítico con enormes pérdidas financieras como resultado de tales ataques. Los atacantes se organizaron más y comenzaron a seguir un enfoque sistemático en su amenaza de ejecución. Se ha vuelto más difícil detectar su presencia sigilosa en la red móvil, protegerla y mitigarla, con un ataque promedio que consiste en meses de duración.

5G se presenta con la promesa de conectar miles de millones de dispositivos y teléfonos a través de una infraestructura de red altamente confiable, ampliamente densa, con gran capacidad de ancho de banda, rápida y tolerante a fallos, que dará servicio a múltiples sectores e industrias. Los casos de uso clave para 5G son la infraestructura crítica, IoT, las ciudades inteligentes y el mundo conectado. Con estos casos de uso, 5G será un objetivo ideal para los atacantes que quieran causar una interrupción económica y social importante dentro de un plazo mínimo. Las amenazas 5G se constituirán en torno a ganancias financieras y políticamente motivadas, ejecutadas por grupos de profesionales y delincuentes con amplios conocimientos y recursos tecnológicos.

3.2.1 Amenazas de seguridad y protección para 1G

1G ofrecía servicios de solo voz que se basaban en la tecnología analógica, también conocida como Advance Mobile Phone System (AMPS). Utilizaba frecuencias separadas utilizando el método FDMA (Acceso Múltiple por División de Frecuencia) para cada llamada y requería un gran ancho de banda para servir a varias unidades móviles. No había mecanismos integrados de autenticación o identificación para identificar de forma única el teléfono del usuario, lo que dejaba la red móvil expuesta, con nula protección contra el secuestro de canales, la clonación y las escuchas. La clonación se utilizó no sólo para el uso indebido del sistema, sino también para muchas otras actividades delictivas y fraudulentas.

Como se demuestra en la Figura 26, los atacantes pueden usar herramientas listas para usar como Oki 900 para suplantar y espiar las comunicaciones a través de AMPS.

Tales amenazas han obligado a los operadores a interrumpir muchas conexiones legítimas de suscriptores e introducir nuevos mecanismos de identificación, como un código PIN único para que cada cliente elimine dispositivos móviles nefastamente clonados de su red.

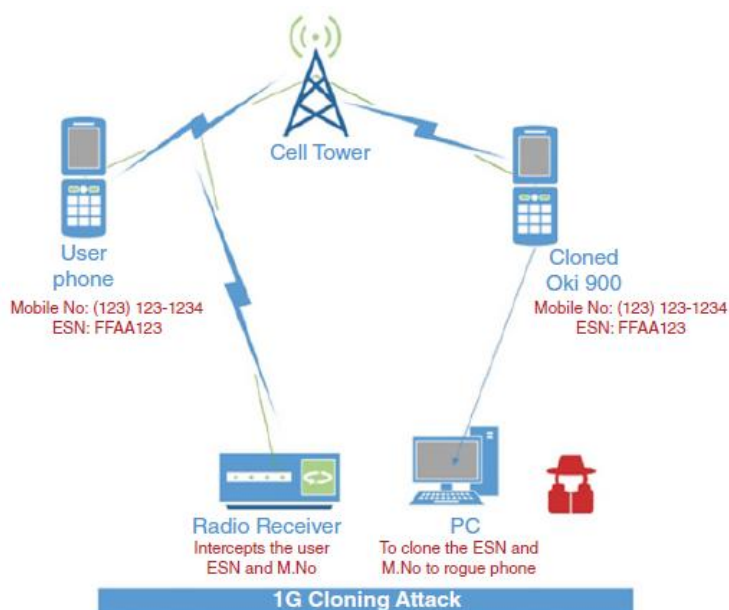


Figura 26: Ataque de clonación de teléfonos móviles en red 1G

3.2.2 Amenazas de seguridad y protección para 2G

La autenticación del usuario siguió siendo un enfoque clave al desarrollar estándares 2G, ya que el objetivo era reducir el fraude de cargos de llamadas, el secuestro de canales y la superficie de ataque de clonación móvil. El módulo de identidad del suscriptor (SIM) se utilizó por primera vez para asignar una identificación única para teléfonos móviles y podía almacenarse de forma segura como un chip de computadora dentro del teléfono celular.

A medida que la protección de la identidad del usuario comenzó a tomarse en serio, se introdujo una nueva amenaza en 2G, enmascarada como una estación base portadora con una estación base deshonesta (también llamada IMSI Catcher) para realizar un ataque man-in-the-middle- (MitM).

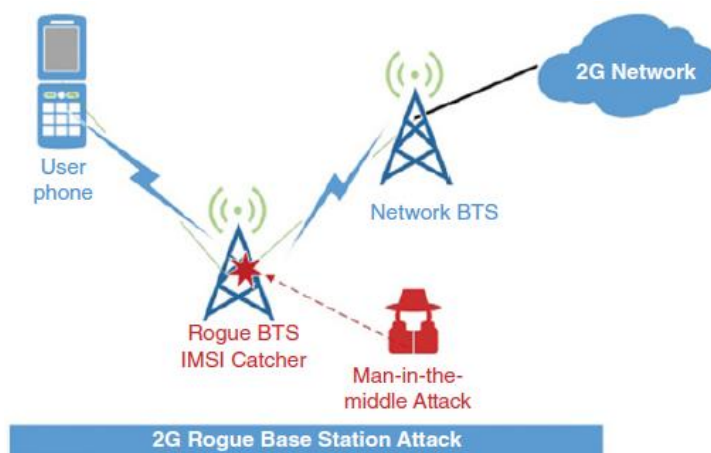


Figura 27: Ataque IMSI Catcher en red 2G

La amenaza IMSI (International Mobile Subscriber Identity) se muestra en la Figura 27. Este ataque explotó la falta de autenticación de 2 vías entre el teléfono y la red móvil. Los atacantes instalarían una estación base no autorizada que podría hacerse pasar por una BTS (estación transceptora base) válida y permitir que el usuario transmitiera la información de identidad crítica, como IMSI, a través de un canal no seguro. Un atacante podría copiar fácilmente el tráfico de Internet del usuario y extraer la información, como la contraseña, a través de analizadores. Curiosamente, las herramientas necesarias para lanzar un ataque GSM MitM están disponibles en el mercado, es decir, un BTS (Base Transceiver Station) regular y el software de código abierto OSMOCOMBB.

3.2.3 Amenazas de seguridad y protección para 3G

La red móvil de tercera generación (3G) decidió basar su seguridad siguiendo el marco CIA (Confidencialidad, Integridad y Disponibilidad). Como resultado, se adoptó el protocolo AKA (Authentication and Key Agreement) para la autenticación bidireccional entre el equipo del usuario y la red, y también para proteger contra ataques, como estaciones base no autorizadas. AKA utilizó fuertes claves de autenticación de 128 bits y funciones hash para mantener la autenticidad e integridad de los mensajes de señalización enviados por radio.

A pesar de que la autenticación bidireccional redujo las posibilidades de tales ataques, ataques como MitM todavía serían posibles en el entorno UMTS utilizando herramientas tan avanzadas como bloqueadores móviles y OSMOCOMBB.

Las redes móviles pasaron a un modelo de conmutación de paquetes, RAN (Radio Access Network) y red IP Core basadas en IP, y estos cambios desataron el vector de amenazas basado en IP que no había estado presente en generaciones anteriores de redes móviles.

Los dispositivos móviles fueron reemplazados por ordenadores de pequeño tamaño llamados teléfonos inteligentes (smartphones), que se convirtieron en anfitriones de vulnerabilidades y debilidades típicas del sistema operativo. Los teléfonos inteligentes ahora requieren parches y actualizaciones regulares contra las vulnerabilidades del sistema y la entrada de virus y spyware.

La instalación de aplicaciones no autorizadas o maliciosas causó que los teléfonos fueran pirateados y, a veces, se usaran para degradar el rendimiento del servicio de los proveedores de servicios móviles y atacar la red.

3.2.4 Amenazas de seguridad y protección para 4G

4G LTE y LTE Adv. en general han introducido un gran salto y evolución en el rendimiento y el rendimiento de la red móvil. Ofrece servicios de voz, datos, video e Internet a través de una arquitectura móvil común.

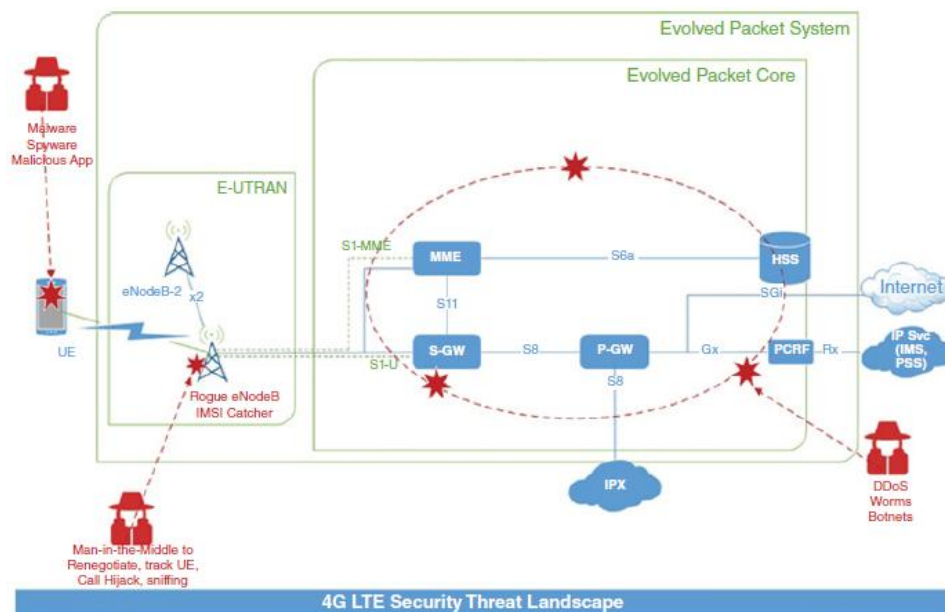


Figura 28: Panorama de amenazas de seguridad 4G de extremo a extremo

Las amenazas 4G estaban dispersas en múltiples dominios de la red 4G, como se muestra en la Figura 28. Hubo nuevos tipos de malware dirigidos a teléfonos inteligentes, con el fin de robar datos de usuario y contraseñas. Se han desarrollado millones de aplicaciones maliciosas para hacerse pasar por juegos de usuario, utilidades o aplicaciones bancarias falsas. A medida que la base instalada del sistema operativo de teléfonos inteligentes llegó a millones, los atacantes comenzaron a identificar vulnerabilidades y desarrollaron amenazas en consecuencia, como las APT.

Con las redes centrales IP, las redes 4G fueron atacadas con ataques DDoS (denegación de servicios distribuidos) bien diseñados para causar un mayor impacto en los servicios móviles. La seguridad 4G LTE se puede dividir en múltiples dominios, como UE, RAN, Core Network y Internet Services.

- **Seguridad del dominio LTE (red de acceso remoto).** LTE E-UTRAN puede ser explotado para obtener acceso a las ubicaciones de UE utilizando su Identificador Temporal de Red de Radio Celular (C-RNTI), mientras que UE reside en una sola celda o se desplaza a través de múltiples celdas. Este ataque se puede proteger cifrando la señal de control de transporte de tráfico y ordenando y confirmando mensajes para C-RNTI.
- **Seguridad del dominio de red central LTE.** La protección para DDoS se puede realizar a través de un sistema de seguridad anti-DDoS especializado, o se pueden usar tecnologías de red más nuevas, como la red definida por software (SDN), para impulsar las políticas de seguridad a través de un controlador centralizado.

3.2.5 Amenazas de seguridad y protección para 5G

Con el amplio espectro de aplicaciones y servicios 5G y su papel crítico para servir a la sociedad para el crecimiento social, económico y de seguridad pública, el vector de amenaza para 5G puede ser muy amplio. Las motivaciones para amenazar y atacar el 5G ahora serán más altas que en las generaciones de redes anteriores. Existe una mayor posibilidad de que el 5G sea un objetivo clave para las actividades criminales impulsadas por varios motivos diferentes, como motivos políticos patrocinados por el estado, cárteles del crimen organizado, espionaje y guerra cibernética.

Los atacantes siguen innovando y encontrando nuevas formas de evadir la detección, habiendo aprendido a explotar el sistema social y financiero para sus necesidades. Con la evolución de los sistemas de pago digital y tecnologías como Bitcoin entrando en la corriente principal, será mucho más fácil para los delincuentes permanecer bajo la manta y seguir obteniendo los beneficios financieros.

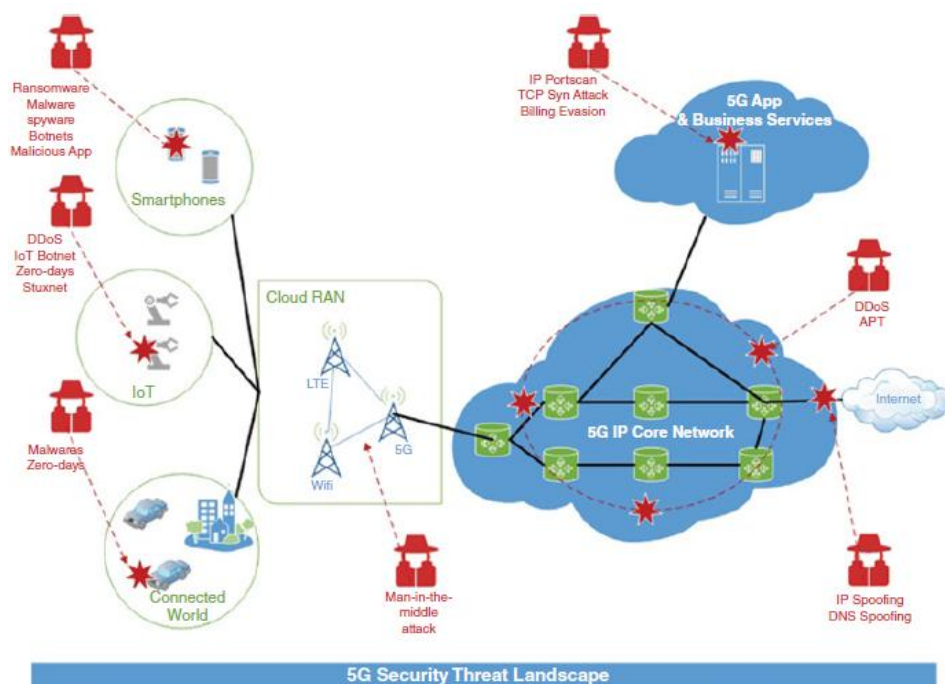


Figura 29: Panorama de amenazas a la seguridad 5G

El vector de amenaza 5G no tendrá límites y abarcará desde el equipo del usuario final, como teléfonos móviles, artículos industriales, sensores, domótica, automóviles automatizados, redes empresariales hasta redes móviles. Con un panorama de amenazas tan grande, como se demuestra en la Figura 29, abarcará desde los dispositivos del usuario final hasta la RAN (Red de Acceso Radio) y la red central móvil e Internet. La Figura 29 también cubre el posicionamiento de varios tipos de amenazas dentro de la red, como los tipos de amenazas de teléfonos inteligentes, incluidos ransomware, spyware, malware y bots. Se podría lanzar un ataque MitM en el dominio Cloud RAN, mientras que DDoS puede apuntar a la red central IP, cada dominio de la red 5G estará bajo amenaza en tal panorama.

Para proteger 5G de entornos de amenazas avanzados y complejos, es necesario un modelo de seguridad evolucionado que ofrezca una protección en profundidad, no solo contra las amenazas existentes sino también contra los tipos de amenazas en evolución y de día cero. Requerirá una estrategia y un plan de seguridad bien definidos para proteger los diversos componentes de la red 5G, incluidos los dispositivos finales y los usuarios finales.

3.3 Aspectos fundamentales de la seguridad en las redes 5G

Los sistemas de seguridad también deben rediseñarse de acuerdo con los requisitos de diseño y arquitectura de 5G. La visión de los sistemas 5G seguros se basa en tres principios:

- 1) Mecanismos de seguridad flexibles;
- 2) Seguridad suprema incorporada; y
- 3) Automatización.

La visión es que 5G debe proporcionar sistemas de seguridad altamente robustos contra ataques cibernéticos, con una mayor garantía de privacidad y seguridad. Los mecanismos de seguridad deben ser flexibles para incorporar tecnologías novedosas, por ejemplo, para la autenticación y la identificación. La flexibilidad debe permitir la opción de utilizar cifrado para el plano de usuario y el ajuste de los parámetros de seguridad por segmento de red. Los sistemas de seguridad también deben poder automatizarse para ajustarse y adaptarse de forma inteligente según el entorno, las amenazas o los controles de seguridad. Una orquestación y gestión de seguridad holística será muy necesaria.

Dado que 5G tiene una mayor flexibilidad y agilidad, los dos conceptos que son más prominentes para desempeñar un papel vital en 5G son las funciones de red virtual (VNF) y el control de red basado en software. Se prevé que estas características sean habilitadas por la virtualización de funciones de red (NFV) y las redes definidas por software (SDN).

NFV permite a los proveedores implementar funciones de red en software llamadas VNF e implementarlas en servidores de alta gama o en plataformas de la nube en lugar de hardware especializado específico de la función.

SDN, por otro lado, separa el plano de control de red del plano de reenvío de datos para permitir la innovación en los sistemas de control de red. Por lo tanto, NFV y SDN serán vitales para proporcionar seguridad infalible en los sistemas 5G. El diagrama básico de la red 5G que proporciona conectividad a todos los dispositivos en todo momento, cubriendo casi todos los aspectos de la sociedad, se presenta en la Figura 30.

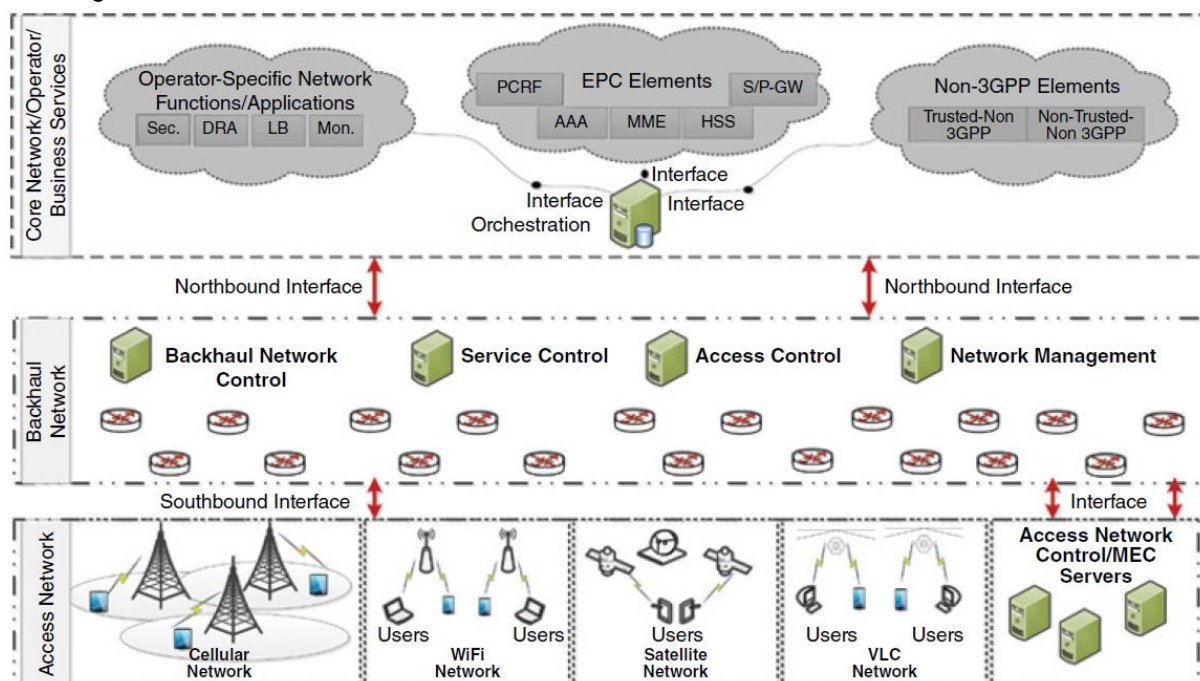


Figura 30: Arquitectura 5G de alto nivel que integra múltiples tecnologías de acceso

3.3.1 Seguridad en la capa física

La seguridad de la capa física ciega basada en marcas de agua (WBPLSec) es un método valioso para asegurar la comunicación sin ninguna suposición sobre canal de espionaje ni interferencia de nodos de terceros. En el contexto multimedia, el proceso de marca de agua digital se utiliza para ocultar o incrustar una señal deseada en otra señal, por ejemplo, en imágenes y videos. Este proceso tiene muchas similitudes con las comunicaciones tradicionales.

La seguridad de la capa física se puede utilizar junto con y no en competencia con los protocolos criptográficos convencionales. En el 5G de las redes móviles, en el que la seguridad debe estar integrada en la arquitectura del sistema, es importante desarrollar nuevas técnicas que implementan soluciones independientes. En este punto, WBPLSec aparece como una solución de capa física confiable contra ataques de divulgación de información, como las escuchas.

Hoy en día, hay dos prácticas estándar para asegurar las comunicaciones. El primer enfoque agrega autenticación y cifrado a los protocolos existentes. El segundo, incorpora tecnologías de seguridad en la capa física. En el contexto de las redes 5G, la seguridad de la capa física proporciona ventajas en comparación con las técnicas de criptografía. La primera ventaja es que esta técnica no depende de la complejidad computacional. En otras palabras, el nivel de seguridad de la WBPLSec no se verá afectado, incluso si un usuario con alta capacidad de cálculo escuchara la comunicación segura. La segunda ventaja está relacionada con la escalabilidad, porque cualquier comunicación segura basada en criptografía necesita la distribución de claves criptográficas y la gestión de claves. En resumen, la seguridad de la capa física se puede utilizar para proporcionar una comunicación directa de datos segura o para facilitar la distribución de claves criptográficas en las redes 5G.

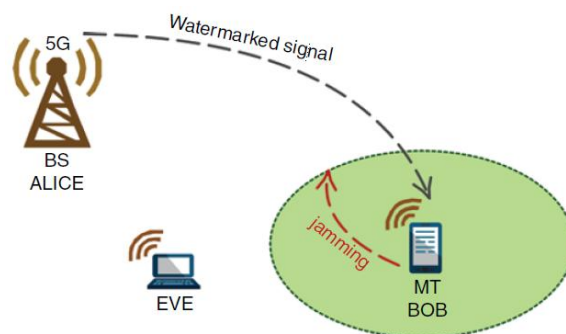


Figura 31: WBPLSec aplicado a la red 5G

La Figura 31 muestra cómo se puede aplicar WBPLSec a las redes 5G. La estación base (BS), marcada como Alice, envía la señal con marca de agua al terminal móvil (MT), marcado como Bob. Se asume que Bob tiene múltiples interfaces de radio para recibir y bloquear la señal recibida. La técnica WBPLSec crea una región segura alrededor de Bob, en la que cualquier otro MT, como Eve, no puede escuchar la información.

WBPLSec ofrece la posibilidad de evitar el uso de la criptografía en las capas superiores, lo que hace que la seguridad de la capa física sea atractiva como una solución de seguridad independiente que también puede mejorar la duración de la batería, ya que ahorra computación en comparación con el cifrado.

3.3.2 Seguridad en la capa de enlace de datos

La seguridad del enlace de datos es necesaria para garantizar que los datos fluyan entre los puntos finales autorizados y no se desvíen o intercepten mientras están en tránsito. Las generaciones anteriores, es decir, 3G y 4G, no proporcionaban integridad criptográfica a la comunicación del plano del usuario. En 5G, será una preocupación de seguridad importante y expondrá la comunicación privada no solo entre usuarios, pero entre dispositivos que transportan información confidencial, como datos de sistemas de atención médica y otras infraestructuras críticas. Por lo tanto, se necesitan nuevos mecanismos para asegurar la comunicación de datos entre usuarios y dispositivos.

El protocolo OpenFlow admite Seguridad de la capa de transporte (TLS) y Seguridad de la capa de transporte de datagramas (DTLS). TLS se utiliza para proporcionar privacidad e integridad de datos para la comunicación entre usuarios. DTLS se utiliza para proteger los datos entre las aplicaciones que se comunican, principalmente el tráfico UDP. Estas tecnologías utilizan criptografía simétrica para el cifrado de datos.

Además del uso de TLS y DTLS, las redes virtuales o la segmentación de red se pueden utilizar para proporcionar canales de comunicación privados tanto para los datos como para la información de control, como se muestra en la Figura 32. La segmentación también puede proporcionar integridad y privacidad de datos basada en el aislamiento. Las secciones de usuarios individuales se pueden separar mediante un hipervisor de red como FlowVisor. El aislamiento del tráfico se puede utilizar para proteger un tipo de tráfico de otro para fortalecer la confidencialidad y la integridad del tráfico de

usuarios. La técnica OpenFlow Random Host Mutation (OF-RHM) consigue evitar ataques de escaneo en hosts finales.

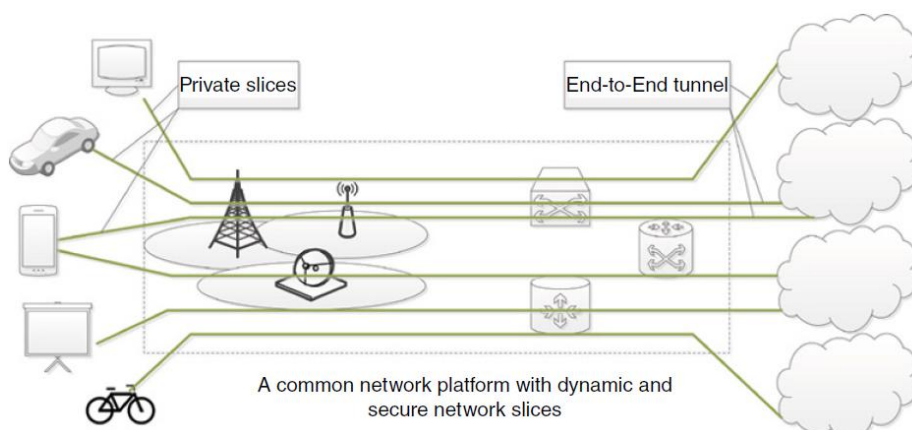


Figura 32: Segmentos de red seguros para diferentes servicios

3.3.3 Seguridad en la capa de control

Los canales de control transportan la información de control entre el usuario y la red, y entre las entidades de red.

La autenticación mutua y el acuerdo de claves entre la UE y la red son importantes en muchos aspectos, siendo el más importante el seguro de identidad de la UE. En LTE, la UE y la red, o sus entidades como la Entidad de Gestión de la Movilidad (MME), realizan la autenticación mutua a través del Acuerdo de Autenticación y Clave (AKA) del Sistema de Paquetes Evolucionado (EPS), conocido como EPS-AKA. Cuando un UE se conecta al EPC a través de la red de acceso que no es 3GPP, el UE se autentica a través del servidor AAA. Para redes de acceso confiables que no son 3GPP, el servidor UE y AAA utilizan el EAP-AKA o el EAP-AKA mejorado para la autenticación. Para las redes de acceso no 3GPP no confiables, la UE utiliza el establecimiento de túnel IPsec de puerta de enlace de datos de paquetes evolucionados (ePDG) para conectarse al EPC. Dichos canales de control, además de ser seguros, tienen los siguientes beneficios:

- Los mensajes son cortos en comparación con otros protocolos de autenticación.
- Solo requiere un protocolo de enlace entre la UE y la red de servicio, y entre las redes de servicio y domésticas.
- El HSS se actualiza a través de la red de servicio, por lo que es capaz de manejar muchas solicitudes.
- El protocolo basado en clave simétrica hace que los cálculos requeridos en el centro de autenticación (parte del HSS) y en el USIM (Universal Subscriber Identity Module) sean muy eficientes en comparación con los mecanismos basados en clave pública.

La variante OpenFlow de SDN utiliza TLS, en el que los certificados de identificación se comprueban correctamente en cualquier dirección y permiten cifrar el canal de control para asegurarlo y evitar que escuche a escondidas.

Además, IPsec es el protocolo de seguridad más utilizado para asegurar los canales de comunicación en las redes de telecomunicaciones actuales, como 4G-LTE. Por lo tanto, se diseñaron nuevas arquitecturas de comunicación basadas en IPsec para asegurar el control y los canales de datos de 5G. La arquitectura propuesta utiliza seguridad distribuida, puertas de enlace (SecGW) para proteger el controlador y túneles de modo IPsec Encapsulating Security Payload (ESP) Bounded-End-to-End-Tunnel (BEET) para proteger el control y la comunicación de los canales de datos. Además, también se propone el mecanismo de seguridad basado en el protocolo de criptografía basada en la identidad (IBC) para asegurar el tráfico entre controladores y canales de control en redes SDN generales de múltiples controladores.

3.3.4 Monitorización de tráfico

La monitorización del tráfico se puede utilizar para detectar intrusiones y prevenirlas. Los sistemas de detección de intrusiones (IDS) y los sistemas de prevención de intrusiones (IPS) observan el tráfico de la red de acuerdo con diferentes políticas de seguridad, encuentran vulnerabilidades, amenazas y

ataques, y utilizan contramedidas para proteger la red. En las redes tradicionales, los planos de control de los elementos de red están débilmente acoplados con una comunicación limitada entre sus planos de control. Por lo tanto, las tecnologías IDS e IPS en cada dominio de red están configuradas independientemente para hacer frente a los desafíos en su dominio. Esto hace que los sistemas actuales sean difíciles de actualizar con los tipos de ataques y vectores de amenazas recientemente identificados.

SDN toma una ruta diferente al permitir que las aplicaciones recuperen estadísticas de conmutadores o extraigan muestras de paquetes de flujos para el análisis de seguridad. Después del análisis de seguridad, las solicitudes pueden indicar al controlador que elimine los paquetes o los reenvíe a los sistemas de seguridad o cajas intermedias para una mayor investigación. Por lo tanto, SDN hace que la supervisión del tráfico sea bastante simple al permitir la visibilidad global del comportamiento del tráfico de red y la programabilidad de la red.

3.3.5 Control de acceso

Los mecanismos tradicionales de control de acceso utilizan firewalls desplegados en los límites (edge) de la red para examinar los paquetes entrantes o salientes para evitar ataques y accesos no autorizados. Por lo tanto, los insiders son considerados como socios de confianza. Esto puede conducir a graves violaciones de seguridad, ya que los usuarios en la zona interna podrían lanzar ataques o eludir los mecanismos de seguridad. Además, los cambios en las políticas de red y las condiciones de tráfico requieren una configuración compleja de los firewalls, lo que hace que sea aún más complicado mantener la seguridad en su lugar.

SDN permite la automatización a través de la programabilidad y centraliza el control de red que logra visibilidad global del comportamiento del tráfico de red. Por lo tanto, el tráfico proveniente del exterior y el tráfico originado dentro de la red se pueden monitorizar fácilmente. Del mismo modo, el tráfico que se origina dentro de la red también se puede verificar fácilmente actualizando las tablas de flujo del conmutador, de la misma manera que el tráfico proveniente de fuera de la red. Ya se han desarrollado varias aplicaciones de firewall para SDN, como Network Flow Guard (NFG) y OpenFlow firewall.

3.3.6 Resiliencia de red

Los mecanismos de resiliencia de la red ayudan a la red a operar en presencia de diversos desafíos, como ataques cibernéticos, configuraciones incorrectas, sobrecarga operativa o fallos en los equipos. La red debe ser capaz de proporcionar servicios a los usuarios cuando se producen tales desafíos. Las estrategias básicas de resiliencia incluyen defender, detectar, remediar, recuperar, diagnosticar y refinar (D2R2 + DR). A través de la visibilidad global y un ciclo de recolección de inteligencia de la red subyacente, el plano de control SDN se mantiene actualizado de la situación de la red. Con APIs programables en equipos de red, se consigue una reacción rápida ante fallos en equipos de red y mala configuración. Se desarrollan marcos de resiliencia basados en SDN que proporcionan una gestión controlada por políticas con una configuración de red basada en políticas de acuerdo con estrategias de resiliencia. Otros enfoques incluyen el uso de múltiples controladores para aumentar la resiliencia de los SDN.

3.3.7 Sistemas de seguridad y cortafuegos

Las aplicaciones de red móvil y los middleboxes son administrados de forma independiente por operadores móviles y desarrolladores de aplicaciones. Los desarrolladores de aplicaciones desconocen las políticas de middlebox aplicadas por los operadores. Los operadores tienen menos conocimiento del comportamiento y los requisitos de la aplicación. Tal desajuste o falta de comprensión puede crear posibles desafíos de seguridad.

Normalmente, el tráfico se enruta a varios middleboxes para realizar una evaluación de seguridad de la red o verificar el comportamiento y la legalidad del tráfico. Sin embargo, las cajas intermedias tradicionales tienen una serie de desafíos con respecto a su ubicación, escalabilidad y alteración de la política de seguridad. Estos desafíos ocurren principalmente debido a configuraciones manuales complejas, la necesidad de colocación de middleboxes específicos de ruta y la falta de flexibilidad de las arquitecturas de red existentes.

SDN hace que la implementación de middleboxes sea simple y elegante a través de la programabilidad de la red y el control centralizado de la red. Una buena práctica consiste en integrar el procesamiento

de middleboxes en la propia red, utilizando los conceptos de SDN para la consistencia de las políticas y una mayor visibilidad del comportamiento de los middleboxes a través de un control centralizado.

3.3.8 Automatización de la seguridad de red

La automatización es el proceso de minimizar la interacción hombre-máquina mediante la delegación de funciones de control complejas a las máquinas para mayor fiabilidad y precisión. El objetivo principal de la ejecución de funciones complejas por parte de la máquina, llamada automatización, es la precisión y la fiabilidad a través de:

- adquisición de información;
- análisis de la información;
- selección de decisiones y acciones; e
- implementación de acciones.

SDN permite políticas consistentes en toda la red a través de la visibilidad global de los sistemas generales de red y las políticas implementadas en cada uno. Al permitir la programabilidad y abstraer las configuraciones de bajo nivel de las cajas individuales, SDN proporciona lenguajes de diseño y controladores de red que son capaces de reaccionar automáticamente al estado cambiante de la red. SDN mejora la automatización de muchos procesos y procedimientos, incluida la administración y reconfiguración de redes físicas y virtuales, e introduce la posibilidad de implementar nuevos servicios automatizados.

Procera es un marco de control de red para operadores, que implementa políticas flexibles basadas en la vista de red. Procera asigna políticas basadas en eventos de alto nivel a políticas basadas en configuración de red de bajo nivel, eliminando así la necesidad de configuraciones manuales. La infraestructura de gestión de OpenFlow (OMNI) simplifica la gestión de OpenFlow y proporciona mecanismos para una plataforma de control autónomo con capacidad de respuesta.

Dado que la cantidad de dispositivos conectados en 5G será enorme (los requisitos de latencia serán estrictos, lo que requerirá una detección rápida de amenazas y una respuesta más rápida), la automatización de la seguridad será necesaria. La visibilidad global de todo el comportamiento de la red permitirá la detección rápida de amenazas y la programabilidad de la red permitirá una mitigación de amenazas más rápida. Dado que estas características serán creadas por SDN, la automatización basada en SDN será muy valiosa en las redes 5G.

3.4 Conclusión

En este capítulo se ha cubierto el panorama de amenazas en evolución de las redes móviles, comenzando desde 1G cuando los móviles ofrecían servicios de solo voz y cuando las amenazas de seguridad giraban principalmente en torno a las ganancias financieras mediante la clonación de los teléfonos móviles. Luego se ha analizado cómo evolucionaron las amenazas de seguridad y se dirigieron a la infraestructura de la red móvil, como las estaciones base, causando un impacto más amplio. Con la introducción de servicios de datos y dispositivos móviles reemplazados por smartphones, y de redes móviles construidas sobre un núcleo IP, las amenazas de seguridad también se ampliaron notablemente. Los dispositivos móviles eran una fuente importante de transporte de spywares, gusanos y malwares, y cada día se encontraba una nueva vulnerabilidad en los sistemas operativos móviles, ya que miles de millones de dispositivos obtuvieron acceso a aplicaciones inseguras, causando un impacto inconcebible. Las redes 5G están planificadas para servir como una infraestructura crítica para los negocios y ofrecen nuevas capacidades como la nube, IoT y banda ultra-ancha, que afrontarán desafíos únicos y se convertirán en el objetivo de amenazas de seguridad sofisticadas como ransomware y botnets.

Los conceptos de SDN y NFV permiten actualizaciones rápidas de la red, facilitan la implementación de nuevas tecnologías y servicios, y permiten la implementación paralela de tecnologías y servicios antiguos y nuevos. Al ser de naturaleza programable, estas tecnologías también abren el campo de la creación de redes para la innovación. Esta es la razón por la que los nuevos sistemas y servicios de seguridad ya están desarrollados por la industria, la academia y las personas que trabajan en proyectos de código abierto.

4 Resumen esquemático

- 1) La seguridad en redes.
 - a. Estándares de seguridad: ISO 27001, ISO 27002.
 - b. Fundamentos de seguridad de red: Confidencialidad, Integridad y Disponibilidad (CIA)
 - i. Aplicación de principios de seguridad fundamentales al diseño de redes:
Principio de mínimo privilegio, Defensa en profundidad (DID), Separación de funciones y Auditoría.
 - ii. Topologías de red: CAN, WAN, DC, SOHO.
 - iii. Seguridad de red para un entorno virtual.
 - c. Seguridad en **WiFi**: WEP, WPA, WPA2 y **WPA3**.
 - d. Seguridad en **SDN**.
 - i. **VXLAN y overlays.**
 - ii. **Microsegmentación.**
 - iii. Iniciativas de código abierto: Neutron, OVN, OVS, ODL, Contiv.
 - e. Seguridad en la **nube**.
 - i. Estándares de seguridad en la nube: ISO 27017, ISO 27018.
 - ii. **Arquitectura serverless**
 - iii. **DevSecOps**: Fuzzing, SAST, DAST.
 - iv. **Zero Trust**.
 - v. Seguridad en la nube en un entorno multinube o de nube híbrida.
- 2) Tipos de ataques y herramientas para su prevención.
 - a. **Tipos de ataques**
 - i. Ataques distribuidos de denegación de servicio (**DDoS**): directo, reflejado, de amplificación.
 - ii. Métodos de **ingeniería social**: phishing, publicidad, estafas.
 - iii. Métodos de pérdida y **exfiltración de datos**
 - iv. **Virus y gusanos**
 - v. **Trojanos**
 - vi. Distribución de **malware**: wrappers, packers, droppers y cripters
 - vii. **Ransomware**
 - viii. **Comunicación encubierta**
 - ix. **Keyloggers**
 - x. **Spyware**: vigilancia y publicidad.
 - xi. Ataques de computación en la nube.
 - xii. Amenazas de seguridad de IoT.
 - b. **Herramientas para la prevención de ataques**:
 - i. **Cortafuegos**.
 1. Metodologías: Filtrado estático de paquetes, puerta de enlace de la capa de aplicación, filtrado de paquetes con estado (stateful), inspección de aplicaciones, firewalls transparentes.
 2. **NGFW**
 3. **NAT y PAT**
 4. Configuraciones: basado en host de red, dual-homed host, basado en router y host filtrado.
 - ii. **Control de accesos: Autenticación, Autorización y Accountability (AAA)**
 1. **Autenticación por conocimiento, por propiedad o posesión, por característica y multifactor.**
 2. **Autorización: MAC, DAC, RBAC, ABAC y basada en reglas.**
 3. **Protocolos AAA: RADIUS, TACACS+, Diameter. 802.1X.**
 4. **ACL: ACL de VLAN, SGACL, dACL.**
 - iii. **Control de intrusiones: IDS, IPS, NGIPS.**
 1. Técnicas IPS: **snort, honeypots, DAM/DAMP, deflexión de intrusión, disuasión de intrusiones.**
 2. Identificación del tráfico malicioso: **IPS/IDS basados en firmas, en políticas, en anomalías y en reputación.**

- iv. **Técnicas criptográficas: PPTP, IPsec** (AH, ESP, SA, ISAKMP, IKE), **SSL/TLS**
- 3) Medidas específicas para las comunicaciones móviles.
 - a. **La seguridad en redes móviles:** amenazas [A] y medidas de protección [MP].
 - i. 1G. [A]: Clonación. [MP]: Mecanismos de identificación.
 - ii. 2G. [A]: MitM. [MP]: Autenticación SIM.
 - iii. 3G. [A]: Virus, spyware. [MP]: Autenticación AKA.
 - iv. **4G.** [A]: **APT, DDoS.** [MP]: **cifrado, anti-DDoS, SDN**
 - v. **5G.** [A]: **Ataques a infraestructuras críticas.** [MP]: **modelo de seguridad evolucionado**
 - b. Aspectos fundamentales de la seguridad en las **redes 5G.**
 - i. Capa física: **WBPLSec.**
 - ii. Capa de enlace de datos: **OpenFlow.**
 - iii. Capa de control: **AKA EPS,** IPsec, IBC.
 - iv. Monitorización de tráfico.
 - v. Control de acceso: NFG.
 - vi. Resiliencia de red.
 - vii. Sistemas de seguridad y cortafuegos: **middleboxes.**
 - viii. Automatización de la seguridad de red: **programabilidad SDN.**

5 Glosario

Acrónimo	Significado
AAA	Authentication, Authorization and Accounting
ABAC	Attribute-Based Access Control
ACL	Access Control List
AH	Authentication Header
AKA	Authentication and Key Agreement
APT	Advanced Persistent Threat
ASDM	Adaptive Security Device Manager
AVP	Attribute Value Pair
BEEET	Bounded-End-to-End-Tunnel
CAN	Campus Area Network
CASB	Cloud Access Security Broker
CHAP	Challenge Handshake Authentication Protocol
CIA	Confidentiality, Integrity and Availability
CSP	Cloud Service Provider
DAC	Discretionary Access Control
dACL	Downloadable Access Control List
DAST	Dynamic Application Security Test
DC	Data Center
DDoS	Distributed Denial of Service
DID	Defense in Depth
DPI	Deep Packet Inspection
DoS	Denial of Service
DTLS	Datagram Transport Layer Security
EAP	Extensible Authentication Protocol
EAPoL	Extensible Authentication Protocol over Local Area Network
EPS-AKA	Authentication and Key Agreement Evolved Packet System
ESP	Encapsulating Security Payload
FWaaS	Firewall as a Service
GENEVE	Generic Network Virtualization Encapsulation
HTTPS	Hypertext Transfer Protocol Secure
ICMP	Internet Control Message Protocol
IdAM	Identity and Access Management (IdAM)
IDS	Intrusion Detection System
IKE	Internet Key Exchange
IPS	Intrusion Prevention System
IPsec	Internet Protocol security
ISAKMP	Internet Security Association and Key Management Protocol
KDC	Key Distribution Center
L2TP	Layer 2 Tunnel Protocol
MAC	Mandatory Access Control
MFA	MultiFactor Authentication

Acrónimo	Significado
MPPE	Microsoft Point-to-Point Encryption
MSP	Multicloud Service Provider
NaaS	Network as a Service
NAT	Network Address Translation
NFV	Network Functions Virtualization
NGFW	Next Generation Firewall
NGIPS	Next Generation Intrusion Protection System
NTP	Network Time Protocol
NVGRE	Network Virtualization using Generic Routing Encapsulation
PAT	Port Address Translation
PCI DSS	Payment Card Industry Data Security Standard
PPP PAP	Point to Point Protocol - Password Authentication Protocol
PPTP	Point to Point Tunnel Protocol
RADIUS	Remote Authentication Dial-In User Service
RAT	Remote Access Trojan
RBAC	Role-Based Access Control
SA	Security Associations
SAST	Static Application Security Test
SCTP	Stream Control Transmission Protocol
SDN	Software Defined Network
SecGW	Security Gateway
SGACL	Security Group Access Control List
SGSI	Sistema de Gestión de Seguridad de la Información
SOHO	Small Office/Home Office
SSH	Secure Socket Shell
STT	Stateless Transport Tunnel
TACACS+	Terminal Access Controller Access Control System Plus
TAN	Transaction Authentication Number
TCP	Transmission Control Protocol
TLS	Transport Layer Security
UART	Universal Asynchronous Receiver-Transmitter
UDP	User Datagram Protocol
UEBA	User and Entity Behavior Analytics
USIM	Universal Subscriber Identity Module
VLAN	Virtual Local Area Network
VNF	Virtual Network Function
VPN	Virtual Private Network
VTEP	VXLAN Tunnel End Point
VXLAN	Virtual eXtensible Local Area Network
WAN	Wide Area Network
WBPLSec	Watermark-based Blind Physical Layer security
WEP	Wired Equivalent Privacy
WPA	WiFi Protected Access

6 Test

6.1 Preguntas de test

- 1) ¿Cuál es el término para un firewall que es simplemente software instalado en un servidor existente?
 - a) Basado en host de red
 - b) Dual-homed
 - c) Basado en router
 - d) Anfitrión filtrado

- 2) ¿Cuál es una debilidad importante con un firewall basado en host de red?
 - a) Su seguridad depende del sistema operativo subyacente
 - b) Es difícil de configurar
 - c) Puede ser fácilmente hackeado
 - d) Es muy caro.

- 3) ¿Cuál es el término para un sistema falso diseñado para atraer intrusos?
 - a) Honeypot
 - b) Sistema falso
 - c) Sistema de deflexión
 - d) Atrapamiento

- 4) ¿Qué método utilizan la mayoría de las implementaciones de software IDS?
 - a) Detección de anomalías
 - b) Bloqueo preventivo
 - c) Disuasión de intrusiones
 - d) Infiltración

- 5) ¿Cómo se llama un DoS lanzado desde varias máquinas simultáneamente?
 - a) Ataque de área amplia
 - b) Ataque smurf
 - c) Inundación SYN
 - d) Ataque DDoS

- 6) ¿Qué puede hacer con un firewall para defenderse contra los ataques DoS?
 - a) Bloquear todo el tráfico entrante
 - b) Bloquear todos los paquetes TCP entrantes
 - c) Bloquear todo el tráfico entrante en el puerto 80
 - d) Bloquear todos los paquetes ICMP entrantes

- 7) ¿Por qué la protección contra los troyanos reduce los ataques DoS?
 - a) Debido a que muchos ataques de denegación de servicio se llevan a cabo mediante el uso de un caballo de Troya para obtener una máquina desprevenida para ejecutar el DoS
 - b) Porque si puede detener un ataque de caballo de Troya, también detendrá los ataques DoS
 - c) Porque un caballo de Troya a menudo abrirá puertos permitiendo un ataque DoS

- d) Porque un caballo de Troya ataca de la misma manera que un ataque DoS
- 8) ¿Cuál de los siguientes no es un ejemplo de ransomware?
- a) WannaCry
 - b) Nyeta
 - c) Bad Rabbit
 - d) Ret2Libc
- 9) ¿Cuál de estos ataques ocurre cuando las fuentes del ataque reciben paquetes falsificados que parecen ser de la víctima, y luego las fuentes se convierten en participantes involuntarios en los ataques DDoS al enviar el tráfico de respuesta a la víctima prevista?
- a) DDoS reflejado
 - b) DoS directo
 - c) Retroceso DoS
 - d) Inundación SYN
- 10) ¿Un ataque de denegación de servicio afecta a cuál de los siguientes?
- a) Integridad
 - b) Disponibilidad
 - c) Confidencialidad
 - d) Ninguna de las respuestas es correcta.
- 11) ¿Cuál de los siguientes es un ejemplo de herramientas y métodos para hackear dispositivos IoT?
- a) Depuradores UART
 - b) Analizadores JTAG
 - c) IDA
 - d) Ghidra
- 12) ¿Cuál de los siguientes es un proyecto de código abierto que permite implementar servicios basados en políticas de microsegmentación en entornos de contenedores?
- a) OVS
 - b) Contiv
 - c) ODL
 - d) Todas las anteriores
- 13) A lo largo de los años se han introducido múltiples mecanismos de túnel IP. ¿Cuáles de los siguientes son ejemplos de mecanismos de túnel IP?
- a) VXLAN
 - b) SST
 - c) NVGRE
 - d) Todas las respuestas son correctas.
- 14) ¿Cuál de las siguientes afirmaciones es cierta acerca de SDN?
- a) SDN proporciona numerosos beneficios en el área del plano de gestión. Estos beneficios se encuentran tanto en conmutadores físicos como en conmutadores virtuales.

- b) SDN cambió algunas cosas en los planos de administración, control y datos. Sin embargo, el gran cambio fue en los planos de control y datos en switches y routers basados en software (incluyendo switches virtuales dentro de hipervisores).
 - c) SDN ahora se adopta ampliamente en los centros de datos.
 - d) Todas las respuestas son correctas.
- 15) ¿Cuál de las siguientes opciones se utiliza para crear superposiciones de red?
- a) SDN-Lane
 - b) VXLAN
 - c) VXWAN
 - d) Ninguna de las respuestas es correcta
- 16) ¿Cuál de las siguientes opciones describe el tipo de autenticación en la que el usuario proporciona un secreto que solo él o ella conoce?
- a) Autenticación por contraseña
 - b) Autenticación por conocimiento
 - c) Código de número de identificación personal (PIN)
 - d) Autenticación por características
- 17) ¿Cuál de las siguientes opciones define cómo se conceden los derechos de acceso y permisos? Ejemplos de ese modelo incluyen capacidad de objetos, etiquetas de seguridad y ACL.
- a) Un modelo de control de acceso obligatorio (MAC)
 - b) Un modelo de autorización
 - c) Un modelo de autenticación
 - d) Un modelo de responsabilidad (accounting)
- 18) ¿Cuál de las siguientes afirmaciones es verdadera?
- a) RADIUS usa UDP y TACACS+ usa TCP.
 - b) En RADIUS, la autenticación y la autorización se realizan con el mismo intercambio. La responsabilidad se realiza con un intercambio separado.
 - c) RADIUS proporciona compatibilidad limitada para la autorización de comandos. TACACS+ proporciona autorización de comandos granular.
 - d) Todas estas respuestas son correctas.
- 19) Los dispositivos de acceso a la red (como los conmutadores de red y los puntos de acceso inalámbricos) pueden utilizar un protocolo IEEE que, cuando está habilitado, permitirá el tráfico en el puerto solo después de que el dispositivo haya sido autenticado y autorizado. ¿Cuál de los siguientes es un estándar IEEE que se utiliza para implementar el control de acceso basado en puertos?
- a) 802.11ac
 - b) 802.1Q
 - c) 802.1X
 - d) pxGrid
- 20) ¿Cuál de las siguientes afirmaciones es cierta acerca de los controles de acceso discrecional (DAC)?
- a) Los controles de acceso discrecional (DAC) son definidos por el propietario del objeto.
 - b) Los DAC se utilizan en sistemas operativos comerciales.

- c) El propietario del objeto crea una ACL que permite o deniega el acceso al objeto en función de la identidad única del usuario.
- d) Todas estas opciones son correctas.

21) 802.1x utiliza cuál de los siguientes protocolos?

- a) EAPoL
- b) EAP
- c) RADIUS
- d) Todas las opciones son correctas.

22) ¿Cuál de las siguientes afirmaciones es verdadera?

- a) IKEv1 e IKEv2 son protocolos incompatibles; por lo tanto, no puede configurar un dispositivo IKEv1 para establecer un túnel VPN con un dispositivo IKEv2.
- b) IKEv1 e IKEv2 son protocolos compatibles; posteriormente, puede configurar un dispositivo IKEv1 para establecer un túnel VPN con un dispositivo IKEv2.
- c) IKEv1 e IKEv2 son protocolos incompatibles; sin embargo, ambos admiten EAP para la autenticación.
- d) En las implementaciones de IKEv1, se intercambian menos paquetes y se necesita menos ancho de banda en comparación con IKEv2.

23) ¿Qué tipo de ataque implica mentir sobre la dirección de origen de una trama o paquete?

- a) Ataque de hombre en el medio
- b) Ataque de denegación de servicio
- c) Ataque de reconocimiento
- d) Ataque de suplantación de identidad

24) ¿Qué dos enfoques de seguridad proporcionan los resultados más seguros desde el primer día?

- a) DoS, DDoS
- b) Defensa en profundidad, Mínimo privilegio
- c) Autenticación, autorización
- d) ABAC, RBAC

25) ¿Cuál de las siguientes no es una forma de ingeniería social?

- a) Estafas telefónicas
- b) Phishing
- c) Denegación de servicio (DoS)
- d) Publicidad maliciosa

26) ¿Qué método debe implementar cuando no es aceptable que un ataque llegue a su víctima prevista?

- a) IDS
- b) IPS
- c) Fuera de banda
- d) Dispositivo de hardware

27) ¿Qué método de IPS utiliza una línea de base del comportamiento normal de la red y busca desviaciones de esa línea de base?

- a) IPS basado en la reputación

- b) IPS basado en políticas
- c) IPS basado en firmas
- d) IPS basado en anomalías

28) ¿Qué tipo de implementación requiere que el administrador cree firmas personalizadas?

- a) IPS basado en la reputación
- b) IPS basado en políticas
- c) IPS basado en motor
- d) IPS basado en anomalías

29) ¿Qué tipo de amenazas son las que mayor impacto tienen sobre las redes 4G de telefonía?

- a) DoS
- b) Clonación
- c) DDoS
- d) Ransomware

30) ¿En qué generación de red de telefonía móvil se empieza a aplicar el protocolo WBPLSec?

- a) 5G
- b) 2,5G
- c) 6G
- d) 4G

6.2 Soluciones a las preguntas de test

PREGUNTA	SOLUCIÓN
1	D
2	A
3	A
4	A
5	D
6	D
7	A
8	D
9	A
10	B
11	D
12	B
13	D
14	D
15	B
16	B
17	B
18	D
19	C
20	D
21	D
22	A
23	D
24	B
25	C
26	B
27	D
28	B
29	C
30	A

7 Bibliografía básica

7.1 Bibliografía básica

1. Computer Security Fundamentals. Easttom C., Pearson.
2. Cryptography and Network Security. Stallings, W., Prentice Hall.
3. RFC 2401 Security Architecture for the Internet Protocol. Kent, S., Atkinson, R.
4. Towards 5G security. Proceedings of the 4th IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom). Horn, G. and Schneider, P.

7.2 Bibliografía para ampliar el tema

1. Security Engineering: A Guide to Building Dependable Distributed Systems. Anderson, R., Wiley.
2. The Internet Security Guidebook. Ellis, J. and Speed, T., Academic Press.
3. Computer Networks. Tanenbaum, A. S., Prentice Hall.